국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

K-20-RN-0203-N

자동화 기반 과학기술정보보호서비스

(Science and Technology Security Service Based on Automation)

한국과학기술정보연구원

2020년

과학기술정보통신부

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제 출 문

과학기술정보통신부 장관 귀하

본 보고서는 과학기술정보통신부 정부출연금에서 지원하는 “한국과학기술정보연구원 운영사업” 중 “**자동화 기반 과학기술정보보호 서비스**”과제의 보고서로 제출합니다.

2020 12. 31.

주관연구기관명 : 한국과학기술정보연구원

주관연구책임자 : 과학기술사이버안전센터장 이 혁 로

참 여 연 구 원 : 과학기술사이버안전센터 박학수, 최윤수
이행곤, 김진숙
박진형, 최상수
김규일, 송중석
송보연, 이윤수
주광일, 허완영
최지우, 송태욱
권태웅, 문형우
김태용, 박건량
오채연, 박경선
박지은, 차충일
신익수, 최익제
고영민, 강소영
INDRA KUMARI

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

보고서 초록

<table>
<tr><td>과제관리번호</td><td></td><td>해당단계
연구기간</td><td>2020.1.1~2020.12.31</td><td>단계 구분</td><td>3차년도 / 3차년도</td></tr>
<tr><td rowspan="3">연구사업명</td><td>대 과 제 명</td><td colspan="4">국가 슈퍼컴퓨팅 연구 · 서비스</td></tr>
<tr><td>세부과제명</td><td colspan="4">자동화 기반 과학기술정보보호서비스</td></tr>
<tr><td>과제명(영문)</td><td colspan="4">Science and Technology Security Service Based on Automation</td></tr>
<tr><td>연구책임자</td><td>이 혁 로</td><td>해당단계
참여연구원수</td><td>총 : 27명
내부 : 17명
외부 : 10명</td><td>해당단계
연구비</td><td>정부 : 2,361 천원
기업 : - 천원
계 : 천원</td></tr>
<tr><td>연구기관명
소속부서명</td><td colspan="3">한국과학기술정보연구원 과학기술사이버안전센터</td><td>참여기관명</td><td>-</td></tr>
<tr><td>국제공동연구</td><td colspan="5">-</td></tr>
<tr><td rowspan="2">위 탁 연 구</td><td colspan="5">연구기관명 : 고려대학교 연구책임자 : 이희조</td></tr>
<tr><td colspan="5">연구기관명 : 고려대학교 연구책임자 : 노희준</td></tr>
<tr><td colspan="4">요 약</td><td>보고서 페이지</td><td>88</td></tr>
</table>

□ 연구개발 최종목표

○ 자동분석·처리를 통한 사이버위협 침해대응 신속성 향상

○ 인공지능 기술을 활용한 자동화 기반 보안관제 기술연구·적용 및 확산

□ 연구개발 내용

○ 과학기술분야 정보보호 컨트롤 타워 역할 및 핵심 연구정보자원 보호

○ 과학기술계 사이버위협 대응체계 통합 및 고도화

○ 인공지능 기반 대용량 위협데이터 자동분석·대응 기술연구 및 적용

○ 대규모 네트워크 기반 이상행위 탐지·분석·대응 기술연구 및 적용

○ 기관 정보보안·정보통신망 정책 및 인프라 운영을 비롯한 전주기적 정보보호 활동

□ 활용계획 및 기대효과

○ (활용측면) 대용량 사이버위협 정보를 자동으로 분석·처리하는 기술을 국내 정보보호 관련 중소·중견 기업에 이전하여 보안시장 성장을 지원하고 기관 정보인프라에 대한 침해위협 최소화 실현

○ (기대효과) 과학기술분야 정보보호 컨트롤타워 역할 수행을 통한 지능화된 사이버 침해사고 피해방지 자체 개발한 첨단 보안관제 기술을 유관기반에 전파하여 국가차원의 대응공조체계 강화

색 인 어	한 글	사이버안전센터, 인공지능, 보안관제, 자동분석·대응, 이상행위 탐지
	영 어	Cyber Security Center, Artificial Intelligence, Security Monitoring, Automatic Analysis and Response, Anomaly Detection

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

요 약 문

I. 과제명 : 자동화 기반 과학기술정보보호 서비스

II. 연구개발의 목적 및 필요성

자동분석·처리를 통한 사이버위협 침해대응 신속성 향상

인공지능 기술을 활용한 자동화 기반 보안관제 기술연구 · 적용 및 확산

○ 지능정보화시대인 4차 산업혁명의 시대는 디지털 기술로 촉발되는 초연결 기반의 지능화 혁명으로 인공지능(AI), 빅데이터와 같은 지능정보 기술이 핵심적인 역할을 수행할 것으로 예상

○ 인공지능 분야는 전세계적으로 폭넓은 영향력을 미칠 것으로 예상되며 그 중에서 '인공지능 강화(AI Foundation)'부문은 가장 첫 번째로 기술 정점화를 달성할 것으로 예측

○ 기존의 범용성에 초점을 맞춘 'General AI' 분야와 달리, 특정 업무를 수행하기 위해 최적화된 알고리즘 기반 머신러닝 기술을 토대로한 'Narrow AI'개발에 집중이 필요한 상황

○ 정보보호업계에서는 인공지능 기반 정보보안 솔루션 개발에 박차를 가하고 있으며, 글로벌 보안전문기업인 IBM과 Oracle 등에서 집중적인 연구개발 투자를 수행하고 있음

○ 보안관제분야에서는 이기종 보안위협 정보를 통합하여 신속성과 정확성을 향상하기 위한 기술개발을 수행하고 있으나 단순히 빅데이터 처리기술에 적용하는 수준에 불과

○ 한국과학기술정보연구원은 과학기술분야 정보보안체계 구축·운영 및 지원이라는 고유임무를 달성하기 위하여 2005년부터 국가 핵심 보안관제센터인 과학기술사이버안전센터를 운영 중임

○ 과학기술분야는 선진국 도약을 위한 핵심 성장동력으로 연구데이터의 중요성과 가치가 높은 만큼 이에 대한 정보자원의 보호 및 유출에 대비한 선제적 침해대응 체계가 필요

○ 급변하는 사이버위협 상황에 대한 신속·정확한 보안관제 및 침해대응을 수행하기 위해 사이버위협 준자동분석 기반 보안관제 기술을 개발 및 적용할 필요

○ 4차 산업혁명시대에 안전한 연구데이터 생태계 조성을 위해 인공지능 기반 사이버위협 자동분석 기술개발·적용을 통해 보안관제 패러다임 전환이 반드시 필요한 상황

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

III. 연구개발의 범위 및 결과

1. 과학기술분야 사이버위협 통합대응체계 구축 및 서비스

○ 24시간×365일 실시간 보안관제·분석을 통한 신속·정확한 사이버공격 대응활동 강화
- 과학기술정보통신부 산하 연구·공공기관 60여개 기관 대상으로 중앙기관 보안정책을 기반한 집중 보안관제 및 기술지원 활동 수행
- 과학기술연구망 활용기관 및 첨단 연구자 그룹 200여개 대상으로 사이버안전 유관기관과 함께 공동대응체계 강화를 바탕으로 보안관제 중점수행 및 침해예방 기술지원 확대

○ 국내 최고 수준의 보안관제 연구·개발 기술력과 운용 노하우 접목으로 사이버공격 탐지·분석·대응의 신속성·정확성 극대화
- 독자개발한 통합보안정보분석시스템(SMARTer) 연계 및 지속적인 고도화를 통해 국내 유일의 사이버안전 골든타임 달성률 제고
- 대용량 보안정보 자동분석 모델 설계 및 개발을 위한 인공지능 알고리즘 테스트 플랫폼 개발로 대규모 네트워크 원본 보안이벤트를 자동분석·대응 기술연구 적용

○ 대규모 네트워크 기반 이상행위 탐지·분석·대응 기술연구 및 적용
- 과학기술연구망(KREONET)을 통해 발생하는 대용량 침해위협 정보를 직관적으로 모니터링할 수 있는 실시간 모니터링 및 탐지 분석하기 위한 가시화 방법론 구축
- 기존 체계의 사각지대인 암호화통신에 대한 네트워크 기반 보안관제 체계 구축을 위한 기초연구를 수행하여 현장에 적용할 수 있는 프레임워크를 도출

2. 정보보안 환경강화 기반 조성

○ 사이버 침해위협 대응을 위한 전주기적 정보보호 활동
- 기관 보안장비, 네트워크 시스템 등 이기종 장비와의 연동을 통한 통합 로그관리를 통해 사이버위협에 신속하게 대응할 수 있는 조기탐지체계 마련
- 사용자가 운용중인 정보자원과 운영센터를 통한 백본 네트워크 망에서의 통합 보안 인프라를 활용하여 침해위협 시도 탐지·분석·대응지원을 수행

○ 원내 취약요소 진단을 통한 사전예방활동 강화
- 표적화된 DDoS 공격을 비롯하여 APT공격 등의 다양한 해킹 공격으로부터 안전한 정보

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

서비스를 제공하기위하여 주요 정보시스템 취약점 점검 수행

- 사이버 통합 위협분석 및 사전 예방활동 강화 : 침해위협분석보고서, 홈페이지 취약점 대응 가이드를 비롯하여 각종 매뉴얼 발간, 인식제고를 위한 홍보자료 제작 등

○ 주요 정보시스템 보안체계 강화

- 주요정보통신기반시설 취약점 분석 및 평가를 통하여 국가슈퍼컴퓨팅, 국가과학기술연구망의 보안 사각지대 분석 및 평가 실시로 운영관리 환경 보안성 강화
- 안전한 연구환경 기반조성을 위한 개인정보보호 관리수준 강화활동 실시

IV. 연구개발결과의 활용계획

○ 보안관제 패러다임 전환(수동 → 준자동 → 완전자동)을 기반으로 과학기술사이버안전센터 중심의 과학기술계 전주기적 정보보호 서비스 품질 향상

○ 개발된 인공지능 알고리즘과 차세대 보안관제시스템을 관계분야 보급·확산을 통해 지적재산권 확보뿐만 아니라, 국가 차원의 보안관제 기술수준 고도화에 기여

○ 과학기술계 연구데이터 생태계 보호수준 제고를 통해 거대·도전과제 연구를 확산시키고 과학기술분야 국가 경쟁력 강화에 기여

○ 국가 연구개발 핵심 인프라 및 유통되는 연구데이터 전반에 대한 사이버 위기대응 수행체계가 구축됨에 따라 글로벌 연구그룹·연구자에게 안전한 연구환경을 제공

○ 과학기술분야에서의 사이버안전 문제를 획기적으로 개선할 수 있는 선도기술을 독자적으로 연구·개발함에 따라 정보보안전문기업을 통해 보안산업 전반에 걸쳐 시장확대 기여

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Summary

I. Necessity of Research

○ In the era of the fourth industrial revolution, the intelligent information age, intelligence information technology such as artificial intelligence (AI) and big data is expected to play a key role as a revolutionary intelligent revolution based on the digital technology.

○ The information protection industry is accelerating its development of artificial intelli gence-based information security solutions and is conducting intensive research and development investments in global security firms such as IBM and Oracle.

○ Need to develop and apply cyber threat semi-automatic analysis-based security control technologies to ensure rapid and accurate security controls and response to rapidly changing cyber threats

○ Proactive system is needed in research and development in order to National Science and Science Technology Resource in response to a preemptive cyber-attack and leak prevention

Ⅱ. The Goal and Contents of Research

A. Final goals of research

· Improved rapidity in response to cyber threats through automatic analysis and processing

· A Study on the Application and Diffusion of Automatic Security Control Tech nology Using Artificial Intelligence

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

B. Contents of research

○ 24 hour x 365 day, Reinforce rapid and accurate cyberattacks through real-time security controls and analysis

○ The highest level of security control in Korea The combination of research and development technology and operation know-how maximizes the speed of cyber attack detection, analysis and response.

○ Research and application of large-scale network-based abnormal behavior detection, analysis and response technology

○ Preventive information protection activities to counter cyber threats

○ Strengthen preventive activities through diagnosis of vulnerable elements in researchers

○ Strengthening the security system of major information systems

Ⅱ. Conclusion and Application Plans

○ Improving the quality of all-periodic information protection services centered on the Science and Technology Cyber Security Center based on the security control paradigm shift (manual → semi-automatic → complete automation)

○ Developed artificial intelligence algorithm and next generation security control system to contribute to not only securing of intellectual property rights by spreading and spreading related fields but also upgrading level of national security control technology

○ Research in the science and technology field by enhancing the level of protection of the data ecosystem, expanding the research of large-scale challenges and challenges, and contributing to strengthening the national competitiveness of the science and technology sector

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

목 차

제 1 장 연구개발과제의 개요 ····· 1

제 1 절 연구개발 목적 및 필요성 ····· 1

1. 연구의 목적 ····· 1

2. 연구개발 필요성 ····· 2

3. 연구개발 추진체계 및 전략 ····· 4

제 2 장 국내외 기술개발 현황 ····· 6

제 1 절 연구개발 동향분석 ····· 6

1. 국내동향 ····· 6

2. 국외동향 ····· 7

3. 사이버보안 위협 동향 ····· 8

제 2 절 연구사업 목표 및 내용 ····· 11

1. 연구사업의 최종 목표 ····· 11

2. 핵심고객 및 고객니즈 ····· 11

3. 연구사업 결과 활용방안 및 기대효과 ····· 12

제 3 장 연구개발수행 내용 및 결과 ····· 13

제 1 절 과학기술계 사이버위협 통합대응체계 구축 및 서비스 ····· 13

1. 연구개발 추진방법 ····· 13

2. 당해연도 중점 추진내용 및 결과 ····· 13

제 2 절 인공지능 기반 대용량 위협데이터 자동분선 · 대응 기술연구 및 적용 ···· 17

1. 연구개발 추진방법 ····· 17

2. 당해연도 중점 추진내용 및 결과 ····· 18

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제 3 절 대규모 네트워크 기반 이상행위 탐지 · 분석 · 대응 기술연구 및 적용 … 23

1. 연구개발 추진방법 …… 23

2. 당해연도 중점 추진내용 및 결과 …… 24

제 4 절 사이버위협 분석 방법 및 절차 …… 31

1. 연구개발 추진방법 …… 31

2. 당해연도 중점 추진내용 및 결과 …… 33

제 5 절 정보보안 환경 강화 기반 조성 …… 46

1. 연구개발 추진방법 …… 46

2. 정보보안관리체계 기반 조성을 위한 조직구성 …… 48

3. 사용자 정보보안 환경강화를 위한 주요 추진사항 …… 51

4. 주요정보통신기반시설 보안체계 강화 …… 66

5. 기관 개인정보보호 관리체계 정립 …… 71

제 4 장 목표달성도 및 관련분야에의 기여도 …… 78

제 1 절 연구개발 목표달성도 …… 78

1. 세부 성과지표 수립 …… 79

2. 성과지표 달성도 …… 80

3. 대표성과 …… 81

제 5 장 연구개발결과의 활용계획 …… 82

1. 연구사업 성과의 활용 방안 …… 82

2. 기대효과 …… 83

3. 기업화 추진방안 …… 84

제 5 장 참고문헌 …… 86

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제1장 연구개발과제의 개요

제 1절 연구개발 목적 및 필요성

1. 연구의 목적

현재 우리나라의 과학기술 정보환경은 4차 산업혁명 시대를 맞아 대·내외적으로 역동적으로 변화하고 있다. 따라서 이러한 현실에 적절하게 대응할 수 있는 지능화를 통한 4차 산업혁명 시대를 맞이하고 있다. 그중에서 정보통신 인프라는 개인에 관련된 서비스 제공에 활용될 뿐만 아니라, 보다 큰 단위에서 사용되고 있다. 에너지, 수자원, 국방, 교통, 의료, 금융, 그리고 통신 등에서 사용이 활발히 진행됨에 따라 국가주요기반시설에서 정보통신망 수요가 급증하고 있다. 이러한 곳으로 사이버 공격이 발생할 경우 개인 단위의 공격 보다 더 큰 피해가 국가적인 재난 상황으로 이어질 수 있다. 금융망 해킹으로 인해 경제에 악영향을 끼칠 수 있고 군통신망에 접근하여 각종 군사 보안 위협에 노출될 수 있으며 핵발전소의 네트워크에 잠입하여 핵시설의 오동작을 일으킬 수 있다. 이러한 피해들의 공통점은 단지 개인에 국한되는 소규모 피해가 아닌 대규모의 파급 효과를 불러일으킬 수 있다는 것에서 피해의 심각성이 드러나고 있다.

IoT와 클라우드 컴퓨팅 기술의 발전으로 인하여 정보통신 인프라는 개인과 국가의 전사적 자원을 서로 연결시키고 더 나아가 전 세계적인 거대한 네트워크를 구축해나가는 중이다. 이러한 폭증하는 수요를 충족하고자 정보통신 기술은 대용량 데이터 전송을 위한 대역폭, 원거리 데이터 송수신을 위한 백본용 광케이블, 및 무선 통신을 위한 기존의 4G와 차세대 5G 기술들을 발전시키며 하드웨어적인 측면에서 눈부신 성장을 이루어왔다. 이러한 기술들로 구축된 정보통신 네트워크를 악성 코드 및 비인가 사용자로부터 접근을 제한하기 위한 사이버 보안 기술의 필요성은 날로 증대되고 있고 점차 다양해지는 공격 수법에 대응하기 위해서 방어 기법의 고도화가 필요한 실정이다.

4차 산업혁명은 디지털 기술로 촉발되는 초연결 기반의 지능화 혁명으로 인공지능(AI), 빅데이터(Big Data)와 같은 지능정보 기술이 핵심적인 역할을 수행할 것으로 예상되고 있다. 최근 정부에서는 대통령직속 4차 산업혁명위원회를 중심으로 「사람중심의 4차 산업혁명 대응계획 1.0」을 추진하고 있다. 또한 정보보호업계에서는 인공지능 기반 정보보안 솔루션 개발에 박차를 가하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

이러한 필요성 아래, 한국과학기술정보연구원 과학기술사이버안전센터에서는 국가 과학기술 분야 보안관제를 위해 2005년부터 설립 운영되어 왔다. 대·내외 과학기술 정보환경 변화에 대응하기 위한 안정적 정보자원의 보호를 위한 정보보호 프로세스 정립을 통해, 과학기술 정보서비스 전문기관의 대·내외 위상을 강화하기 위한 목적으로 본 연구를 수행하였다.

2. 연구개발 필요성

나날이 증대하는 IT 서비스에 대한 수요는 거대한 정보통신 인프라를 구축하게 만들었지만 방대한 양의 민감한 정보를 가지고 있는 통신 네트워크를 보호하는 것은 역부족인 실정이다. 일반 시민들의 삶과 밀접한 영향력을 가지고 있는 가정용 IoT부터 국가의 중요시설의 내부 네트워크까지 보안이 보장되지 않는다면 그 파급효과는 우리의 삶을 송두리째 무너뜨릴 수 있을 만큼 위협적이다. 이에 반해 최근 사이버 공격 유형은 악의적이고 다양해지고 있다. 악성 코드 기반의 랜섬웨어, 가상화폐를 이용한 지능범죄, 정치적 갈등 관계에 있는 타국들의 사이버 해킹, 국가기관 침입을 통한 기밀 탈취, 그리고 금융정보 해킹을 통한 불법 인출 등 그 피해가 매우 심각한 정도에 이르렀으므로 사이버 안보가 그 어느 때 보다도 중요한 시점으로 간주되고 있다.

대한민국 정부는 사이버 공격으로부터 국민과 국가를 보호하기 위해 사이버 위협, 탐지, 그리고 대응을 수행할 수 있는 관련 법규와 법령을 정비하고 있다

법에 의해 민간 영역에서의 보안관제 업무는 KISA에서 주관하고 있으며 중앙행정기관, 지방자치단체, 그리고 공공기관은 '국가사이버안전관리규정' 에 의거하여 별도의 보안관제센터를 설치 및 운영하여야 한다. 국가기관 및 공공기관의 보안관제는 단위보안관제(각급기관) -> 부문보안관제(중앙행정기관) -> 국가보안관제(국가사이버안전센터)로 구성된 3단계 사이버 공격 탐지 차단 체계를 구축하여 운영하고 있다.

현재 KISTI의 과학기술사이버안전센터는 국가사이버안전센터로부터 관련 법규에 의거하여 정부출연연구소 및 국립연구소들을 네트워크로 구성하는 국가과학기술연구망의 보안을 관제하는 업무를 위임 받아 수행하고 있다. 해당 기관들의 연구망을 대상으로 24시간 365일 무중단 보안 관제를 실시하면서 사이버 공격으로 인한 피해의 발생 또는 확산을 방지하고 국가기관이 보유한 정보 시스템 및 전산망 정보를 외부의 침입으로부터 안전하게 보호하는 역할을 수행하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최근 보안관제센터들은 새로운 공격에 대한 능동적 대응 능력 향상 및 사이버 침해사고 예방을 위해 인공지능을 기반으로 하는 사이버대응 기술을 도입하고 있다. 또한 스마트폰, 클라우드 기반의 IoT 기기들이 등장하면서 보안관제 대상과 범위가 점차 확대되고 있고 기존 보안기술을 우회하는 기법들이 난무하는 상황이다. 현재 보안 장비들은 개별적인 침해사고 탐지, 분석, 및 파편화된 정보 위주로 대응하고 있어 새로운 네트워크 환경에 대응하는데 한계가 있다. 이러한 한계를 극복하기 위해 대량의 침해사고 정보를 분석하여 신속한 탐지와 대응 방안을 마련하고 침해 사고 사이의 연관성 및 특징을 발견할 수 있는 인공지능 보안 기술이 필요하다.

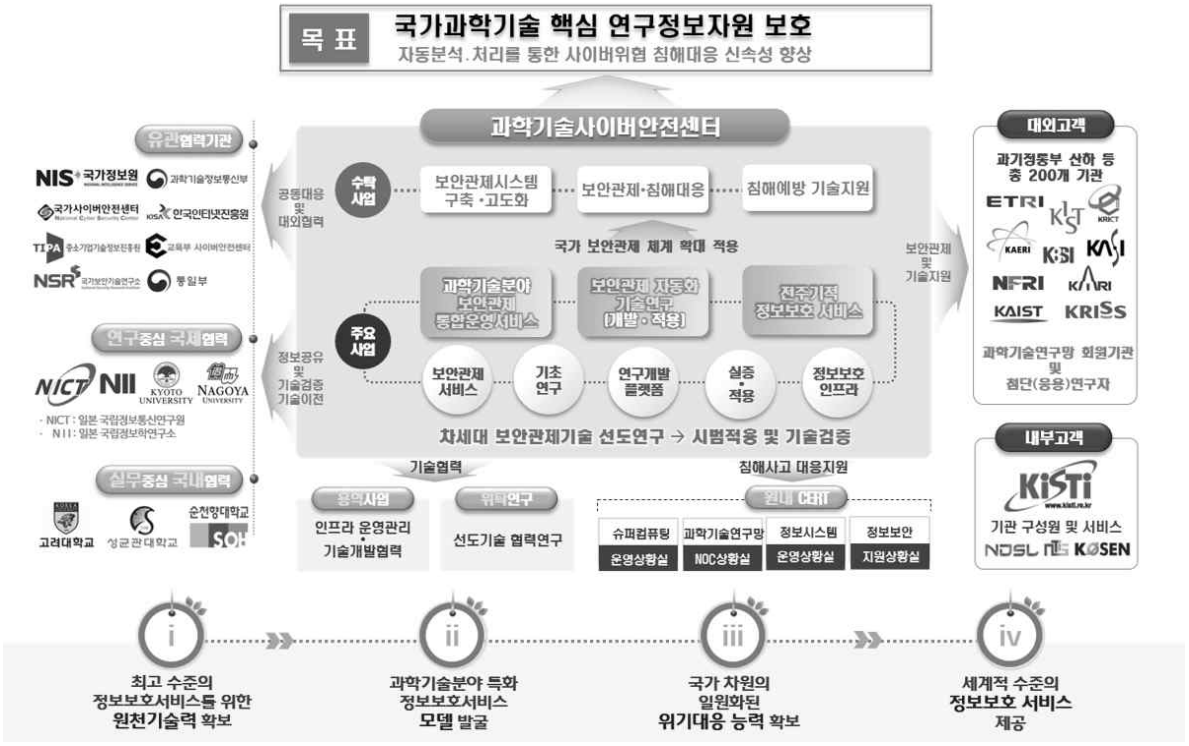
세계적인 시장조사기관인 가트너(Gartner)에서는 세계에 폭넓은 영향력을 미치거나 향후 5년 내에 정점에 달할 잠재력을 가진 전략 기술을 선정하여 「10대 전략기술 트렌드」를 발표하고 있으며, 2018년의 경우 인공지능 강화 시스템(AI Foundation)을 첫 번째로 제시하고 있다. 특히, 기존의 범용성에 초점을 맞춤 'General AI'가 아니라, 특정 업무를 수행하기 위해 최적화된 알고리즘 기반 머신러닝 기술을 토대로 'Narrow AI'개발에 대한 집중이 필요한 상황이다.

과학기술 분야는 선진국 도약을 위한 핵심 성장동력으로 연구데이터의 중요성과 가치가 높은 만큼 이에 대한 정보유출 시도(소니픽처스, 한수원 사고)가 지속적으로 증가하는 추세에 있다. 급변하는 사이버 위협 상황에 대한 신속·정확한 보안관제 및 침해대응을 수행하기 위하여, 과학기술사이버안전센터에서는 사이버위협 준자동분석 기반의 보안관제 기술원형 독자개발 및 시범 적용을 수행한 국내 최고 수준의 자동분석 기반 보안관제 기술력과 노하우를 보유하고 있다.

4차 산업혁명 시대에 안전한 연구데이터 생태계 조성을 위해서는 인공지능 기반 사이버위협 자동분석 기술개발·적용을 통해 보안관제 패러다임 전환이 반드시 필요한 상황이다. 또한, 이기종 보안위협 정보를 통합하여 보안관제 및 침해대응의 신속성·정확성을 향상시키기 위한 빅데이터 처리기술을 접목하여 기존의 기술적 한계를 가진 보안관제분야에 대한 극복과 더불어 정보보호 산업의 발전에 기여하는 측면에서 본 연구의 필요성이 제기된다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 연구개발 추진체계 및 전략



<Figure 1-1> 연구개발 추진 체계도

한국과학기술정보연구원 과학기술사이버안전센터는 앞서 서술한 바와 같이, 대·내외 과학기술 정보환경의 변화에 대응할 수 있는 국가과학기술 핵심 연구자원 보호를 목표로 설정하고, 세부 과제를 수행하고 있다.

○ 첨단응용연구 정보(자원)보호를 위한 실시간 보안관제 체계 구축
- 주요 첨단연구망 활용기관 및 첨단응용연구자가 집중된 지역망센터에 실시간 보안관제 인프라 확장 구축 및 고도화
- “Non-Stop” 종합상황실 기반 실시간 보안관제 인프라를 구축·운영함으로써 개별기관이 수행하기 어려운 24시간 보안관제를 통한 신속·정확한 침해공격 대응지원

○ 대규모 네트워크 기반 보안관제 기술선도 및 실용화를 위한 R&D 핵심역량 강화
- 실용적인 보안관제 기술연구를 통한 지적재산권 확보 및 관련 기술력 확산성과 창출
- 정보보안 기술연구 결과를 첨단연구망 보안관제 서비스에 연계하는 방향으로 추진

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

과학기술사이버안전센터의 주요 기능으로 과학기술분야 보안관제 통합운영을 비롯하여 보안관제 자동화기술연구 및 전주기적 정보보호 서비스를 수행하고 있다. 핵심고객으로는 과학기술연구망을 활용하고 있는 200여 대상기관과 한국과학기술정보연구원 내부의 대외서비스 주체, 전임직원을 들 수 있다. 또한, 과학기술정보통신부, 행정안정부, 국가정보원 등의 유관 협력기관과 국내외 기관과의 전체적인 대응이 필요한 외부협력를 추진체계로 삼고 있다.

본 사업의 효율적인 수행을 위해 최고 수준의 정보보호서비스를 위한 원천기술력 확보 및 과학기술분야 특화 정보보호서비스 모델 발굴로 정보보호산업 전반에 걸친 기여확대를 바탕으로 국가차원의 위기대응 능력 확보를 위한 보안기술분야의 표준화 추진으로 구분하여 추진하는 투 트랙 전략을 취하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제2장 국내외 기술개발 현황

제1절 연구개발 동향분석

1. 국내동향

과학기술정보통신부는 2018년 1월「데이터, 네트워크, 인공지능(Data, Network, AI, : DNA」 역량을 지속적으로 강화해 초연결 기반 지능화 인프라를 구축하고 혁신성장을 선도하겠다는 계획을 밝혔다. 과학기술로 국민 삶의 질을 높이고 인류사회 발전에 기여한다는 비전을 바탕으로 미래사회의 새로운 문제에 대처하고 지속가능한 발전과 삶의 질 향상을 이끌어가는데 과학기술이 중점적 역할을 수행한다는 내용으로 진행하였다.

정부는 융합과 협력을 강화하기 위하여 활발한 혁신생태계를 조성하는 산・학・연간 유기적인 협력체계 구축으로 국가 R&D 시스템의 개방성을 과감히 확대하여 성장한계를 돌파하고자하는 체계를 마련할 계획이다.

4차 산업혁명 핵심기술과 관련하여 인공지능 및 블록체임 기술 등이 지능형로봇, 혁신신약과 병행하여 13대 혁신 성장동력으로 선정하여 육성하고 건강, 재난・안전, 환경 등 국민 생활과 밀접한 분야에서의 연구개발을 확대 및 강화하고 있다. 기본계획 실현을 위한 중점 과학기술 중 본 연구사업과 밀접히 관련되어 있는 분야는 아래와 같다.

<Table 2-1> 정부 중점과학기술 中 본 연구사업 유관기술

대분류	중분류	중점과학기술
ICT・SW	빅데이터・인공지능	① 지능형 빅데이터 분석 및 활용 기술
		② 다중인공지능공통 플랫폼 기술
	정보보안	③ 지식정보보안기술
재난안전	재난・안전	④ 범죄・테러 통합 지능형 예측・대응시스템 기술

한편, 과학기술정보통신부는 정보보호담당관실을 설치·운영함으로써 국가 기반 시설이나 주요 과학기술 시설에 대한 지속적인 점검 및 훈련을 제공하고, 사이버 침해 위협에 대응하고 있다. 이를 바탕으로 과학기술 정보보안 영역에서 정보보안 전담 체계가 구축되었으며, 사이버 공격에 대응하는 보안 체계가 확립되고 있다. 특히, 전산망 해킹을 통한 접속 권한 취득, 개인정보 유출,

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

악의적인 디바이스 제어, 시스템 마비 등 국가 기반 시설을 대상으로 이루어질 수 있는 사이버 공격에 대한 다차원적인 예방 기능을 수행하고 있으며, 이러한 사이버 사고의 발생 시 국가정보원 및 국방부와 함께 범정부적으로 대응할 수 있도록 합동 대응 체계를 수립하였다.

국가정보원은 매년 정부출연연구기관을 대상으로 중요 연구자료의 유출 예방을 목적으로 한 산업기밀 보안 교육 및 연구보안 평가를 실시하고 있으며, 주요정보통신기반시설 지정을 통해 보호대책 점검 및 보안관리 수준을 진단하여 국가연구개발 기관의 정보보호 수준향상을 도모하고 있다.

2. 국외동향

선진국은 융합보안을 포함한 정보보안 산업을 육성하기 위해 전략적 투자를 추진하고 있으며 특히, 정보보호 인력양성을 위해 체계적인 지원을 수행한다. 미국의 경우 국토안보부법의 사이버 보안 진흥법[1] 의거 설립된 국가안보부에서 민·관·군을 구별하여 기관별로 임무를 분담하지 않고 통합적으로 운영하고 있다. 유럽연합(EU)은 집행위원회의 정보사회 미디어국과 유럽네트워크 정보보안청이 사이버 보안과 관련한 역할을 주도적으로 수행한다. 대표적인 사례로 EU은 공동연구개발 정책인 7차 프레임워크 프로그램에서 정보보안 분야에 약 9,000만 유로 예산을 투입하고 있다. 이 밖에 일본은 정보보안 정책의 기본 전략을 결정하는 '정보보안 정책 회의'를 정례화하고 그 수행기관으로 내각관방 정보보안센터(NISC)를 설치하여 정보보안 정책을 총괄하고 있다. 또한 일본은 2010년 '국민을 지키는 정보보안 전략'을 발표하고 '정보보안 정책회의'를 통해 국가 정보보안 관련 전략을 수립하였다.

미국 국토안보부(Department of Homeland Security)는 사이버보안 분야에 지능형 정보기술을 적용한 미래형 연구개발(R&D)를 한국 과학기술정보통신부와 공동 추진하기로 합의하였다. 양국은 '한-미 ICT 정책포럼'을 통해 사이버보안 분야 협력 확대방안을 논의하였으며, 공동 연구개발을 통해 '인공지능(AI))'를 활용한 사이버공간의 위협을 탐지・분석・예방하는 최신기술 분야를 선정하여 추진하기로 하였다.

매년 1월에 개최되는 세계 최대의 가전・정보통신기술 전시회인 CES에서는 4차 산업혁명을 주도하는 핵심 기술인 인공지능(AI), 사물인터넷(IoT), 가상현실(VR), 5세대(5G) 이동통신 등 다양한 산업분야의 혁신기술 등을 다양하게 선보였다.

---

1) 사이버보안진흥법(Cyber Security Enhancement Act) : 정보보안 산업 육성을 위해 전략적 투자를 추진하고 있고 정보보호 인력 양성을 위해 다양한 대학 교육 지원 프로그램을 운영

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

사이버보안 분야에서는 고도화된 침해사고가 끊임없이 발생하고, 기존의 백신 제품으로는 탐지가 어려운 악성코드가 꾸준히 등장함에 따라 미국 국방부(DARPA)는 사상 처음으로 2016년 8월 인공지능 간의 사이버전을 다룬 '사이버 그랜드 챌린지(CGC)를 개최하였다.

미국 행정부를 비롯하여 국가 정부기관에서는 국가정보능력(National Intelligence)을 이용하여 불법적 사이버공격을 시행하는 해커들을 색출하는 노력을 강구하는 한편, 정보보안과 관련하여 다양한 정책과 법률을 제안하고 있다. 예를 들어 미국 행정부는 2013년 오바마 정부에 이어 2017년 트럼프 정부에서 사이버보안 향상을 위한 행정조치(Executive Order)들을 단행하였다.

독일에서는 인공지능 분야만을 전문적으로 연구하는 공공・민간 합작의 인공지능연구소(DFKI)가 20년 전부터 설립・운영되고 있으며 인텔, 마이크로소트프, BMW, 구글 등을 비롯한 민간 기업과 브라운호퍼, 자를란트 대학 등이 국제 주주로 참여하고 있다. 그 중에서 지능형 네트워크 연구부서/그룹은 인더스트리 4.0, IoT, 소셜미디어 등 다양한 분야에서의 지능형 네트워크 기술, 네트워크 안정성 및 보안에 대한 연구를 수행하고 있다.

정보보호 및 보안 관점에서 보면, 전 세계적으로 데이터 보호 및 보안에 대한 인식이 가파르게 상승하고 있다. 개인 또는 기업 차원에서 대응하기 어려운 사이버 공격이 많아지는 추세에 따라, 국가 주도의 사이버 공격 대응이 이뤄지고 있다. 대표적으로 미국은 국토안보부를 통해 정보보호 정책을 총괄하고 있고, 독일은 연방보안기술청, 프랑스는 중앙정보시스템 보안국에서 총괄체제 및 전문조직을 운영하고 있다.

3. 사이버보안 위협 동향

최근 행해지고 있는 사이버공격의 위협 특징을 살펴보면, 정치적 갈등으로 인한 사이버공격, 해킹을 통한 금전 탈취, 취약점 및 APT 공격 기법을 통하여 랜섬웨어 유포, 그리고 고급망 공격 전략을 이용한 악성코드 유포 등이 있다. 이러한 사이버 보안상의 핵심 이슈에 대한 자세한 설명은 다음과 같다.

첫째, 정치적 갈등으로 인한 사이버공격의 원인으로 한반도 사드배치가 있다. 한국은 지정학적으로 미국, 중국, 일본, 러시아 등 강대국들에 의해 둘러싸여 있기 때문에 과거부터 오늘날까지 주변국들에게 많은 영향을 받고 있다. 특히 중국은 신흥 강국으로 G2의 위상을 뽐내며 첨단 과학기술에 천문학적인 자금을 투자하고 있고 IT분야에서 선두를 달릴 만큼 그 위상을 떨치고 있다. 중국 정부에서는 비공식적으로 사이버전을 대비하여 대규모 전문 해킹 부대를 양성하고 지원

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

하고 있다. 이러한 사이버 해킹 부대들은 적대적 혹은 정치적 갈등 관계에 있는 타국의 사이버 시설에 침투하여 막대한 피해를 끼치고 있다. 그 예로 2017년 3월 한반도 사드패치 사례가 있다. 중국 정부는 한국 정부에 철회를 요청하였지만 요구가 받아들여지지 않자, 한국의 여러 공공기관, 정부 부처 홈페이지, 민간 기업들의 시스템에 침투하여 그 기능을 마비시켰다. 공격 방식은 디도스 및 웹 변조였으며 한국 정부는 이에 대해 외교적인 결례를 언급하며 유감을 표시하였다.

둘째, 사이버 공격을 통한 금전 탈취의 해킹사고의 예로 불법으로 돈이 인출 당한 사건이 있다. 전자상거래가 활발히 이루어지고 텔레뱅킹을 통한 금융거래가 활성화됨에 따라 ATM 기기를 사용하는 빈도수는 예전보다 줄어들고 있다. 하지만, 해당 기기들은 금융거래에 필요한 많은 개인 정보들에 접근하고 변경할 수 있으므로 매우 강력한 보안이 요구된다. 국내 대다수 은행들은 자사들의 ATM 기기의 OS를 사이버 공격으로부터 보호하기 위해 바이러스 백신 제작 업체와 같은 보안 솔루션 업체에 그 업무를 위탁하고 있다. 해커들은 오히려 이러한 점을 악용하여 백신 업데이트 서버를 해킹하여 악성 코드에 감염시켰고 ATM 기기들에 설치된 백신이 업데이트될 때 감염된 서버로부터 악성 코드를 배포하여 2차 감염을 유발하였다. 이로 인한 피해는 은행 고객들의 전자금융거래정보가 대만, 태국, 그리고 일본 등 총 6개국으로 유출되었고 이 정보는 해외 해커들에 의해 악용되어 96명의 복제카드를 만드는데 사용되었다. 해당 복제카드로 총 1억 264만원이 불법 인출되었으며 이를 계기로 금융 결제 관련 임베디드 기기의 보안이 중요한 이슈로 떠오르게 되었다.

셋째, 국내외 기업들이 취약점 및 APT 공격 기법을 활용한 랜섬웨어에 감염되어 업무 방해와 금전적 피해를 입은 사례가 있다. 전 세계의 많은 컴퓨터 시스템은 마이크로소프트社의 윈도우 제품을 사용하고 있으며 해당 본사로부터 주기적인 보안 패치 및 시스템 업그레이드를 원격으로 제공받는다. 해커들은 이 점을 이용하여 윈도우 PC에서 파일 공유에 사용되는 서버 메시지 블록의 취약점을 악용하여 150여 개국의 약 30만대의 시스템이 워너크라이 랜섬웨어에 감염시켰다. 감염 증상으로는 부팅 시 화면이 자동으로 잠금 상태가 되어서 사용할 수 없는 상태가 된다. 이를 해결하기 위해서는 해커가 요구하는 금액을 송금하고 코드를 전송받아서 입력해야 한다. 한편 국내에서는 랜섬웨어에 감염된 서버로부터 웹호스팅 서비스를 받는 개인 사업자들, 병원, 게임 업체, NGO 단체의 홈페이지가 마비되었고 해커는 복구 대가로 피해자들에게 50억 원을 요구하였으나 협상 끝에 13억 원으로 합의되었다. 이처럼 사이버 공격 수법이 무작위로 악의적으로 피해를 끼침에 따라 언제든지 그 누구라도 희생자가 될 수 있다는 공포감이 감돌았다.

넷째, 공급망 공격 전략을 이용한 악성코드 유포의 사례로는 소프트웨어 업데이트 모듈의 악성코드 감염으로 인한 피해가 있다. 이 공격 방법은 다수의 클라이언트들을 원격 제어 및 업데이트

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

관리하는 서버를 감염시킨 후 클라이언트들이 해당 서버에 접속하면 2차 감염을 일으키는 것이다. 2017년 8월, 바이러스 백신으로 유명한 글로벌기업인 카스퍼스키社는 자사 제품의 모듈에 악성 코드가 포함되어 있는 것을 발견 후 자사의 서비스를 제공받는 기업들에게 사실을 고지하였다. 감염된 악성 코드는 사용자 이름, 호스트 이름 등을 주기적으로 해커가 지정한 서버로 전송하였고 해커는 모니터링을 통해 관심 있는 감염 시스템에 추가적인 악성 코드를 다운로드하여 실행할 수 있었다. 랜섬웨어를 실행하거나 데이터베이스에 접근하여 중요한 정보를 빼돌릴 수 있는 위험이 있는 심각한 보안 사고로 기록되었다.

위에서 언급된 사이버 공격 사례들에서 볼 수 있듯이 지능화된 사이버공격이 지속적으로 증가하고 있고 그 의도 또한 악의적으로 변해가고 있다. 따라서 이에 대한 체계적인 사이버 보안 및 대응방안이 필요한 실정이다. 이에 부응하기 위해 현재 KISTI의 과학기술사이버안전센터에서는 다양한 사이버 공격에 대응하고자 보안관련 솔루션에 지속적인 연구와 노력을 기울이고 있다. 위의 사례들에서 볼 수 있듯이 고도화되어가는 사이버 공격들에 신속한 대응을 위해서 본 센터는 최신 사이버 위협 동향 분석을 통한 자동화 기반 보안 체계 구축 및 실시간 네트워크 침입 탐지 가시화를 주력으로 연구하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제 2절 연구개발 목표 및 내용

1. 연구사업의 최종 목표

본 연구사업은 '자동분석・처리를 통한 사이버위협 침해대응 신속성 향상'을 최종 목표로 하고 있다. 세부 추진목표로 인공지능 기술을 활용한 자동화 기반 보안관제 기술연구와 적용 및 기술 확산을 제시하고 있다.

본 사업은 아래 표와 같이 3개년(2018~2020) 연구목표를 수립하여, 최종 목표인 자동분석・처리를 통한 사이버위협 침해대응 신속성 향상을 달성하고자 한다. 연구사업의 단계별 목표는 아래와 같다.

<Table 2-2> 연구사업 단계별 목표

'18년 목표	'19년 목표	'20년 목표
세부과제명 : 자동화 기반 과학기술 정보보호 서비스		
· 과학기술계 보안관제 체계 재정비	· 과학기술계 보안관제 통합운영 서비스	· 과학기술계 보안관제 통합운영 안정화
· 보안관제 전용 인공지능 알고리즘 테스트베드 구축	· 보안관제 전용 인공지능 알고리즘 개발·시범적용	· 보안관제 전용 인공지능 알고리즘 적용·고도화
· 이상행위 탐지기술 연구	· 이상행위 탐지기술 개발·시범적용	· 이상행위 탐지기술 적용·고도화
· 원내 정보보안 관리체계 개선 (연구자 중심)	· 원내 정보보안 관리체계 안정화	· 원내 정보보안 관리체계 고도화
보안관제 자동화 기술연구 기반 조성	**보안관제 자동화 기술연구 개발・적용**	**보안관제 자동화 기술연구 고도화・확산**

2. 핵심고객 및 요구사항 분석

본 연구사업의 핵심고객은 내부과 외부로 구분할 수 있다. 내부는 KISTI 소임직원과 주요정보통신기반시설로 구분할 수 있으며 요구사항은 다음과 같다.

・내부직원 : 정보통신망・정보보안 업무 프로세스 간소화, 정부정책의 효과적 적용
정보보안 강화를 위해 직원 교육 및 제반 홍보 활동 등 인식제고, 역량 강화
정보보안, 네트워크 인프라 등 안정적인 서비스 제공

・주요정보통신기반시설 : 주요정보통신기반시설 보안관리 체계화, 기반시설 운영환경 보안성 강화

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

또한, 외부 고객으로는 과학기술연구망을 활용하는 200여 보안관제대상기관을 비롯하여 대외평가기관으로 구분할 수 있으며, 부문별 요구사항은 다음과 같다.

- 보안관제 대상기관 : 알려진 공격에 대한 신속·정확한 실시간 보안관제 및 침해대응 기술지원
  신변종 공격에 대한 보안관제·침해대응 기술지원 범위 확대
  최신 해킹기법 및 보안기술 분석정보 공유 확대
- 대외평가기관 : 유관기관의 다양한 평가에 대응하기 위한 유연성 확보(국정원, 행안부, 과기정통부)

3. 연구사업 결과 활용방안 및 기대효과

가. 기술적 측면

세계 수준의 사이버 해킹공격 자동분석용 보안관제 기술 개발/적용을 통해 기술료 수입, 지적재산권 확보 목표 등을 달성하고, 사이버침해위협 대응 5분이내 대응을 위한 골든타임 달성으로 신속·정확하게 대응할 수 있는 사이버안전 정보보호체계를 마련한다.

- 분당 1백만 건의 보안이벤트 처리 및 자동분석 유형에 해당되는 사이버 침해위협은 5분 이내 대응 가능한 독자기술을 보유

또한, 보안관제 기술을 선도적으로 연구·적용하고, 관계분야 기술보급·확산을 통해 국가 차원의 기술수준 고도화에 기여한다.

나. 경제적 · 산업적 측면

첨단연구정보 라이프사이클(생성 → 유통 → 관리·공유)의 핵심요소(연구자, 정보인프라, 연구정보)에 대한 사이버 위기대응 기반(Clean-KREONET 체계 구축)이 확보됨에 따라 글로벌 거대도전 연구그룹 등에게 안전한 연구환경을 제공한다.

보안관제 패러다임 전환(인력 기반→시스템 기반)으로 기존 방식대비 약 4배 성능 향상에 따라 추가자원 투입 없이 보안관제 대상 확대 가능한 기술을 확보하여, 국가 경쟁력 강화에 기여한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제3장 연구개발 수행내용 및 결과

제 1절 과학기술계 사이버위협 통합대응체계 구축 및 서비스

1. 연구개발 추진방법

한국과학기술정보연구원(KISTI) 과학기술사이버안전센터의 과학기술 분야 「사이버안전 컨트롤타워」 역할을 강화하기 위하여 핵심 보안관제 인프라·체계 재정비를 통한 실시간 보안관제 및 침해대응 기술지원의 효율성을 극대화하고, 신속성·정확성 향상을 통한 전주기적 정보보호 서비스를 강화하여 안전한 과학기술 연구환경 조성을 추진하였다.

2. 당해연도 중점 추진내용 및 결과

가. 전주기적 정보보호 서비스 제공

과학기술사이버안전센터는 국내 최대 규모의 사이버안전센터로써 아래 그림과 같이 보안관제 대상기관 유형별로 구분하여 종합상황실 중심의 전주기적 정보보호 서비스(실시간 보안관제 → 분석 → 대응·예방 기술지원)를 제공하고 있다.

과학기술정보통신부 소관 연구·공공기관 총 144개(본원 61개, 지역 분·지원 83개)에 대해서는 중앙행정기관의 보안정책을 기반으로 집중 보안관제 및 기술지원을 수행하고 있다. 특히, '20년에는 총 596건의 사이버공격 시도를 신속·정확하게 탐지·분석·대응지원을 수행하여 해킹피해 발생을 미연에 방지하였다.

과학기술연구망 활용기관 및 첨단연구자·그룹 총 276개(가입기관 201개, 연구그룹 75개)에 대해서는 사이버안전 유관기관(부문별 사이버안전센터 : 교육, 국방 등) 공동대응체계 강화를 기반으로 실시간 보안관제를 중점적으로 수행하고 연구망상황실(NOC)과 연계하여 기술지원을 수행하여 안전한 연구환경 조성에 기여하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-2> 전주기적 정보보호 서비스 수행 체계도

<Table 3-1> 보안관제 및 침해대응 추진 실적

(단위 : 건)

구 분	사이버 위협상황별 보안관제·분석 및 침해대응 실적						소 계
	단순 침입시도[2]	웜바이러스 전파[3]	경유지 악용[4]	자료훼손 /유출[5]	홈페이지 위/변조[6]	서비스 거부공격[7]	
2018년	174	560	4	107	13	0	858
2019년	0	289	16	195	3	0	503
2020년	173	218	29	174	2	0	596
합 계	**347**	**1,067**	**49**	**476**	**18**	**0**	**1,957**

특히, 보안관제 대상기관 유형별로 구분하여 맞춤형 관제현황 및 사이버위협 동향보고서를 매월 작성·배포하여 각급기관 보안담당자들의 업무 이해도 및 효율성 향상에 기여하였다.

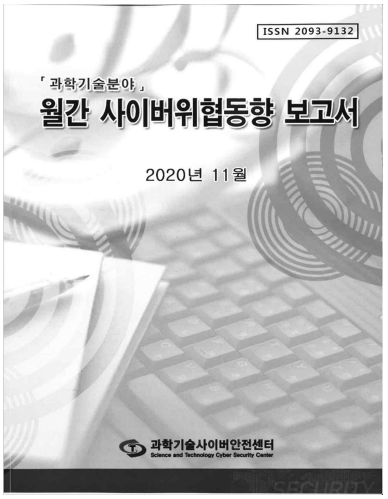
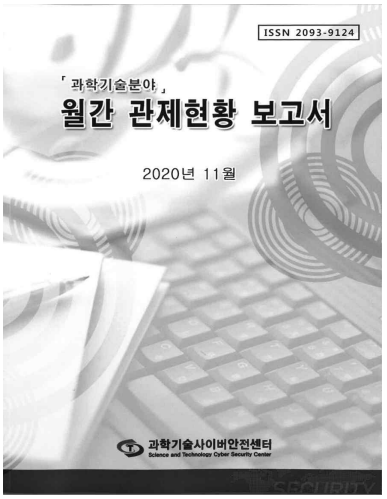
과학기술사이버안전센터는 세계 최초로 “사이버안전 골든타임”을 제시하고 이를 달성하기 위하여 보안관제 패러다임 전환을 추진하고 있다. 1단계는 기존의 “인력 기반의 수동분석”으로 급증하는 사이버공격 정보를 신속·정확하게 분석·대응하는데 한계점을 보이고 있다. 따라서, 2단계 “시스템 기반의 준자동분석”의 필요성을 조기에 인지하고 세계 최초로 보안관제 전문인력의 노하우를 정형화하고 시스템 기반 자동분석이 가능하도록 통합보안정보분석시스템(SMARTer)를 구축·운영하고 있다. 또한, 3단계 “인공지능 기반의 자동분석”이 가능하도록 원천기술을 성공적으로 개발하였으며

2) 외부의 단일 또는 다수의 시스템이 보안관제 대상기관 시스템으로 단순 스캐닝 등을 수행하는 행위
3) 경유지 악용, 홈페이지 변조, 자료훼손 및 유출 외 보안관제 대상기관 시스템이 他 시스템에 공격하는 행위
4) 악성코드 유포지(파일전송), 악성코드 경유지(URL Redirection), Linux/Unix 시스템 여부 확인 등을 수행하는 행위
5) 패스워드 정보, 계정정보 등 개인중요정보 유출 등을 수행하는 행위(OS정보, MAC주소 등 단순시스템 정보유출은 웜바이러스로 분류)
6) 홈페이지 변조시도(특정 URL 접근시도), 악성파일 업로드(ASP, JSP, PHP 등), 특정 URL 페이지 변조 등을 수행하는 행위
7) 외부의 단일 또는 다수의 시스템이 보안관제 대상기관 시스템으로 악의적인 대량의 패킷을 전송하는 행위

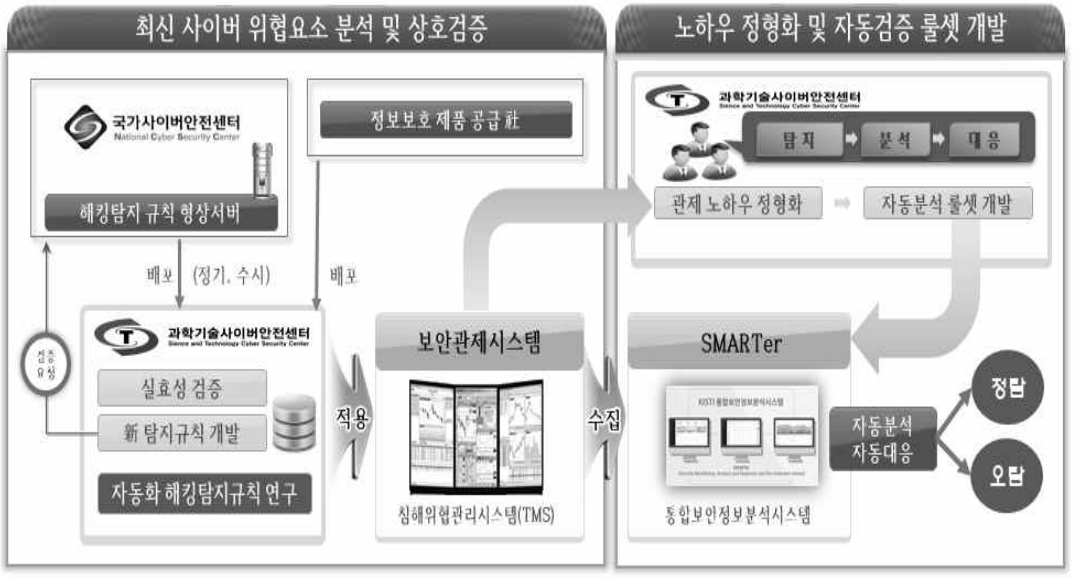
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상세한 내용은 2절에서 다룬다.

<Table 3-2> 대상기관 유형별 맞춤형 정보제공 실적

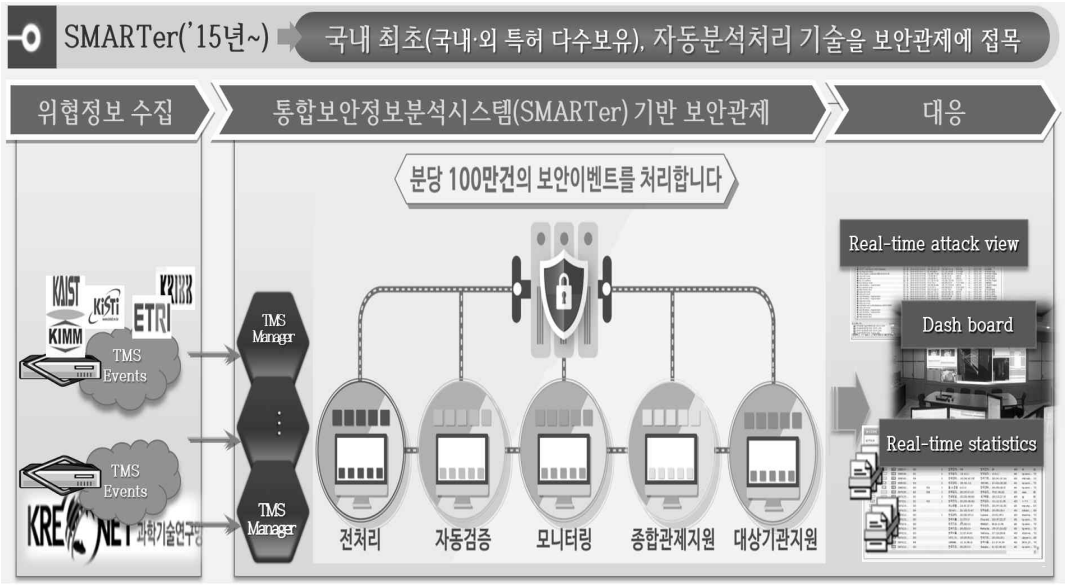
구 분	월간 사이버위협 동향보고서	월간 관제현황 보고서
주요 내용	◦ 침해위협 동향 및 대응현황 ◦ 공공·연구기관 우수사례 등	◦ 기관별 침해위협 시도 통계, 분석 정보 ◦ 침해대응 현황 정보
총 2종, 24건		

특히, SMARTer 기반의 준자동분석을 통해 사이버안전 골든타임 달성율을 향상시키기 위해서는 사이버안전 유관기관(국가정보원 등)이 제공하는 보안관제 탐지규칙과 이에 대한 자동분석이 가능하도록 자동분석 룰셋을 지속적으로 개발·적용하는 것이 매우 중요하다. 따라서, 다음과 같이 보안관제 탐지규칙 및 자동분석 룰셋 개발·검증·적용 체계를 정립하였다.



<Figure 3-3> 보안관제 탐지규칙 및 자동분석 룰셋 개발·검증·적용 체계도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-4> 통합보안정보분석시스템(SMARTer) 시스템 개념도

이를 통해, '20년에는 사이버안전 유관기관이 제공하는 보안관제 탐지규칙 총 3,669개를 검증·적용하였으며, SMARTer 자동분석 룰셋 총 1,299개를 개발·적용하여 사이버안전 골든타임 달성율 향상에 크게 기여하였다.

<Table 3-3> 보안관제 탐지규칙 검증·적용 실적

구 분	보안관제 탐지규칙 분류 유형					합 계
	하드코딩[8]	PCRE[9]	CONTENT[10]	PCRE+CONTENT	IP[11]	
실 적	99개	5개	1,703개	69개	1,793개	3,669개

<Table 3-4> 자동분석 룰셋 개발·적용 실적

구 분	정탐 룰셋		오탐 룰셋		합 계	
	'20년 신규개발	누적치	'20년 신규개발	누적치	신규개발	누적치
실 적	69개	593개	37개	706개	106개	1,299개

8) 하드코딩 : 임계치 기반의 대규모 사이버공격을 탐지하기 위한 자동화 규칙(Rule)
9) PCRE(Perl Compatible Regular Expressions) : 정규 표현식을 활용한 해킹공격 탐지 규칙
10) CONTENT : 단순 문자열을 활용한 해킹공격 탐지 규칙
11) IP : 블랙 IP(악성코드 유포지·경유지 등)를 활용한 해킹공격 탐지 규칙

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제2절 인공지능 기반 대용량 위협데이터 자동분석·대응 기술연구 및 적용

1. 연구개발 추진방법

변종적이고 지능화된 사이버공격이 폭발적으로 증가함에 따라 기존의 인력 기반 수동분석으로는 신속·정확한 탐지·분석·대응에 한계점이 대두되는 상황이다. 이에, 과학기술사이버안전센터는 보안관제 패러다임 전환을 다음과 같이 3단계 추진전략을 수립하였다.

○ 1단계 : 전문인력 기반 수동분석
- 가장 일반적인 보안관제 수행체계이며, 실시간으로 수집된 대용량 보안정보를 보안관제 전문요원이 보유한 기술수준 및 노하우에 의존하여 사이버공격 정·오탐 여부를 수작업으로 분석하는 방법
- 사이버안전센터 초기 구축 및 안정화 단계에 적합한 모델

○ 2단계 : 시스템 기반 준자동분석
- 세계 최초로 과학기술사이버안전센터에서 연구·개발하여 적용한 보안관제 수행체계이며, 다년간 축적된 보안관제 및 침해대응 노하우를 정형화하고 보안관제시스템에 적용하여 사이버공격 정·오탐 여부를 실시간으로 자동 분석하는 방법
- 사이버안전센터 안정화 및 고도화 단계에 적합한 모델

○ 3단계 : 인공지능 기반 완전자동분석
- 4차 산업혁명 시대의 핵심기술인 인공지능을 접목한 보안관제 수행체계이며, 실시간 보안관제에 최적화된 인공지능 알고리즘을 연구·적용하여 사이버공격 정·오탐 여부를 실시간으로 자동 분석하는 방법
- 사이버안전센터 고도화 단계(차세대 기술)에 적합한 모델

특히, 인공지능 기술을 실시간 보안관제 분야에 성공적으로 도입하기 위해서는 실제 사이버공격 데이터세트를 확보하는 것이 매우 중요하며, 과학기술사이버안전센터는 국내 최대 규모의 사이버안전센터로 지난 2005년부터 수집·분석된 실제 데이터세트를 보유하고 있는 강점이 있으며, 이를 토대로 보안관제 및 침해대응의 신속성·정확성을 획기적으로 향상시킬 수 있도록 연구·개발을 중점적으로 추진하고 있다.

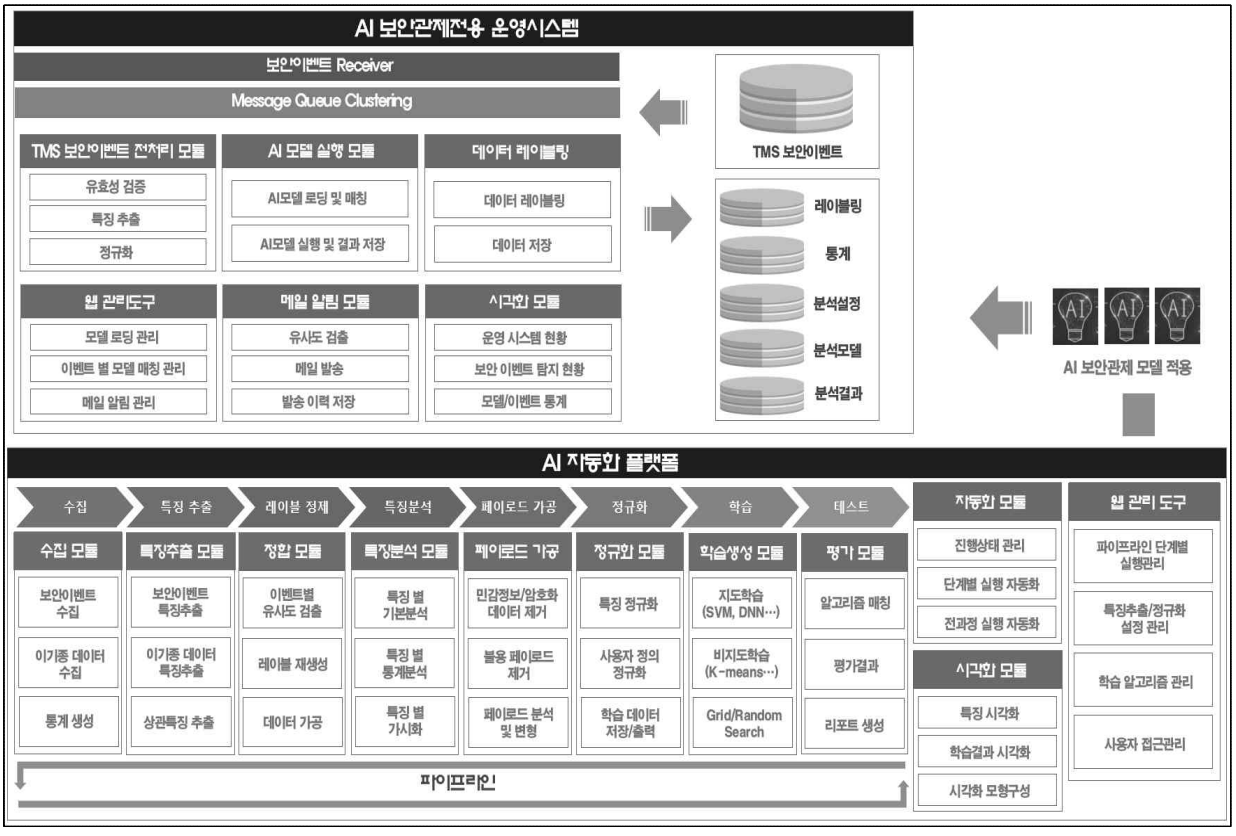
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 당해연도 중점 추진내용 및 결과

과학기술사이버안전센터는 기존 인력중심의 보안관제 체제에서 인공지능 기반 자동화 체계로 전환하기 위해 대규모 사이버공격 및 이상행위를 자동으로 분석하기 위한 AI기반 자동화 시스템 및 운영시스템을 성공적으로 개발·구축하였다. 이를 통해 대용량데이터 자동분석에 기반한 사이버 안전 골든타임 달성율을 확기적으로 향상시킬 수 있는 기반을 마련하였으며 신·변종 침해위협으로부터 안전한 사이버 환경을 조성하는데 큰 역할을 수행하였다.

가. 대규모 사이버공격 및 이상행위를 자동으로 분석하기 위한 AI 자동화 시스템 개발

대규모 원천 데이터 수집·가공부터 최종단계인 AI 모델 생성·적용까지 전 과정을 사용자 요구 방식에 따라 Non-Stop으로 처리하며, 최적의 AI모델 생성/평가/검증/적용을 위한 AI 자동화 플랫폼의 핵심적인 수집, 전처리, 인공지능 알고리즘 및 자동화 모듈이 탑재되어 있다. 아래 그림은 자동화 시스템 아키텍처를 보여주며 주요 모듈 및 연구내용은 다음과 같다.



<Figure 3-5> 보안관제 전용 AI기반 자동화 시스템 아키텍처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 대용량 침해위협 데이터 수집모듈 : 특징추출 대상을 수집할 때 대상 데이터에 대한 다양한 검색 조건을 부여하기 위해 모든 수집필드에서 복합적 조건을 손쉽게 추가, 삭제 및 수집이 가능한 인터페이스 구현

○ 데이터 정합 모듈 : 레이블링이 되지 않은 수집 데이터 정제를 위해 코사인 유사도(Cosine Similarity)를 이용하여 정·오탐 레이블로 재생성하는 기술 개발

○ 특징추출 및 분석 모듈 : 학습에 적합한 특징을 선택할 수 있도록 다양한 통계정보(정·오탐 개수, 최소/최대/평균, 비율), 공격자 동적 행위 분석을 위한 보안이벤트 간 연관성 특징정보 및 군집정보 등 특징별 추출·분석 기능 구현

○ 페이로드 가공 모듈 : 학습을 방해하는 암호·특수 문자, 무의미 문자 등의 노이즈 데이터를 제거하고 페이로드 분석을 통해 양질의 데이터만을 학습시키기 위한 기능 구현

○ 인공지능 모델생성 모듈 : 머신러닝 학습 성능을 높이기 위한 다양한 형태의 딥러닝 알고리즘(RNN, CNN, RCNN)을 적용 및 사용자 정의대로 히든레이어 및 노드의 개수를 지정할 수 있도록 구현

○ 자동화 모듈 : 인공지능 모델 생성에 필요한 수집/특징추출/학습데이터 생성/정규화/학습 전(全)과정을 자동화 파이프라인(Pipeline)화 하여 하나의 흐름(Flow)으로 자동 수행 환경 구현



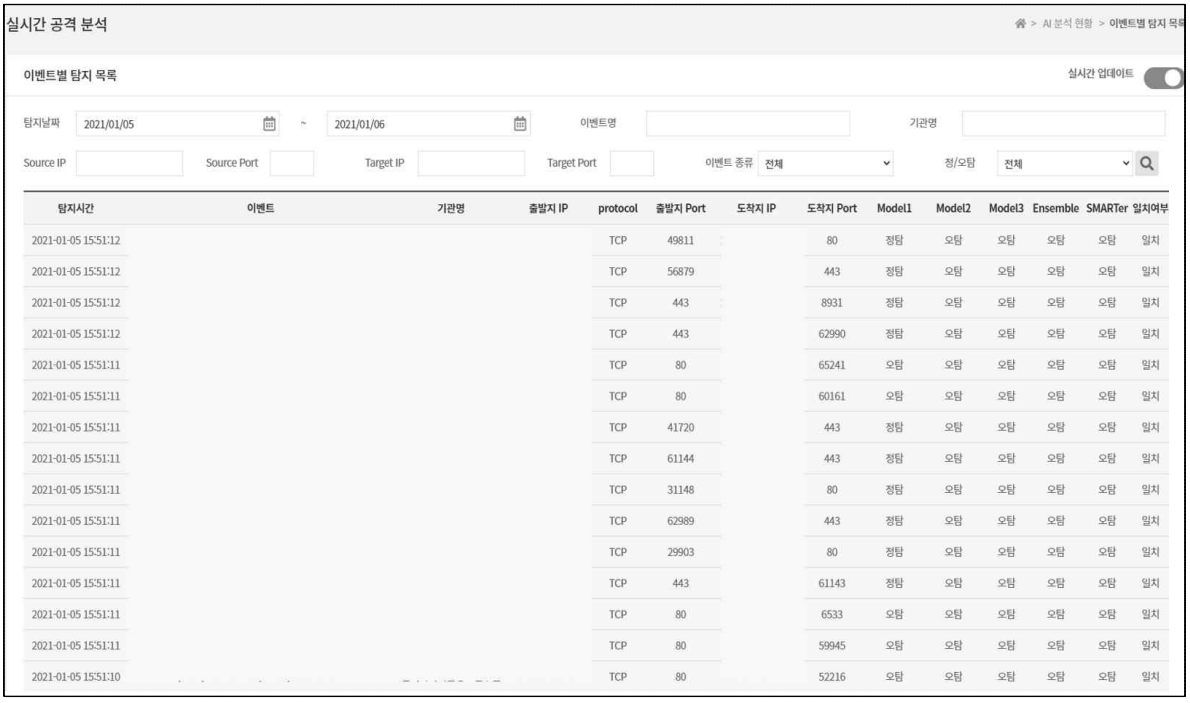
<Figure 3-6> 인공지능기반 자동화 시스템 대시보드

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 보안관제 실환경 적용·자동분석을 위한 AI 운영시스템 개발

과학기술사이버안전센터에서 탐지한 하루 평균 수천만 건의 보안이벤트를 대상으로 사이버 공격과 정상행위를 실시간으로 자동 분류하는 보안관제 전용 AI 운영시스템을 개발·구축을 완료하였다. 이로써, 인공지능 운영시스템을 통해 기존 인력중심 보안관제 체계의 한계점을 극복하여 대규모 사이버공격 및 이상행위 분석을 신속·정확하게 대응하는 획기적인 시스템 중심 보안관제 체계로의 대전환을 이뤄냈다. '20년 보안관제 전용 운영시스템의 주요 모듈 및 연구내용은 아래와 같다.

- 보안이벤트 전처리 모듈 : 실시간으로 유입된 보안이벤트 중 수집필터를 이용하여 수집 대상이 되는 데이터만을 선별하고 AI 모델생성에서 사용되었던 학습데이터 설정정보 등을 활용한 보안이벤트 전처리 기능 개발
- 보안이벤트 정·오탐 분류 모듈 : 실시간 보안이벤트를 앙상블 AI모델로 매칭하여 정확도, 재현율, 정밀도, F1 스코어를 기반으로 정·오탐 결과 도출
- 보안이벤트 레이블링 모듈 : AI 운영시스템에서 활용한 모든 데이터를 저장하고 정·오탐 레이블 변경이 있을 시 해당 레이블을 수정하는 기능구현
- 메일 알림 모듈 : AI 운영시스템 분석 결과와 기 구축한 자동검증시스템의 분석결과가 동일하게 정탐인 경우 해당결과를 보안 관제요원에게 메일로 전송하는 기능 개발



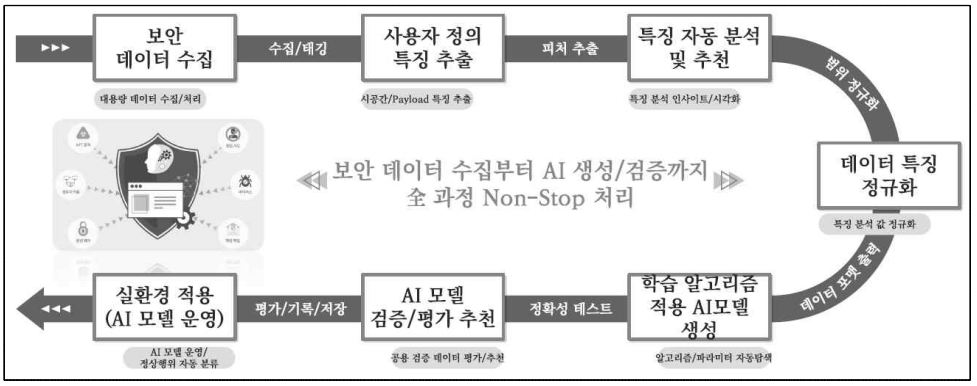
탐지시간	이벤트	기관명	출발지 IP	protocol	출발지 Port	도착지 IP	도착지 Port	Model1	Model2	Model3	Ensemble	SMARTer	일치여부
2021-01-05 15:51:12				TCP	49811		80	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:12				TCP	56879		443	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:12				TCP	443		8931	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:12				TCP	443		62990	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	80		65241	오탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	80		60161	오탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	41720		443	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	61144		443	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	31148		80	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	62989		443	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	29903		80	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	443		61143	정탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	80		6533	오탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:11				TCP	80		59945	오탐	오탐	오탐	오탐	오탐	일치
2021-01-05 15:51:10				TCP	80		52216	오탐	오탐	오탐	오탐	오탐	일치

<Figure 3-7> 보안관제 전용 실시간 보안이벤트 정·오탐 판별화면

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

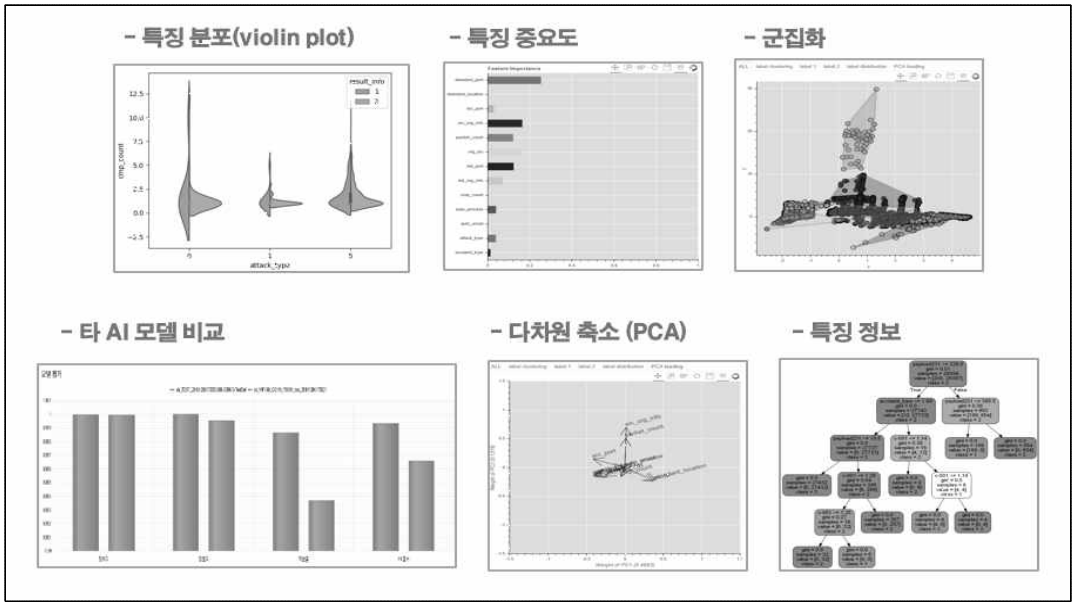
다. 인공지능 기반 대용량 위협데이터 자동분석 주요성과

인공지능 기반 자동화시스템은 대용량 위협데이터 수집·가공부터 AI모델 생성·평가·적용까지 전 과정을 사용자 요구방식에 따라 연속적으로 처리가 가능하다. 특히, 수집, 특징추출, 정규화, 인공지능 알고리즘을 선택 및 조합하여 다양한 AI모델을 손쉽게 생성할 뿐만 아니라 인공지능 모델을 통해 침해위협 데이터를 실시간으로 분석 및 보안관제의 신속성/정확성을 극대화할 수 있다.



<Figure 3-8> 대규모 원천데이터 수집부터 검증까지 전과정 자동화 프로세스

또한, AI 자동화 플랫폼에서 생성한 인공지능 모델을 보안관제 전용 운영시스템에 적용하여 실제 보안이벤트 분석을 통해 하루평균 수 천만건의 보안이벤트를 99.9% 정확도로 자동분류할 수 있다. 개발·구축된 본 시스템의 가장 큰 장점은 대시보드, 이벤트별 및 모델별 분석화면을 제공하여 쉽고 빠르게 정·오탐 결과확인이 가능하며 해당결과에 대한 직관적인 이해를 할 수 있도록 다양한 데이터 시각화 기능을 구현하였다.

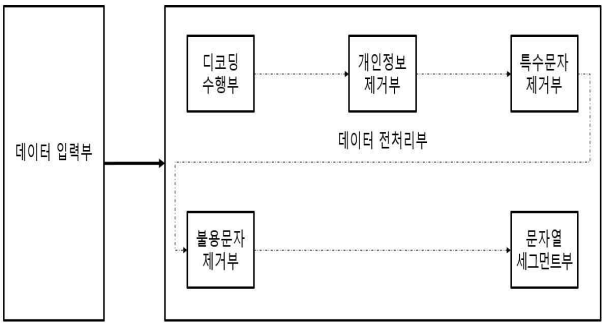


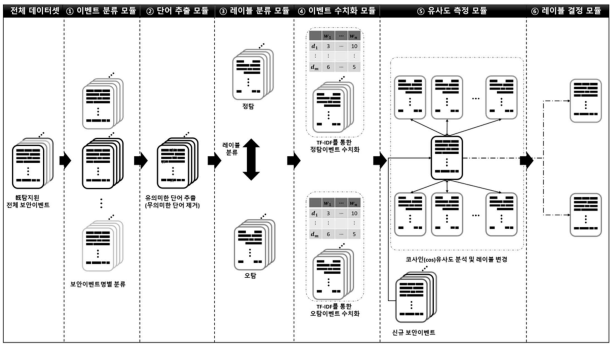
<Figure 3-9> AI 모델생성 결과에 대한 시각화 구현

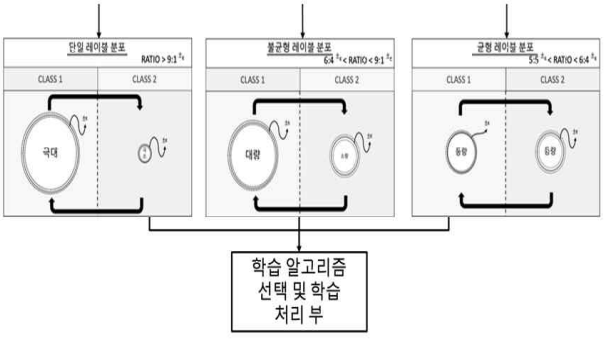
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

아울러, AI 자동화 플랫폼 및 보안관제전용 운영시스템 연구개발에 대해 아래와 같이 국내 특허를 출원하여 핵심 원천기술의 지적재산권을 확보하였으며 해당 시스템을 실제 보안관제 환경에 적용함으로써 인공지능 기반의 보안관제가 실현되는 우수성을 입증하였다.

<Table 3-5> 보안관제 전용 AI 자동화시스템 핵심원천기술(총 3건 특허출원)

특허명	데이터 특성이 보존된 네트워크 페이로드 전처리 방법 및 장치	
핵심내용	인공지능 분류 모델 성능향상을 위한 학습을 방해하는 요인 제거 및 데이터 특성보존	 〈페이로드 전처리 아키텍처〉
진보성	유의미한 문자열만을 학습함으로서 양질의 학습데이터 생성가능	
시장성	인공지능 기반의 제품 상용화시 적용가능	

특허명	일관성이 보장된 인공지능 학습데이터 생성방법 및 장치	
핵심내용	인공지능의 성능을 좌우하는 고정밀의 학습데이터의 자동생성을 위한 유사도 검증 분류셋을 개발하여 일반성 확보	 〈유사도 분류 알고리즘 아키텍처〉
진보성	유사도 및 유사도 알고리즘에 의해 신변종 공격탐지 및 재학습 비용·시간 절감	
시장성	높은 호환성으로 기 상용화 제품에 적용가능	

특허명	2-클래스 데이터의 상호비율에 따른 상태분류 및 최적의 학습알고리즘 적용방법 및 장치	
핵심내용	데이터 클래스(레이블) 분포 기반 최적의 인공지능 모델 생성 알고리즘 자동선택 방법	 〈클래스 분포에 따라 각처리 부 상세도〉
진보성	인공지능 알고리즘을 사용자에게 자동 추천함으로서 연구생산성 극대화	
시장성	단시간에 고성능의 인공지능 모델생성이 가능하여 다양한 AI제품에 상용화	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제3절 대규모 네트워크 기반 이상행위 탐지·분석·대응 기술연구 및 적용

1. 연구개발 추진방법

국내 보안관제 수행체계는 국가정보원이 개발·배포하는 보안관제 탐지규칙을 각급 사이버안전센터에 검증·적용하여 국차 차원의 일원화된 사이버공격 대응을 수행하는데 초점을 맞추고 있다. 특히, 보안관제 전용장비(침입탐지시스템 제품군)에 의해 탐지된 보안로그를 기반으로 사이버공격 정·오탐 여부를 판별해야 하는 상황으로, 급변하는 사이버 위협상황에 신속·정확하게 대응하는 데에는 근본적인 한계점이 존재하는 상황이다.

이에, 과학기술사이버안전센터에서는 “보안관제 패러다임 전환”과 병행하여 “차세대 보안관제·침해대응 원천기술 연구·개발”도 수행하고 있다. 특히, 다음과 같이 3가지 영역의 원천기술 확보를 통해 보안관제·침해대응의 신속성 및 정확성 향상 등 사이버안전 역량 강화 및 기술 선도를 중점적으로 추진하고 있다.

○ 암호화통신 보안관제 원천기술 연구·개발
- 보안관제 탐지규칙 기반 기존 보안관제의 사각지대인 암호화통신에 대한 실시간 보안관제 및 침해대응이 가능한 방법론 개발

○ 네트워크 이상행위 기반 보안관제 원천기술 연구·개발
- 백본 네트워크에서 탐지된 보안정보만으로는 분석이 어려운 신·변종 사이버공격에 대한 적시 대응이 가능하도록 네트워크 이상행위을 실시간으로 수집·분석 및 자동대응할 수 있는 방법론 개발

특히, 암호화통신 보안관제 및 네트워크 이상행위 기반 보안관제 원천기술은 ’18년부터 시작하는 단계로 실제 보안관제·침해대응 업무에 적용하기 위해서는 장기간 집중적인 연구·개발 추진이 필요한 실정이다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 당해 연도 중점 추진내용 및 결과

가. 멀웨어 분류 기반 암호화통신 보안관제 원천기술 연구・개발

(1) 연구배경 및 필요성

사용자 간 정보 교환의 장이었던 인터넷은 사용자의 사생활 보호 이슈와 함께 보안에 대한 경각심이 증대함에 따라 암호화 통신 트래픽의 사용률이 급격하게 증가하고 있다. Google Transparency Report에 의하면 구글 서버를 통하는 95% 이상의 트래픽이 암호화 되어 있으며, Zscaler Report에 의하면 2018년 Zscaler 클라우드 내 기업 트래픽의 80%가 SSL/TLS로 암호화 되었다고 보고 되었다.

이러한 변화는 일반 사용자의 트래픽 뿐만 아니라 각종 사이버 공격 또한 암호화되어 시도되는 문제점을 발생시켰다. SophosLabs에서 2020년 2월 공개한 자료에 따르면 최근 6개월간 인터넷에 접속을 시도한 멀웨어 샘플 중 23%가 C&C 서버와의 통신에 HTTPS를 사용함으로서 TLS를 사용하여 통신하는 멀웨어가 급속도로 증가하였음을 알 수 있다. 또한 같은 자료에서, 정보 유출 멀웨어 중 44%가 TLS를 사용하고 있다는 사실을 통해 특정 멀웨어 패밀리의 암호화된 TLS 사용 빈도가 높다는 사실이 밝혀졌다. 하지만 기존 보안관제 시스템은 시그니처 탐지 기반으로 설계 및 구현되었기 때문에, 암호화를 통해 시그니처의 엔트로피가 높아진 경우에는 탐지의 어려움이 발생한다.

이러한 이유로 최근 암호화 통신 보안관제를 위해 연관 플로우를 분석하여 암호화된 플로우에 대한 정보를 분석하는 방법이 논의되고 있다. 연관 플로우는 이론적으로는 암호화된 플로우의 생성과 더불어 필연적으로 또는 높은 확률로 발생하는 암호화되지 않은 플로우의 집합으로 정의할 수 있으며, 실무적으로는 암호화된 플로우의 활동 기간 전후의 기간 동안 활동한 플로우의 부분 집합으로 정의할 수 있다. 이를테면, 웹 브라우저가 HTTPS로 웹 페이지를 수신하기 위해서는 HTTPS를 사용하는 도메인명을 DNS 서버에 암호화하지 않은 상태로 송신하여 그 쿼리 결과를 수신하여야 하고, HTTPS에 활용되는 인증서를 검증하기 위해 특정 서버와 메시지를 교환할 수 있다. 따라서 HTTPS 웹 페이지가 발생시킨 암호화된 플로우의 응용, 목적, 정보 등을 연관 플로우를 통해 추론할 수 있는 것이다.

따라서, 암호화통신의 보안관제 가능성을 확인하기 위하여, 암호화 통신 트래픽 특성을 중심으로 한 멀웨어 패밀리의 분류를 통해 암호화 통신으로 생성된 플로우를 분석 자동화하는 기술을 개

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

발하고자 한다. 멀웨어 분류 관련 최신동향을 참고하여 암호화 통신 트래픽의 특성 추출을 진행하고, 특히 각 멀웨어 패밀리 별로 어떠한 특성에 의존하는지 파악을 시도한다. 이 결과를 멀웨어 패밀리 분류 기술 설계에 적용하여 분석 자동화 기술 설계가 이루어지도록 하며, 이를 통해 암호화 통신 보안관제를 위한 기술 확보의 가능성을 확인한다.

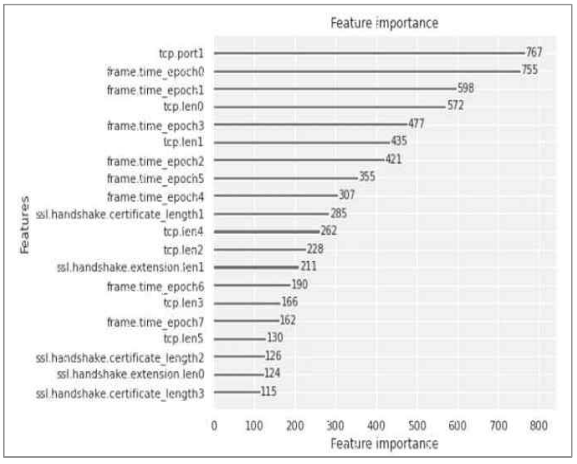
(2) 연구수행 내용

- 기계학습 기반의 암호화 통신 사용 멀웨어 패밀리 분류 모델 설계

페이로드(Payload)의 해독이 불가능한 암호화통신 플로우가 급속히 증가하는 상황에서 암호화 통신을 사용하는 멀웨어 패밀리(Malware Family) 분류에 따른 플로우의 행동적, 부수적 특징을 수집(특징분석 단계)하고 기계학습 기반의 분류 모델 설계를 통해 이상 행위를 자동적으로 판정, 분석하는 기술(기계학습 알고리즘 적용 단계) 확보 하였다. 먼저 원시 데이터로부터 특징을 추출한 후 지도학습 모델에 적합한 형식으로 변환하는 작업 과정을 수행한다. 아래 표<특징 추출 및 내용>의 내용과 같이 기본 데이터로 사용할 암호화된 패킷의 PCAP 데이터로부터 17종의 데이터 종류(특징)을 추출한다.

	feature 이름	내용
1	filename	파일명
2	_ws.col.Protocol	통신시 사용하는 프로토콜
3	ip.src	송신한 곳의 ip address
4	ip.dst	수신한 곳의 ip address
5	tcp.port	사용한 tcp port
6	frame.time_epoch	플로우 도착간 시간
7	tcp.len	tcp 열의 길이
8	ssl.handshake.version	ssl handshake의 version
9	ssl.handshake.type	ssl handshake의 종류
10	ssl.handshake.ciphersuites	사용할 수 있는 암호화 알고리즘 후보
11	ssl.handshake.ciphersuite	ssl.handshake.ciphersuites 중 실제로 사용된 ciphersuite
12	ssl.handshake.cipher_suites_length	사용된 ciphersuite의 길이
13	ssl.handshake.extensions_supported_groups	ssl handshake 확장 지원 여부
14	ssl.handshake.extensions_server_name	ssl handshake 확장 서버명
15	ssl.handshake.extension.len	ssl handshake 확장 길이
16	ssl.handshake.certificate	ssl handshake 인증서
17	ssl.handshake.certificate_length	ssl handshake 인증서 길이

〈특징 추출 및 내용〉



〈중요도 기반 모델링〉

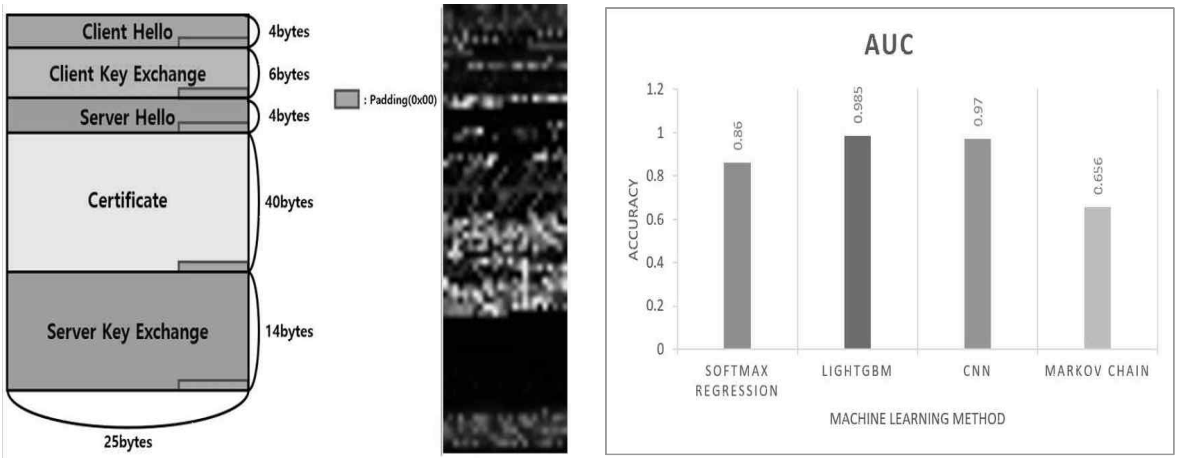
<Figure 3-10> 기계학습 기반 암호화통신 멀웨어 패밀리분류 주요내용

추출된 특징은 여러 가지 속성값으로 정의될 수 있기 때문에, 총 904개의 특징이 존재 할 수 있다. 그러나 기계학습 수행을 고려했을 경우 904개의 특징을 각각 학습하는 것은 효율적이지 않을 뿐더러 오히려 성능을 저하시키는 요소로 작용하기 때문에 LightGBM 라이브러리에서 제공하는 특징 중요도 모델링을 바탕으로 기계학습에 활용할 특징을 중요도 기반으로 추출한다. 그 결과 표 <중요도 기반 모델링> 과 같이 총 15개의 유형의 특징 집합을 추출할 수 있었으며, 속

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

성값을 고려하여 최종적으로 304개의 특징을 학습에 사용할 것으로 판단하였다.

정의된 특징을 바탕으로 지도, 비지도 및 딥러닝을 포함한 다양한 알고리즘의 기계학습 기법을 적용하여 멀웨어 분류 가능성 확인을 시도하였다. 아래 그림 <CNN기법 적용(멀웨어 패밀리 종류별 특성 추출/활용)>에서와 같이 멀웨어는 암호화 통신을 사용하더라도 그 특징에 해당하는 부분을 기계학습을 통해 밝혀낼 수 있었으며, 이를 통해 멀웨어를 탐지하는데 활용할 수 있음을 확인할 수 있었다. 또한 그림 <정확도 검증(평균 86.8%의 정확도 확보)> 에서와 같이 현재 거의 판별이 불가능한 TLS/SSL 암호화 통신 트래픽에서도 멀웨어의 탐지를 평균 80%이상 수행이 가능함을 확인 하였다.



〈CNN기법 적용(멀웨어 패밀리 종류별 특성 추출/활용)〉 〈정확도 검증 (평균 86.8%의 정확도 확보)〉

<Figure 3-11> 기계학습 기반 암호화통신 멀웨어 패밀리분류 기법 및 정확도 검증

(3) 결론

암호화 통신 분석과 멀웨어 패밀리 분류 기술에 대한 최신 동향을 바탕으로, 암호화 트래픽 분석을 위한 멀웨어 패밀리 분류 기술개발을 수행하였다. 먼저 가상환경인 샌드박스를 사용해 암호화 통신 플로우 수집 및 정보 수집 자동화가 이루어지도록 설계 및 구현을 수행하고, 샌드박스 회피를 하는 샘플에 대해 대응하기 위해 샌드박 스 회피 방지 기법에 대해서도 연구를 진행하였다. 이와 같은 가상환경을 바탕으로 수집된 멀웨어 활동이 포함된 암호화 트래픽을 바탕으로 총 17가지의 데이터 feature를 선별했다. 본 데이터에서 머신러닝 학습에 있어 중요한 feature를 알아보기 위해 LightGBM에서 제공하는 기능인 feature importance를 이용했다. 이를 바탕으로 유의미한 feature를 판단해 전체 특징 수를 줄일 수 있었고, 전체 학습 시간 및 비용이 절감되었다. 또한, 전문가가 투입되지 않아도 중요한 feature를 스스로 판단할 수 있다는 점에서, 멀웨어 패밀리 분류 자동화 기술 설계에 있어 해당 기능 은 큰 의의가 있다고 판단되었다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

특징 분석, 중요도 추출 및 전처리까지 수행된 데이터를 바탕으로 마르코프 체인, Softmax 회귀, CNN, LightGBM 모델을 바탕으로 자동화 기술 설계 방법론을 제시하고, 학습을 진행해 각 모델의 성능을 평가하였다. 평가결과 마르코프 체인, Softmax 회귀, CNN, LightGBM 의 순서대로 65.6%, 86.0%, 97.0%, 98.5%의 정확도를 산출하였으며, 그 중 LightGBM이 가장 좋은 성능을 보여주었다. 본 결과로 미루어보았을 때, 암호화 트래픽의 멀웨어 패밀리별 분류의 분석 가능성을 확인할 수 있었으며, 또한 feature importance의 결과였던 tcp port, tcp len, 플로우 도착 간 시간, 인증서 길이 feature를 중점으로 지도학습 분류 알고리즘을 사용한 모델은 암호화 트래픽의 멀웨어의 패밀리별 분류 문제에서 높은 정확도를 바탕으로 실제 보안관제 탐지에 활용될 수 있을 것으로 전망된다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 네트워크 이상행위 기반 보안관제 원천기술 연구・개발

(1) 연구배경 및 중요성

보다 많은 전자기기가 인터넷에 연결되는 IoT (Internet of Things) 세상이 다가옴 에 따라 이를 악용하는 사이버위협들이 날로 증가하고 그 규모도 커지고 있다. 과거 데스크톱 좀비 PC가 주가 되던 봇넷(Botnet)들은 그 감염 대상을 IoT 기기들로 확장 함에 따라 DDoS (Distributed Denial of Service) 공격 또한 매년 최고 볼륨을 경신하 고 있다. 특히, 과거 국내 DDoS 공격의 규모가 몇 배로 커져 DDoS공격에 이용되는 장비가 과거에 1만대 규모였다면 현재는 약 10만 ~ 100만대 가량으로 규모가 증대했으며, 이 장비 중에는 취약점을 이용한 IoT 장비도 공격에 악용되었을 것으로 보고 있다. 이렇게 급증하는 IoT 기 기 시장이 점차 넓어질 경우를 고려했을 때, DDoS 공격의 양적 증가 추세는 앞으로도 이어질 것으로 전망되며, 더 큰 규모를 대비할 필요가 있다는 것을 충분히 보여준다.

오늘날의 사이버위협에 대응하기 위해서는 선제 탐지 대응뿐 만 아니라, 실질적인 공격 단계에서 서버를 보호해 정상적인 서비스를 운영할 수 있도록 높은 회복력과 신속하게 대응할 수 있는 자동대응 기술이 필요하며 라우터에서 다중경로 기반에 라우팅 기술을 구축하거나 SD-WAN을 이용해서 전체적인 네트워크에서 발생하는 트래픽을 관리해 최적화시 켜서 전체적인 네트워크 영향을 감소시킬 필요가 있다. 본 'DNS기반 경량형 이상행위 자동대응 프레임워크 개발' 연구과제에서는 최근 네트워크의 규모・가치를 고려해 실질적인 공격 단계에서 즉각적인 대응할 수 있는 프레임워크 개발과 봇넷・DDoS가 발생한 네트워크에 상승한 대역폭으로 인해 발생할 수 있는 영향을 최소화하는 기술 연구에 대한 연구목표를 성취하기 위해 다음의 세 분야로 나누어 세부별 연구를 협력・진행한다.

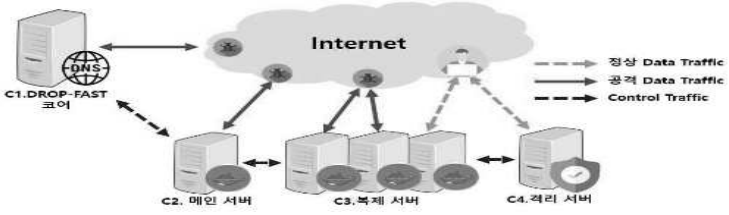
(2) 연구수행 내용 및 결론

(가) DROP-FAST

2019년에 진행한 DROP-FAST의 프로토타입을 확장하여 실무 환경에서의 Intra-AS DDoS 자동대응 연구의 효용성 검증 내용을 기술한다. 또한, DROP-FAST 기능을 통한 메인서버의 가용성 보장에 대한 효용성을 검증한다. 또한 기존 연구에서 부족했던 모니터링과 DNS 업데이트 기능을 보완하고 격리 서버라는 새로운 개념을 제시한다. DROP-FAST 코어는 방어하고자 하는 메인 서버에 대한 지속적인 모니터링을 통하여 메인 서버에 대한 DDoS 공격여부를 판단한다. DDoS 공격 식별 시, DROP-FAST 코어는 복제 서버 구동 메시지를 보내고, 서버는 복제 서버(Docker Swarm활용)를 생성하고 관리한다. 복제 서버 생성 후, DROP-FAST 코어는 복제 서버의

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

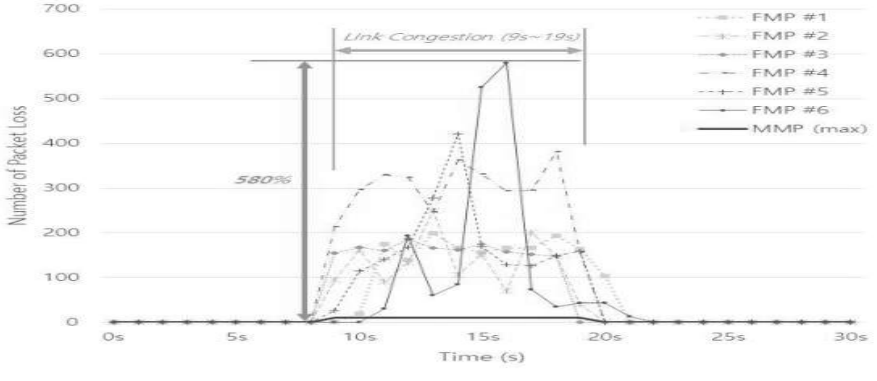
정보를 DNS에 업데이트함으로 트래픽을 복제 서버로 유도한다. 본 연구의 성과 및 DROP-FAST의 효용성 검증을 위하여, KISTI에서 제공하는 DDoS 대응훈련을 실시하고 해당 실험을 통해, 대량의 DDoS 공격 트래픽을 실험 서 버에 발생시켰으며, 대응훈련을 통하여 DROP-FAST의 가용성 보장 실험하였다. 해당 실험을 통하여, 메인 서버에 과도한 트래픽이 발생하여도 격리 서버는 사용자에게 가용성을 보장할 수 있다는 것을 확인하였다.



<Figure 3-12> DROP-FAST 구조

(나) 다중경로 선택 기반 네트워크 최적화 기술 연구

본 연구에서는 해결하고자 하는 Inter-AS 상황에서 발생할 수 있는 네트 워크 장애를 정의하고, 이를 해결할 방법을 연구한다. 본 연구에서는 문제 상황을 해 결하는 방법으로 전체 경로에서 경로 제어를 할 수 있는 다중경로 선택기반 인터넷 아키텍처를 사용한다. 검증을 위해서는 다중경로 선택기반 라우팅을 제공하는 미래 인터넷 아키텍처인 SCION을 이용해 KREONET을 포함한 국제 연구망에 테스트베드 를 구축하고 테스트를 진행한다. 테스트 내용으로는 정의한 문제 상황에서의 기존에 있던 소프트웨어를 이용한 해결 방식 및 네트워크 아키텍처/프로토콜 기반의 해결 방식과 다중경로 선택기반 라우팅 방식의 지연시간(Latency) 및 패킷 손실률(Loss Rate) 을 비교한다. 테스트 결과 MMP(Multi-Hop Multi-Path)가 FMP(First-Hop Multi-Path)에 비해 여러, AS에 걸쳐 발생하는 네트워크 장애를 해 결하는데 더욱 효과적이었다. 더 나아가서 같은 시나리오, 문제 상황을 테스트베드를 확장하여 7개의 국가, 17개의 AS, 4개의 클라이언트에서 테스트하였으며, 그 결과 대 부분의 경우 MMP가 FMP에 비해 여러 국가, AS에 걸쳐 발생하는 Inter-AS 네트워크 장애 상황에서 가용성을 보장하는 데 효과적임을 보였다.



<Figure 3-13> FMP 및 MMP의 네트워크 경로 장애 상황에서의 Packet Loss 비교

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(다) 사이버위협 효용성 검증을 위한 척도 연구 및 조사

대규모 공격트래픽은 과거 서버 운영방식인 온프레미스(on-premis)으로는 제한적인 공간에서 점점 증대되는 공격트래픽에 규모를 감당할 수 없었다, 보안업계에서는 클라우드 컴퓨팅 환경을 활용해 유입되는 공격트래픽에 대해서 필요한 자원의 유연한 확보로 대응해 왔다. 그러나, 클라우드 환경을 공격하는 방법들이 등장하게 되면서 이 또한 잠재적인 위협에 노출되었다.

본 세부 연구는 지속적인 사이버위협에 대해서 대응하기 위한 새로운 기술들을 조사하고, 해당 기술들의 효용성을 증명하기 위해서 각 기술에 이용된 평가지 표들을 조사해 추후 사이버위협 대응을 위한 프레임워크에 효용성을 검증할 수 있는 척도를 제시한다. 효과적인 사이버위협 대응을 위해서는 대표적으로 실질적으로 보호하고자 하는 서버에 공격이 시작되고 다시 정상화되기까지에 소요되는 '대응시간'을 고려해서 빠른 신속한 대응을 효용성 검증척도로 이용해 추가적인 피해를 최소화하고 정상적인 유저에 대한 가용성을 보장해야한다. 또한, 지속적으로 기술이 발달되고 IoT시대가 열리는 등 사이버위협에 이용될 수 있는 형태가 점차 다양화되기 때문에, 탐지하고 대응할 수 있도록 대응체계의 '대응 범위'를 지속적으로 확장하거나 각 유형에 대한 지속적인 분석을 통해서 유지보수 할 수 있도록 해야 한다. 게다가, 실질적 공격 시점뿐만 아니라 선제적 탐지나 필터링을 이용해서 1차적으로 보호하고자 하는 서버에 과부화가 발생하지 않도록 하는 대응기술에 대한 연구 방향성으로 언급 되고 있다.

Layer	Protocol	DDoS attack	평가지표로 사용한 논문들
Network	ICMP	ICMP flood	P3 / P4 / P5 / P6 / P9
		Smurf attack	P6 / P9
Transport	TCP	SYN flood	P1 / P2 / P3 / P4 / P5 / P6 / P9
		SYN-ACK flood	P2 / P3 / P6 / P9
		FIN/RST flood	P9
		Elephant flow	P1 / P9
	UDP	UDP flood	P1 / P3 / P4 / P5 / P6 / P9
		DNS flood	P3 / P9
		DNS amplification attack	P1 / P5 / P9
		SSDP DDoS attack	P9
		QUIC Reflection attack	P9
		NTP amplification attack	P5
		Memcached DDoS attack	P9
Application	HTTP	HTTP flood	P2 / P3
		Slowloris attack	P6

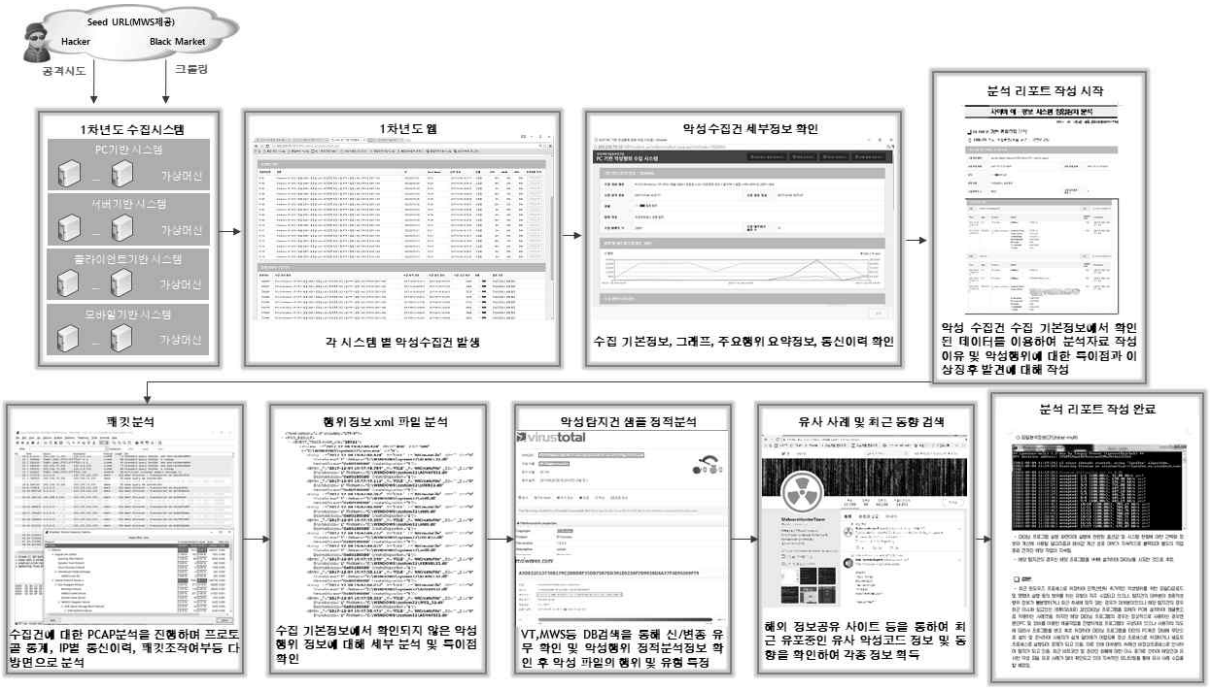
<Figure 3-14> 조사된 연구들에서 이용한 평가지표에 대한 분포

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제4절 사이버위협 분석 방법 및 절차

1. 연구개발 추진방법

과학기술사이버안전센터에서는 과학기술분야「정보보안 컨트롤타워」 역할 강화를 위하여 사이버 예·경보시스템을 구축하여 과학기술계 핵심 보안관제 인프라를 재정비함과 동시에 보안관제체계를 강화하였다. 그 중에서 사이버 예·경보시스템을 통하여 침해위협이 감지되었을 경우 대한 탐지시스템으로부터 수집된 정보에 대해 아래와 같은 방법으로 분석을 실시하고 있다.



<Figure 3-15> 침해위협 분석방법 타임라인

○ 각 수집 시스템별 자체 패턴 및 룰셋 적용을 통한 데이터 수집

- 수집 시스템별로 신·변종 악성행위 수집을 위해 패스워드 정책 및 접근성, 개방성을 조정하여 여러 유형의 악성행위를 종합적으로 수집 실시

○ 수집 기본정보와 상세정보 확인

- 각 시스템별로 수집된 데이터 중 설정된 기준 이상의 악성행위로 추정되는 수집 건에 대하여 기본정보와 상세정보를 확인 실시(중복 수집 여부 및 특이점을 파악)

○ 수집 정보를 토대로 신·변종 악성행위 파악

- 유사한 수집 건 제외 후 평소에 유입되지 않던 특이한 수집 건에 대하여 별도 확인 실시

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(통신 간 패킷, 행위정보파일 분석)

○ 패킷 분석

- PCAP파일 대상 WireShark프로그램을 활용한 프로토콜 분석 실시(프로토콜 통계, IP별 통신이력, 패킷 조작여부, 전송간 파일 존재 여부 등)

○ 행위정보 xml파일 분석

- 수집 시스템에서 기록된 프로그램, 프로세스 단의 사용 이력 대상 별도의 xml파일 분석 실시(해당 xml파일에서 윈도우api 호출 및 비정상적인 프로세스 행위 등 분석)

○ 악성탐지건 샘플파일 정적분석

- 정확한 분석 결과물 산출을 위하여 외부의 악성파일 검사 모듈 탑재 사이트를 통해 파일 정적분석 결과물을 참조(VirusTotal, Malwares.com, 트렌드마이크로 등 교차분석 실시)

○ 유사 사례 및 최근 동향 검색

- 해외 정보공유 사이트(MalwareHunterTeam)을 통하여 최근 유포중인 유사 악성코드 정보 및 동향을 확인하여 각종 최신 정보를 획득

<Table 3-6> 사이버 공격 유형

분류	설명
정보유출	이용자의 PC혹은 모바일 기기내 저장된 ID/PW등을 탈취하는 악성코드
다운로더	추가 악성코드를 인터넷이나 네트워크를 통하여 다운로드 후 설치 및 실행하는 악성코드
랜섬웨어	PC의 중요파일(문서,사진 등)을 암호화 하고 금전을 요구하는 악성코드
코인마이닝 악성코드	온라인 가상통화를 탈취하거나 채굴하기 위한 악성코드
원격제어	해커가 원격지에서 악성코드에 감염된 좀비 PC들을 제어하는 목적으로 이용하는 악성코드
정보유출(기기정보)	감염된 PC혹은 모바일 단말기의 정보를 탈취하는 악성코드
드롭퍼	정상 애플리케이션인 것처럼 배포된 뒤 실행되면 바이러스 코드를 실행하는 악성코드
해킹툴	불법침입, 정보유출, 제3자 공격 등 해킹 목적을 위한 도구 프로그램
키로깅	사용자가 키보드로 PC에 입력하는 내용을 몰래 탈취하기 위한 악성코드
웜바이러스	자신을 복제하고 네트워크를 통해 전파 할 수 있는 악성 프로그램
애드웨어	특정 소프트웨어를 실행할 때 또는 설치 후 자동적으로 광고가 표시되는 프로그램
백도어	몰래 컴퓨터에 접속하여 악의적인 행위를 할 수 있도록 출입통로 역할을 해주는 악성코드

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 당해연도 중점 추진내용 및 결과

가. 앙상블 기반 보안이벤트 분류 인공지능 모델 설계 및 테스트

(1) 연구배경 및 필요성

최근 컴퓨터 하드웨어의 비약적 성능 향상, 그리고 딥러닝을 중심으로 한 머신러닝 알고리즘의 발전과 대중화 성공에 힘입어 그동안 보안 분야에서 활용되지 못했던 빅데이터들이 본격적으로 연구 분석의 대상이 되고 있다. 보안 분야에서 가장 대표적인 빅데이터 분석 분야는 악성코드 분석과 보안관제 로그 분석이다. 하루에도 수십~수백만 건 이상이 발생하는 것으로 알려진 악성코드는 오랫동안 보안 전문가들의 관심 대상이 되어 왔으며, 다량의 분석 데이터가 만들어져 있어 인공지능 기반의 분석 기술을 적용하기에 좋은 대상이었다. 과학기술사이버안전센터에서는 2005년부터 보안관제를 수행해 왔으며, 다년간의 분석 경험을 바탕으로 대량의 보안관제 로그 분석 결과 데이터와 분석 노하우를 집적하고 있다. 과학기술사이버안전센터에서 보유한 이러한 정보들은 보안관제 로그 분석에도 인공지능 기반의 분석 기술 적용을 가능하게 하였다. 이번 연구에서는 앙상블 기반의 인공지능 기술을 활용하고, 과학기술사이버안전센터에서 수집한 침입탐지 로그 데이터를 학습하여 보안관제 요원들이 장시간에 걸쳐 수작업으로 생성한 이벤트 처리 규칙과 거의 동일한 성능을 낼 수 있는 모델 개발을 수행하였다.

(2) 연구수행 내용

본 연구에서는 과학기술정보통신부 소속 및 산하기관들에 설치된 침입탐지시스템(IDS, Intrusion Detection System) 장비로부터 수집된 침입탐지 이벤트를 사용하였으며, 수집된 침입탐지 이벤트는 보안관제 요원의 노하우 기반 자동분석시스템인 스마터(SMARTer) 시스템을 거쳐 '정탐', '오탐', '분석필요', '미분석' 중 하나로 레이블링된다. 본 연구에서는 기존의 연구들과 달리 정·오탐으로 분류된 이벤트뿐만 아니라 분석필요/미분석으로 분류된 보안이벤트들을 추가적으로 활용함으로써 학습에 필요한 데이터를 추가적 확보하였다. 뿐만 아니라 데이터의 일관성을 확보하기 위하여 기존에 스마터에서 지정한 레이블에 상관없이 사고처리(정탐)된 이벤트들을 기준으로 이와 유사한(코사인 유사도 80%이상) 페이로드를 지니는 이벤트를 모두 정탐, 그 외의 이벤트는 오탐으로 분류하여 인공지능 모델의 학습과 성능 검증에 활용하였다. 이번 연구에서는 2018년 1월부터 2019년 3월까지, 총 15개월분(총 4,485,297개) 데이터에 집중하여 분석 및 실험을 진행하였고, 이벤트 로그로부터 추출 가능한 메타정보 및 페이로드를 활용하여 모델의 성능 개선을 시도하였다.

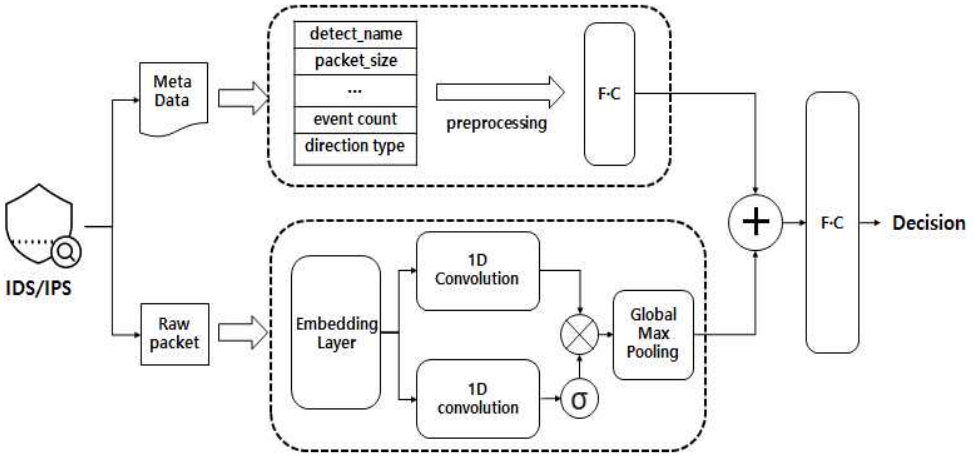
본 연구에서는 페이로드(payload)와 이벤트 로그의 메타 정보(meta-data)를 동시에 학습하여 이벤트 로그의 정·오탐을 분류할 수 있는 새로운 딥러닝 기술을 제안한다. 제안하는 기술은 페이로드 자체를 특별한 가공 없이 입력으로 처리할 수 있는 CNN(Convolutional Neural Network) 모델과 이벤트 로그의 메타 정보를 입력으로 사용하는 DNN(Deep Nerual Network) 모델로 구성된 멀티모달(multi-modal) 신경망 기술이다. 이는 패킷의

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

특징을 자동으로 학습할 수 있으며 특징정보 가공이 필요 없다는 장점이 있다. 또한, 멀티 모달 구조를 채택함으로써 원본로드와 매타 정보를 동시에 학습할 수 있다는 장점이 있다.

<Table 3-7> 침입방지시스템의 이벤트 로그 메타정보에 포함되어있는 9가지 대표 필드

Feature	Description
srcIP	source IP address
srcPort	source port number
destinationIP	destination ip address
destinationPort	destination port number
packetSize	size of packet
protocol	protocol type (TCP, UDP, ICMP,...)
eventCount	number of same events combined at a short time
detectName	event name decided by triggered rule
directionType	inbound or outbound



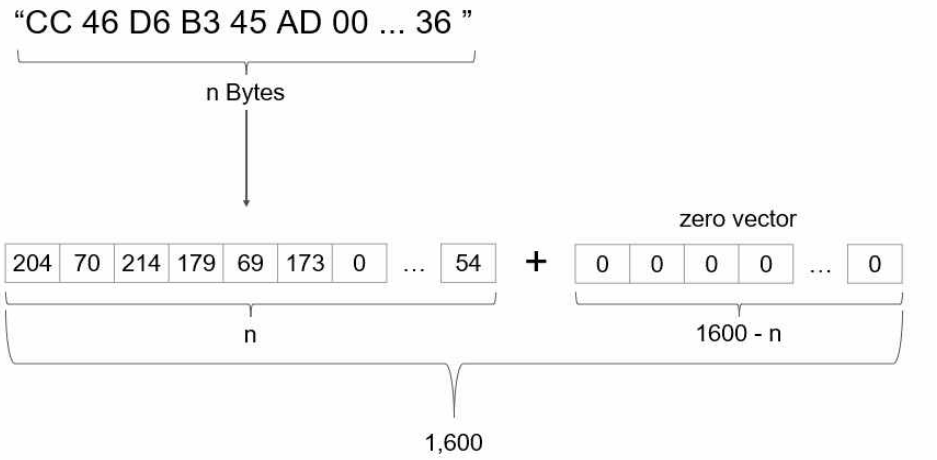
<Figure 3-16> 보안이벤트 정·오탐 분류를 위한 E2E 딥러닝 모델 구조

<Figure 3-16>는 제안하는 모델의 전체 구조를 나타낸다. 그림의 상위 모델에는 알람 로그(Alert log)로부터 메타정보(<Table 3-9> 참조)를 추출하여 완전 연결층으로 학습시키는 모델을 나타낸다. 하위 모델에는 원본 패킷(raw packet)의 내용을 바이트 단위로 입력하여 임베딩, 1DConv, 그리고 글로벌 맥스풀링을 거쳐 그 결과를 나타낸다. 각각의 모델에서 생성된 결과는 마지막 단계인 완전 연결층(fully connection layer)에 입력 값이되며, 이를 통해 입력된 이벤트의 정·오탐을 판별한다. 페이로드 학습모델인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

하위 계층에서는 보안관제 요원들이 보안이벤트의 정·오탐을 판단하는데 사용되는 패턴들을 학습함으로써 보안관제요원의 판단을 대신할 수 있는 모델들을 생성한다.

페이로드를 제안하는 인공지능의 입력으로 활용하기 위해서는 16진수 문자열(hex-string)형태의 바이트 시퀀스(byte-sequence)를 벡터로 변환하는 과정이 필요하다. 먼저, 16진수 문자열로 표현되어있는 바이트 시퀀스를 바이트 단위로 읽어 정수값(0~255)으로 변환한다. 또한 패킷의 데이터 영역의 최대 크기는 1,600바이트이므로 이 이하의 값들은 제로패딩(zero-padding)을 통해 벡터 크기를 1,600으로 고정시킨다. <Figure 3-17>는 해당 과정들을 도식화한 것이다.

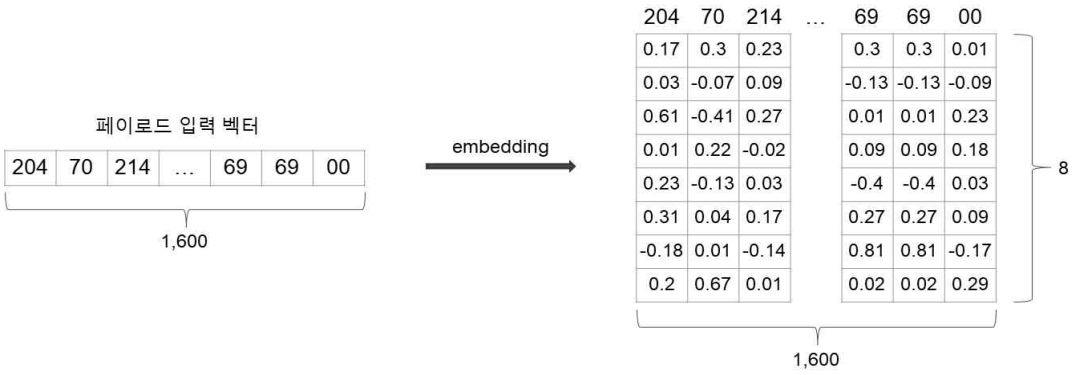


<Figure 3-17> 페이로드 정보의 벡터 변환 과정 예시

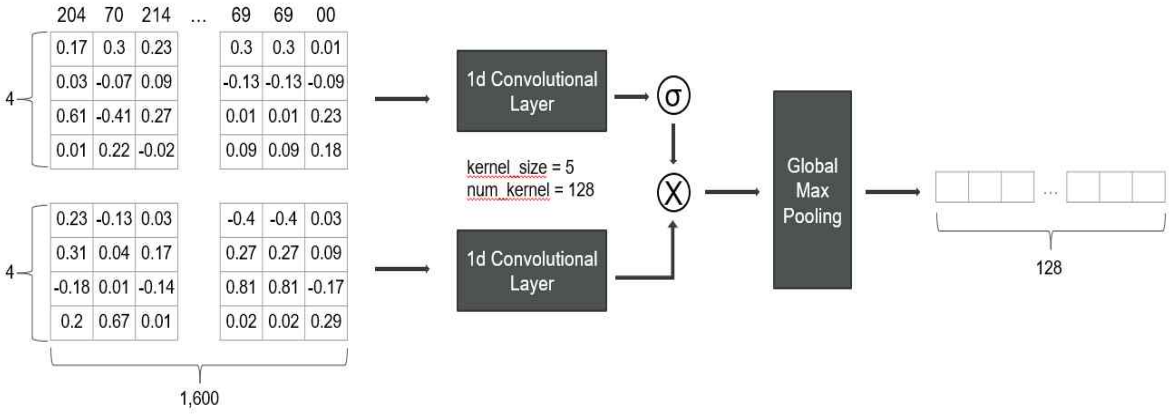
크기가 고정된 벡터는 임베딩 레이어를 통해 임베딩된 벡터로 변환하는데 이는 숫자로 표현된 벡터 간의 대소관계를 제거하되 학습에 활용할 수 있는 값으로 변환하기 위함이다. 임베딩 레이어에서는 룩업 테이블(Trainable Lookup Table)을 이용하여 각각의 입력 벡터를 고정 길이의 특징 벡터에 매핑한다. 본 연구에서는 하나의 입력 값을 8차원 실수형 벡터 공간으로 투영시키는 방식으로 임베딩함으로써 1,600 × 8 크기의 행렬로 반환하도록 하였다. <Figure 3-18>은 페이로드 입력 벡터가 임베딩되는 과정의 예시를 나타낸다.

합성곱층은 직전의 임베딩 레이어에서 입력받은 8차원의 벡터를 동일한 구조를 갖는 2개의 합성곱층이 4차원씩 입력으로 받는다. 한 개의 합성곱층은 학습을 통해 해당 벡터의 특징을 추출해내고 다른 한 개의 합성곱층은 출력값에 시그모이드(sigmoid) 연산을 적용한다. 본 연구에서는 커널 사이즈는 5차원, 커널의 개수를 128개로 설정하여 실험하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-18> 페이로드 입력벡터 임베딩 과정 예시



<Figure 3-19> 페이로드 학습모델 합성곱층과 글로벌맥스풀링 과정 예시

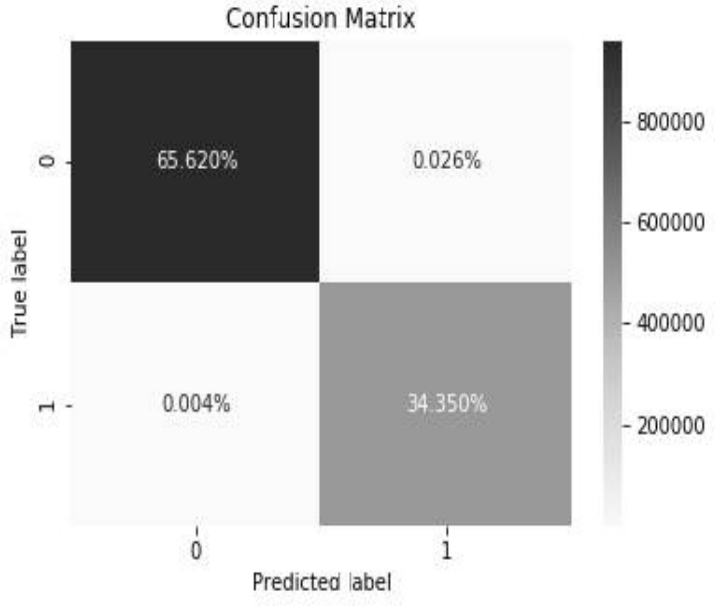
마지막으로 완전 연결계층에서는 메타정보만을 학습하는 상위 모델과 페이로드를 학습하는 하위모델의 결과벡터를 이어 붙여(Concatenate) 164(36+128)차원 크기의 입력벡터를 생성하여 마지막 완전 연결층의 입력 값으로 사용함으로써 최종 레이블의 예측값을 생성하게 된다.

(3) 결론

본 연구에서는 보안관제 이벤트를 공격(정탐)과 오탐을 분류할 수 있는 멀티모달 딥러닝 모델을 제안했으며, 실제 이벤트들을 활용하여 모델의 성능을 검증하였다. 이벤트 로그로부터 페이로드와 메타정보라는 이질적 특징을 딥러닝 모델에 성공적으로 학습시켰으며, 사람의 개입이 최소화되는 데이터 기반의 알고리즘 개발이 가능했다. 국내 보안관제센터에서 발생한 실제 보안 이벤트 로그의 83.3%는 보안관제 요원의 직접적인 개입 및 검증을 통해 처리해야만 했지만, 본 연구에서 제안하는 방법론을 적용할 시 99.9%의 정확도로

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

자동화가 가능함을 확인하였다. 또한, 전체 테스트데이터에 대해 0.99 이상의 f1 스코어 성능을 확인하여 제안 기술의 높은 공격 탐지 성능과 다량의 false-positive가 발생하는 문제 해결이 가능함을 입증하였다.



<Figure 3-20> E2E 멀티모달 분류 모델을 통해 미분석 이벤트 정오탐 분류 성능 혼동행렬

<Table 3-8> E2E 멀티모달 분류 모델에 대한 학습 기간별 테스트 성능 정리표

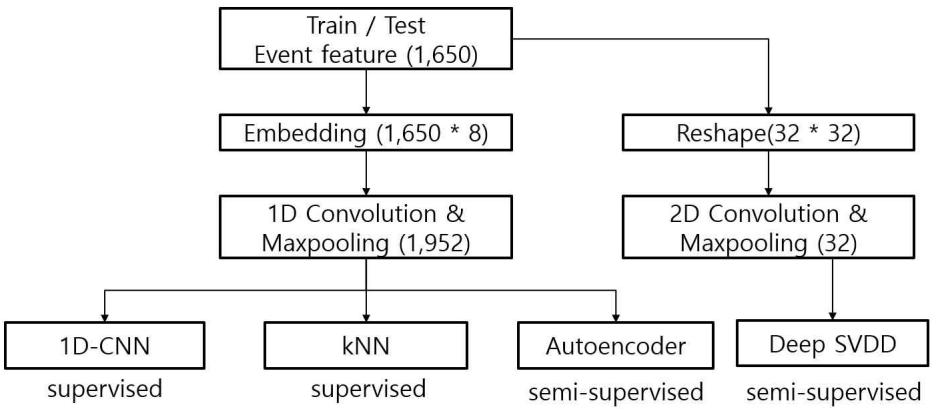
학습 기간	정확도	정밀도	재현율	f1-score
1 ~ 6	0.9995	0.9993	0.99896	0.99913
2 ~ 6	0.99951	0.99925	0.99905	0.99915
3 ~ 6	0.99952	0.99935	0.99899	0.99917
4 ~ 6	0.99956	0.99946	0.99903	0.99925
5 ~ 6	0.99949	0.99924	0.99901	0.99912
6	0.99929	0.99866	0.99888	0.99877

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. Payload 분석을 통한 보안이벤트 레이블 변경 검토 대상 추천

(1) 연구수행 내용 및 절차

지도학습 기반의 인공지능모델이 고성능의 분류결과를 도출하기 위해서는 양질의 학습데이터가 확보가 되어야 한다. 과학기술사이버안전센터의 경우 사람이 설정한 룰(rule)에 따라 이벤트를 분류할 수 있는 SAMRTer 시스템을 보유하고 있으며, 이를 통해 효율적인 보안관제 수행 및 지도학습 기반의 인공지능 모델 생성하기 위한 백데이터(back data) 생성에 이를 활용하고 있다. 그러나 SMARTer의 룰은 사람이 지정하기 때문에 잘못된 룰이 설정되거나 시기에 따라 룰이 변경될 수 있다. 이는 양질의 학습데이터를 생성을 저해할 수 있기 때문에 룰셋에 대한 검증 및 SMARTer 시스템이 부여한 레이블에 대한 검토가 주기적으로 필요하다. 본 연구에서는 kNN, 1D-CNN, 현재 레이블(SMARTer 시스템에서 분류한 레이블) 3개의 결과를 종합한 다수결 모델(Supervised 방식), Semi-supervised 방식의 Autoencoder, Deep SVDD(Deep Support Vector Data Description) 등을 통해 기존의 레이블과 신규 레이블의 결과 비교를 통하여 레이블 변경 대상 선정 및 SMARTer시스템의 검증 룰에 대한 검토를 수행하였다.



<Figure 3-21> 침해위협 분석방법 타임라인

(2) 모델별 기법

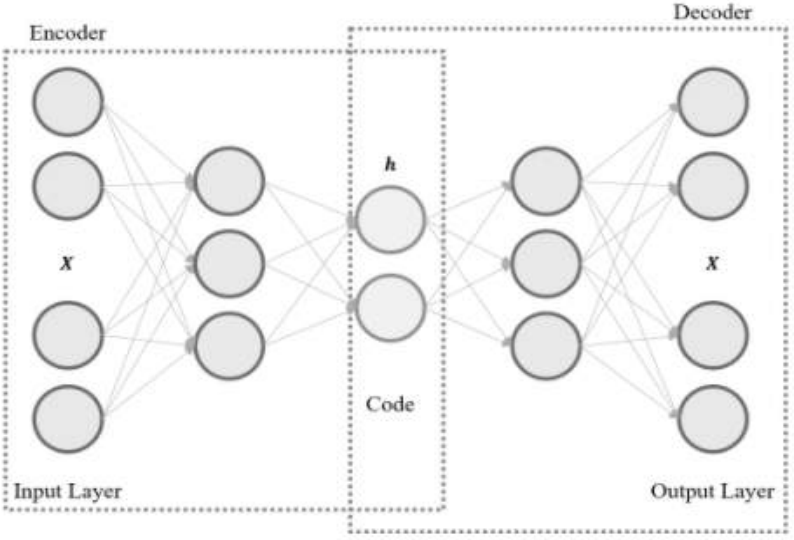
1D-CNN은 '2-가'에서 수행한 방식을 통해 정·오탐을 분류한 모델이다. 각 탐지 이벤트로부터 추출한 1,952개의 feature를 통해서 분류된 결과를 정탐일 경우 '1', 오탐일 경우 '2'로 부여하였다.

kNN은 새로운 데이터가 주어졌을 때 기존 데이터 가운데 가장 유사한 k개 데이터를 가장 가까운 이웃으로 발견해 새로운 데이터에 대한 레이블 및 클래스 값을 예측하여 범주를 추론하는 방식이다. 본 연구에서는 kNN이 특징정보간 거리 값을 계산하는 방법으로 Cosine distance 계산법을 사용했다. Cosine distance는 코사인 유사도(Cosine Similarity)를 이용해 계산 가능하며, 코사인 유사도는 두 벡터 간의 코사인 각도를 이용해 유사도를 산출하는 방식이다. 두 벡터의 방향이 일치하게 되면 1의 값을 가지며, 90°의 각을 이루면 0, 180°로 반대의 방향을

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

가지면 -1의 값을 갖게 된다. 따라서 코사인 유사도는 -1 ~ 1 사이의 값을 가지지만 벡터 행렬은 음수 값이 없으므로 코사인 유사도는 0 ~ 1 사의의 값으로 나타나며 0 에 가까울수록 두 악성코드 간 유사도가 낮고, 1에 가까울수록 유사도가 높다고 판단할 수 있다. 이는 두 벡터가 가리키는 방향이 얼마나 유사한가를 의미하게 된다. Cosine distance는 계산된 코사인 유사도를 1에서 뺄셈하여 측정할 수 있다. kNN은 1D-Convolution 과정을 거친 1,952 Feature를 입력으로 한다. k값을 설정하기에 따라 입력한 검증데이터와 가장 유사한 k개의 학습데이터의 거리 값과 레이블을 확인 할 수 있다.

Autoencoder를 여러 층으로 쌓는 형태의 SAE(Stacked Autoencoder)를 이용해 학습을 진행했다. SAE는 중간층을 기준으로 양쪽이 동일하고, Deep Belief Network(DBN)의 구조를 갖는 특징이 있다. 싱글 Autoencoder와는 달리 여러 개의 Hidden layer로 구성되어 있으며, 하나의 Hidden layer로 구성되었을 때보다 훨씬 다양한 기능을 표현할 수 있어 좋은 성능을 보여준다. 분석할 각 사건의 손실 값은 정탐이벤트만 학습한 모델을 사용하여 계산했다. <Figure 3-22>은 SAE 구조물의 예를 나타낸다.



<Figure 3-22> SAE 의 구조 예시

손실 값은 누적분포함수(CDF)를 사용해 0과 1 사이의 값으로 표현되었다. 이상 데이터 검출은 데이터가 정상과 거리가 먼 특징 정보를 지닐수록 CDF 값이 크다는 점을 활용했다. CDF는 특정 확률 분포에서 랜덤 변수가 특정 값보다 작거나 같은 확률을 나타내며, 계산된 CDF 값이 지정된 임계값보다 크면 의심스러운 이벤트로 판단한다.

Autoencoder는 Embedding 과 1D-Convolution 과정을 거친 1,952 Feature를 입력으로 하며, <Figure 3-23>과 같이 3개의 Dense layer로 이루어져 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Layer (type)	Output Shape	Param #
input_1 (InputLayer)	(None, 1952)	0
dense_1 (Dense)	(None, 800)	1562400
dense_2 (Dense)	(None, 400)	320400
dense_3 (Dense)	(None, 800)	320800
outputs (Dense)	(None, 1952)	1563552

<Figure 3-23> Autoencoder 모델 구성

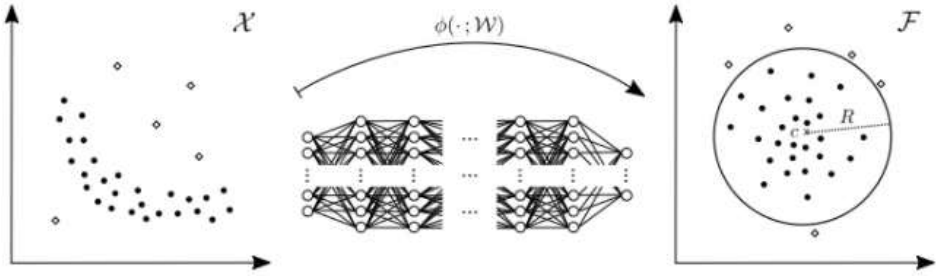
구성된 모델을 이용해 정탐이벤트 추출 Feature만을 이용하여 학습을 진행한 후 검증데이터에 대해서 각 이벤트별 이상치 점수를 계산하였다. <Figure 3-24>은 Autoencoder 모델 결과의 샘플을 나타내며 loss가 손실 값을 outlier_score가 손실 값으로 계산된 CDF 값을 의미한다.

_id	detectName	loss	label	outlier_score
63236925-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002442	1	0.40905
7b56d524-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.001991	1	0.373674
44278e5d-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002246	1	0.393571
b499d5ac-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002363	1	0.402807
17acd1f1-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003309	1	0.479021
7237a80f-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002216	1	0.391167
d865e9fa-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002882	1	0.44434
4028d828-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.004365	1	0.564843
b19c7235-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003007	1	0.454414
d31c0e55-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003416	1	0.487732
93cda77b-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003082	1	0.460546
88dfcbfb-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003376	1	0.484472
098ec92c-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.003092	1	0.46134
9e29c285-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002523	1	0.415477
18cefba3-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002577	1	0.419793
ec80db97-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002465	1	0.410893
737a4f7e-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.001916	1	0.367872
9b99aa4c-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.00309	1	0.461174
2d275f3a-	Malware-PAT-ShadowBrokers(NSA Exploit).17042016	0.002982	1	0.452406

<Figure 3-24> Autoencoder 모델 손실값과 CDF 결과 샘플

Deep SVDD는 SVDD와 딥러닝을 결합한 기법으로 신경망을 통해 특징정보를 추출해 SVDD 기반 비정상 데이터를 탐지한다. Deep SVDD는 이진 분류를 수행하기 위한 경계를 제공하며, 1-SVM과 유사한 특성을 가지고 있다. 1-SVM이 중심지에서 가장 멀리 떨어진 경계선(Hyperplane)을 찾는 것을 목표로 한다면, SVDD는 정상 데이터를 둘러싼 가장 최적의 중심과 경계 영역(Hypersphere)을 찾는 것을 목표로 한다. 또한 이상치 검출에 대한 경계도 제공한다. Deep SVDD 모델은 인터넷 상의 오픈된 소스코드를 사용하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-25> Deep SVDD의 예시

이상 데이터 검출은 입력데이터와 중심지의 거리가 클수록 정상 데이터와 차이가 크다는 점을 활용한다. Deep SVDD를 통해 계산된 거리 값을 이용하여 누적분포함수(CDF)를 계산해 이상치 검출에 활용했다. Deep SVDD은 detectName Feature와 payload Feature를 합한 1,650 Feature를 입력으로 한다. Deep SVDD의 학습에 이용된 딥러닝 모델은 CNN(Convolution Neural Network)구조로서 이미지 형태의 입력을 사용한다. <Figure 3-26>은 모델의 구성을 나타낸다.

Layer (type)	Output Shape	Param #
conv2d (Conv2D)	(None, 32, 32, 8)	200
leaky_re_lu (LeakyReLU)	(None, 32, 32, 8)	0
batch_normalization (BatchNo	(None, 32, 32, 8)	32
max_pooling2d (MaxPooling2D)	(None, 16, 16, 8)	0
conv2d_1 (Conv2D)	(None, 16, 16, 4)	800
leaky_re_lu_1 (LeakyReLU)	(None, 16, 16, 4)	0
batch_normalization_1 (Batch	(None, 16, 16, 4)	16
max_pooling2d_1 (MaxPooling2	(None, 8, 8, 4)	0
flatten (Flatten)	(None, 256)	0
dense (Dense)	(None, 32)	8192

<Figure 3-26> Deep SVDD 학습에 사용된 CNN 모델 구조

<Figure 3-26>의 모델은 이미지 형태의 입력을 받기 때문에 1,650 Feature에 대해서 32x32 크기의 2차원의 이미지의 형태로 변환하는 과정을 거쳤다. 1,650 개의 특징 정보 중 32x32에 해당하는 1,024개의 특징 정보를 순서대로 사용했으며 1,024개에서 초과되는 특징정보는 사용하지 않았다. <Figure 3-27>은 Deep SVDD 결과의 샘플을 나타내며, dsvdd_score는 Deep SVDD를 통해 계산된 거리 값을 의미하며 outlier_score는 거리 값을 이용하여 계산된 CDF 값을 의미한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

_id	detectName	analyResu	dsvdd_score	outlier_score
d925d0ae-	[KISTI_100118_01] DNS SinkHole	1	46.69	0.484609
c0c7ffa4-3	[KISTI_100118_01] DNS SinkHole	1	49.66	0.485655
0887e975-	[KISTI_100118_01] DNS SinkHole	1	34.19	0.480215
6c326835-	[KISTI_100118_01] DNS SinkHole	1	40.8	0.482539
a1582dac-	[KISTI_100118_01] DNS SinkHole	1	47.9	0.485036
f7a7ee4d-	[KISTI_100118_01] DNS SinkHole	1	28.19	0.478104
d2ea50aa-	[KISTI_100118_01] DNS SinkHole	1	33.2	0.479866
c3d03988-	[KISTI_100118_01] DNS SinkHole	1	39.34	0.482026
d76eeb87-	[KISTI_100118_01] DNS SinkHole	1	33.76	0.480063
6f4c15ce-7	[KISTI_100118_01] DNS SinkHole	1	45.26	0.484106
925c8443-	[KISTI_100118_01] DNS SinkHole	1	54.13	0.487227
9551180f-4	[KISTI_100118_01] DNS SinkHole	1	76.65	0.495153
4f213e0b-	[KISTI_100118_01] DNS SinkHole	1	33.97	0.480136
c1cdb27a-	[KISTI_100118_01] DNS SinkHole	1	69.46	0.492624
2316afee-4	[KISTI_100118_01] DNS SinkHole	1	31.18	0.479155
284b81a1-	[KISTI_100118_01] DNS SinkHole	1	40	0.482255
1ab38c51-	[KISTI_100118_01] DNS SinkHole	1	45.26	0.484106
daaa17a1-	[KISTI_100118_01] DNS SinkHole	1	69.2	0.49253
c42edc1a-	[KISTI_100118_01] DNS SinkHole	1	29.78	0.478662

<Figure 3-27> Deep SVDD 결과값과 CDF결과 샘플

앞서 설명한 3가지 모델을 이용한 다수결 모델과 semi-supervised방식(auto encoder, Deep SVDD)을 통해 현재 레이블(analyResult)의 검토 및 레이블 변경 검토대상을 선정하였으며, 그 결과는 다음과 같다. kNN의 경우 k값을 1~3까지 적용하여 모두 동일하게 분류되는 이벤트만 이벤트만을 대상으로 선정하였다.

<Table 3-9> kNN 모델의 레이블 예측 방식 예시

No.	k=1의 Label	k=2의 Label	k=3의 Label	kNN Result
1	정탐	정탐	정탐	정탐
2	정탐	정탐	오탐	분석제외
3	정탐	오탐	정탐	
4	정탐	오탐	오탐	
5	오탐	정탐	정탐	
6	오탐	정탐	오탐	
7	오탐	오탐	정탐	
8	오탐	오탐	오탐	오탐

현재 레이블, 1D-CNN, kNN 3개 모델의 레이블을 이용하여 2개 이상의 모델이 동일한 결과를 예측한 값으로 다수결 모델의 레이블을 부여하였다. 이렇게 부여된 다수결 모델의 레이블과 현재 레이블인 analyResult 값을 비교하여 레이블 변경 검토 대상을 선별 할 수 있다. 또한 각 모델의 판단결과에 따라 다양한 결과해석이 가능하다. <Table 3-12>은 각 모델의 결과에 다른 다수결 모델의 결과를 나타낸다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<Table 3-10> 다수결 모델 기반 레이블 변경대상 산출 결과

분류	모델별 결과(건)			
	kNN	분류모델 (1D-CNN)	현재 레이블 (analyResult)	다수결 모델
Case1	공격	공격	공격	공격
Case2	공격	공격	정상	공격
Case3	공격	정상	공격	공격
Case4	공격	정상	정상	정상
Case5	정상	공격	공격	공격
Case6	정상	공격	정상	정상
Case7	정상	정상	공격	정상
Case8	정상	정상	정상	정상
Case9	분석 제외			

Case1, Case8에 해당하는 이벤트는 kNN, 분류모델, 현재 레이블의 결과가 모두 일치하여 다수결 모델의 결과 역시 동일하게 판단한다. Case2, Case7에 해당하는 이벤트는 kNN, 분류모델이 동일한 판단을 하며 현재 레이블이 상반되는 판단을 하고 있으므로 다수결 모델은 kNN, 분류모델과 동일한 결과를 산출하며, 현재 레이블 변경 검토의 필요성을 제시한다. Case3, Case6에 해당하는 이벤트는 kNN, 현재 레이블이 동일한 판단을 하며 분류모델이 상반되는 판단을 하고 있으므로 다수결 모델은 kNN, 현재 레이블과 동일한 결과를 산출하며, 분류모델의 검토 필요성을 제시한다. Case4, Case5에 해당하는 이벤트는 분류모델, 현재 레이블이 동일한 판단을 하며 kNN이 상반되는 판단을 하고 있으므로 다수결 모델은 분류모델, 현재 레이블과 동일한 결과를 산출하며, 해당 이벤트와 kNN 유사도가 높은 학습데이터의 이벤트의 레이블변경 검토 필요성을 제시한다. 탐지 이벤트는 정탐과 오탐의 불균형 문제가 존재하기 때문에 이를 고려하여 detectName 별 정오탐 데이터 현황을 조사하여 비율이 적절한 이벤트를 선정하여 해당 방법의 적절성을 검증하였다.

(3) 결론

detectName ‘WEB-PAT-00-00-XXXXX’(가칭)인 보안 이벤트는 약 11만개가 발생하였으며, 이 중 약 5,000개를 학습데이터, 약 800개를 검증데이터로 활용하였으며, 구성한 데이터 셋의 학습데이터를 이용하여 1D-CNN, Autoencoder, Deep SVDD 모델을 학습하고 테스트데이터를 이용하여 결과를 확인했다. 각각의 결과는 <Table 3-11>, <Table 3-12>와 같다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<Table 3-11> WEB-PAT-00-00-XXXXX 데이터셋 구성

학습데이터		테스트데이터	
정탐	오탐	정탐	오탐
249	5,111	138	695
합계		합계	
5,360		833	
총 합계			
6,193			

<Table 3-12> 1D-CNN 모델 평가 지표

분류	Result(%)
Accuracy	97.95
Precision	100.0
Recall	87.68
F1 score	93.43

<Table 3-13> Semi-Supervised 모델 실험 결과

분류	학습데이터		테스트데이터	
	정탐	오탐	정탐	오탐
Autoencoder(CDF)	0.15163	0.51523	0.27373	0.307775
Deep SVDD(CDF)	0.10052	0.49030	0.13534	0.30743

<Table 3-11>, <Table 3-12>에 따라 각각의 이벤트의 정·오탐 여부를 표시하고 기존 레이블과 그 결과를 비교하여 <Table 3-14>과 같이 정리 및 비교하여 레이블 검토 대상을 선정하였다.

<Table 3-14> 다수결 모델 기반 레이블 변경대상 산출 결과

분류	모델별 결과(건)				해석
	kNN	분류모델 (1D CNN)	현재 레이블 (analyResult)	다수결 모델	
Case1	공격 (175)	공격 (120)	공격 (120)	공격	현재 레이블 유지
Case2			정상 (0)	공격	현재 레이블 검토 필요
Case3		정상 (55)	공격 (1)	공격	분류모델 검토필요
Case4			정상 (54)	정상	학습데이터 레이블 검토필요
Case5	정상 (623)	공격 (0)	공격 (0)	공격	
Case6			정상 (0)	정상	분류모델 검토필요
Case7		정상 (623)	공격 (16)	정상	현재 레이블 검토 필요
Case8			정상 (607)	정상	현재 레이블 유지
Case9	분석 제외(35)			공격/정상	현재 레이블 유지

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

다수결 모델 결과를 분석한 결과 기존레이블을 유지하는 Case1, Case8, Case9의 경우 91.47%였으며, 분류모델의 판단이 잘못된 Case3, Case6은 0.12%로 확인할 수 있었다. 테스트데이터의 현재 레이블이 잘못되었는지 검토가 필요한 Case2, Case7의 경우 1.92%로 나타났으며, 학습데이터의 이벤트에 대해서 레이블 검토가 필요한 Case4, Case5의 경우에는 6.48%로 확인 가능했다. <Table 3-15>는 해석별 전체대비 분포의 요약을 나타낸다. 해당 결과를 토대로 검토된 이벤트들 및 룰셋을 검증한 결과 실제 학습 데이터 및 분류모델이 판단한 결과에 오류가 있음을 확인하였다.

<Table 3-15> 해석별 전체대비 분포 요약

분류	Result(%)
현재 레이블 유지	91.47
분류모델의 오판	0.12
테스트데이터 레이블 검토	1.92
학습데이터 레이블 검토	6.48

본 연구에서는 기존 모델 및 레이블들을 검토하여 학습데이터를 검증하고 일관성을 확보하여 양질의 학습데이터를 향상시키는데 그 의의가 있다. 다수결 모델 및 준지도학습을 통한 분류 결과를 통해 기존의 결과와 상이한 이벤트결과 또는 기존의 결과가 오판이었을 가능성을 내포한 이벤트들을 검출하는 것을 검증하였으며, 이를 통해 데이터의 일관성·순수성(purity)를 향상시킴으로써 고성능의 인공지능 모델 생성이 가능함을 입증하였다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제5절 정보보안 환경 강화 기반 조성

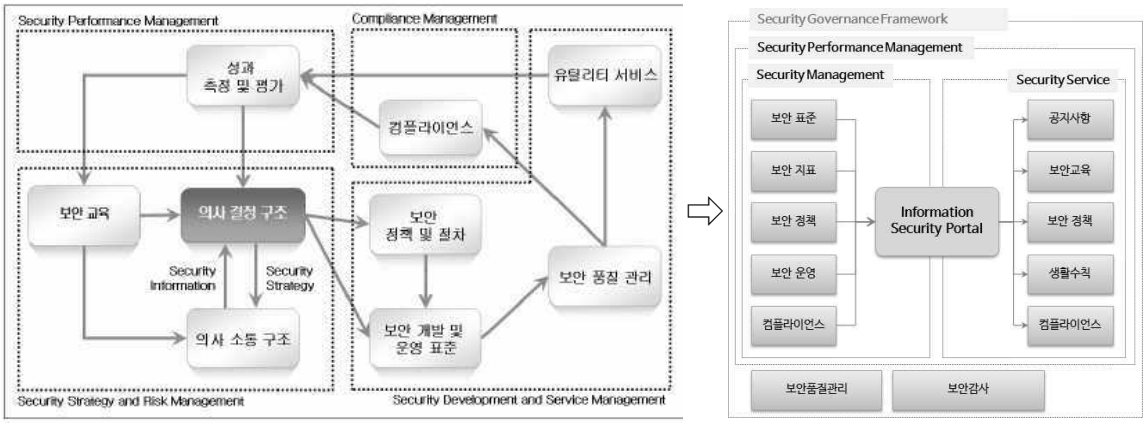
1. 연구개발 추진방법

국가정보보안관리체계는 정보보안거버넌스 관점에서 국가정보원이 국가 정보보안에 대한 기획 및 조정업무를 수행하고 있다. 또한 각급 중앙부처를 중심으로 정보보호담당관 조직을 신설하여 정보보안 업무에 대한 관리체계를 수립 및 운영하고 있으며, 보안관제 중심의 사이버 침해대응 업무에 대하여 주요 기관별 사이버대응센터를 통해 소속 및 산하기관에 대한 대응태세를 갖추고 있다.



<Figure 3-37> 국가정보보안관리체계

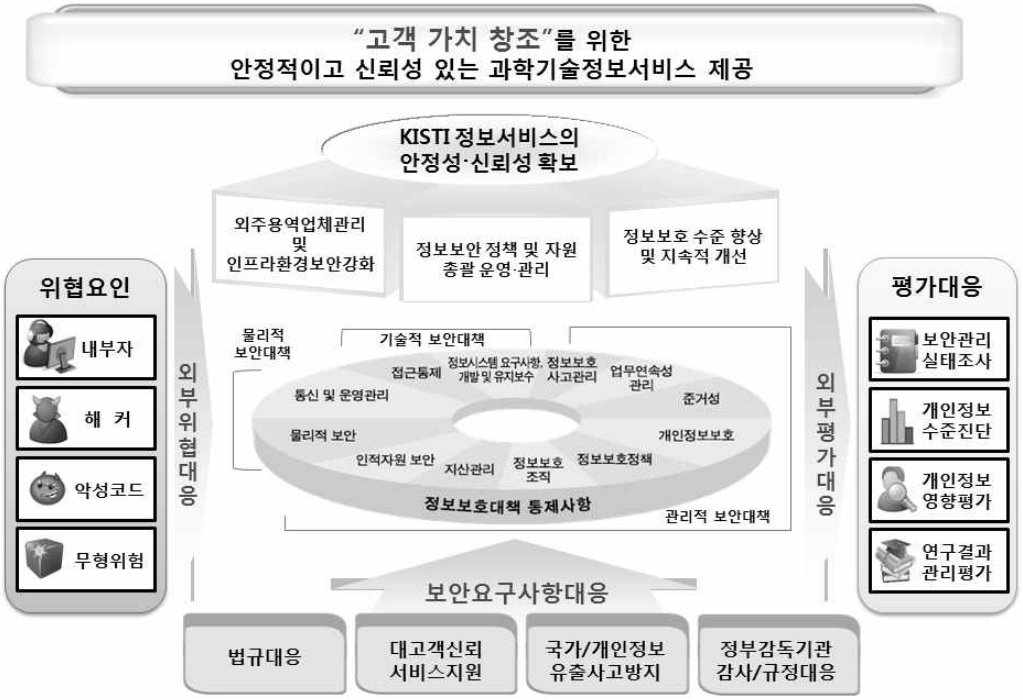
과학기술사이버안전센터에서는 국가정보원의 국가정보보안기본지침을 근거로 과학기술정보통신부 산하기관의 보안관제 및 기관 내 보안관리체계를 운영하고 있다. 또한 과학기술 생태계의 안정적 지원을 위하여 신뢰성 있는 과학기술정보서비스 제공을 목표로 정보보안거버넌스 관점에서 정보보안 서비스 통합을 수행하고 있다.



<Figure 3-38> 정보보안 거버넌스 프레임워크

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

과학기술사이버안전센터에서 제공하는 보안서비스의 종류는 정보보안 정책, 대고객 서비스 지원, 유출사고 방지, 내·외부 감사 대응 등으로 변화하는 정보화환경에 맞는 다양한 보안 요구사항에 맞게 관리적, 기술적, 물리적 보안대책을 다음의 목표와 함께 수립하여 추진하고 있다.



<Figure 3-39> 한국과학기술정보연구원 정보보안체제 활동목표

과학기술사이버안전센터는 대외기관의 보안관제서비스 안정화와 원내 사용자 주요 보안서비스의 안정적 실현을 목적으로 기관 정보보안관리체계를 정비하였다. 본 연구에서는 정보보안 환경강화 기반 조성으로 보안관리체계 부문에서 다음과 같은 주제를 중심으로 수행하고자 한다.

○ 정보보안관리체계의 안정적 운영을 위한 기반 마련

- 정보보안관리체계의 대응력 강화를 위한 추진체계 수립 및 관리적·물리적·기술적 보안부문별 주요 정보보안 활동

○ 사용자 정보보안 환경 강화를 위한 주요 추진사항

- 과학기술분야 안정적 서비스 제공을 위한 정보보안 주요 부문별 정보보안 운영 개선 사례를 중심으로 사이버 침해위협 최소화

○ 기관 맞춤형 개인정보보호 관리체계 정립

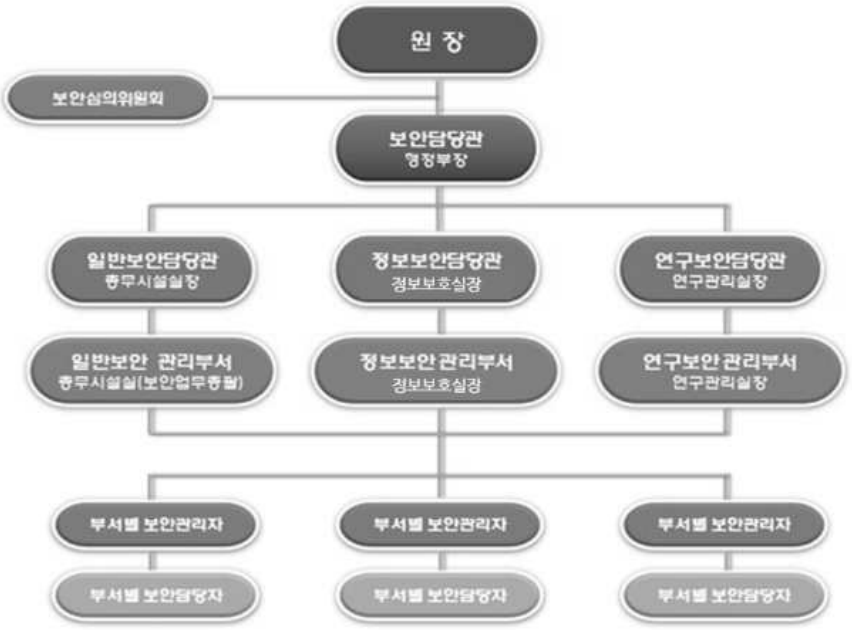
- 주요 개인정보보호 추진과제 및 사례 중심의 부서별 맞춤형 대응활동을 통해 개인정보 침해 및 노출 최소화 실현

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 정보보안관리체계 안정적 운영을 위한 기반조성

가. 정보보안관리체계 기반 조성을 위한 조직구성

한국과학기술정보연구원 보안조직은 보안담당관을 중심으로 일반보안, 정보보안, 연구보안으로 구분하여 운영되고 있으며, 각 부문별 담당관을 중심으로 보안관리 업무를 수행하고 있다. 정보보안 부문에서는 정보보안담당관을 중심으로 아래와 같이 대응 조직을 구성하고 있으며, 부서별 보안관리자를 임명하여 지원조직을 구성하고 있다.



<Figure 3-40> KISTI 정보보안 대응 조직

부서별 보안조직은 부서별 보안관리자를 부서장으로 임명하고, 부서별 보안관리자를 지원하기 위한 부서별 보안담당자를 정보보안과 개인정보보호로 구분하여 각각 임명하여 구성하고 있다. 이를 통해 KISTI에서는 정보보안의 국가정책에 따라 기관담당과 부서담당의 협업 하에 각종 이행사항에 대한 긴밀한 대응을 위한 협조 공조체제를 유지하고 있다.

나. 정보보안 관리체계 주요활동

정보화를 통한 지능정보사회 견인을 위해 핵심 분야로 떠오르는 AI, 클라우드 등 정보화 자원 활용 및 연구 분야 확대로 혁신 성장을 위한 사람중심의 4차 산업혁명 대응계획이 수립되고 추진되면서, 정보자원 종합관리를 위한 정보관리체계 고도화가 요구되고 있다. 따라서 각각의 다양한 연구 환경 및 디바이스, IoT 등을 활용함으로써 보안 관리 포인트가 증가하게 되어 체계적이고 일괄적인 정보보안 전략 수립의 필요성이 증가되고 있다. 이에 대한 지능화된 보안 위협 요인에

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대해 통합 모니터링 체계를 구축 및 정보서비스 전반의 보안정책이 지속적으로 강화 되어야 한다. 이를 위해 본 연구에서는 KISTI 정보화 자원 고도화를 위한 업무 프로세스 개선 및 관련 관리체계를 정비하여 개선활동을 수행하고자 한다.

국가 과학기술 연구기관의 위상에 맞는 중요 연구정보 및 개인정보 유출에 대해서는 타겟형 정보자원의 위협요인에 대해 선제적이고 즉각적인 사이버 공격 대응이 필요하며 보다 강화된 예방활동을 진행하여 만약의 사태를 대비해야만 한다. 이는 IT 환경 및 보안 패러다임의 변화에 KISTI의 역할이 더욱 강화되어야 함을 의미하며, 불특정다수를 대상으로 하는 E-mail등 을 통한 랜섬웨어(Ransomware) 공격 및 APT(Advanced Persistent Threat) 공격과 같은 지능형 표적 공격에 대하여 강화된 보안의식을 바탕으로 전사적인 보안 인식 변화가 요구된다. 이를 위해 사용자 보안 강화를 위한 KISTI 정보보안 체계를 구축하여 사이버 해킹 등 지능화된 공격으로부터 정보자원의 안전한 보호 및 지속적인 운영을 위한 환경을 구축해야 한다.

우선 KISTI의 중요 연구정보 자원 및 개인정보 등 중요 정보 유출에 대해서는 사전 예방 강화를 위해 엔드 포인트 시스템에 대한 데이터 보안 환경을 구축해야만 한다. 그러기 위해서는 사용자의 기기의 최선의 방어 대책인 백신 기능 강화 및 보안장비의 정책에 대한 주기적인 점검 등 사이버공격 침투 경로에 사전 예방 및 분석을 통한 중요 정보가 유출될 수 있는 다양한 경로를 효과적으로 차단하고 있다.

마지막으로 업무용 사용자 PC 내의 중요 정보 파일을 중앙집중식 관리 시스템을 도입하여 체계적으로 관리할 수 있는 기반을 확보하여 중요 정보의 유출 위험성을 조기 발견하고 조치할 수 있도록 한다. 사용자 보안의 경우 보안 인식에 대한 역량 강화를 위해 지속적이고 체계적인 교육이 이루어 질 수 있도록 하며, 이를 유형별 상황별 부서별로 분류하여 각각의 여건에 맞는 맞춤식 교육이 진행될 수 있도록 교육 체계를 정비하여야 한다. 또한 보안 교육 후에는 사용자와 담당자와의 상호 커뮤니케이션을 비롯하여 사용자가 작성할 수 있는 설문조사를 시행하여 보안에 대한 피드백을 받을 수 있는 채널을 다각화함과 동시에 차기 교육과정 및 보안정책에 반영할 수 있는 체계를 수립하여야 한다. 이를 바탕으로 보안업무의 관리적/기술적/물리적 보안으로 구분하여 사용자들의 보안에 관한 인식 제고 및 KISTI에 맞는 보안 정책을 수립할 수 있는 기반을 마련하여야 한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<Table 3-12> 주요 정보보안 추진 활동

구분	주요 보안활동
관리적 보안	◦ KISTI 정보보안 지침 개정을 통한 정보보안 업무 현행화 ◦ 정보시스템 도입 및 증설에 대한 보안성 검토 의뢰 강화 ◦ 업무 담당자 및 영역별 보안 교육 수행 - 정보보안 교육 계획 수립 - 보안 사고자에 대한 교육 의무 수행 ◦ KISTI 정보보안 매뉴얼, 정보보안 및 개인정보보호 담당자 지정 운영을 통한 정보보안 관리체제 현행화 유지 ◦ 주요정보통신기반시설 관리체계 추진 - 국가슈퍼컴퓨팅 및 과학기술연구망 대상 보안관리 실시
기술적 보안	◦ 정보보안 시스템 통합 운영으로 업무 수행의 효율성 확보 - 정보보안 장비 정책 재정비를 통한 보안성 강화 - 신규 도입 정보보안 장비의 기관 정책 반영을 통한 안정적 운영 ◦ 기관 운영 홈페이지 취약점 점검을 통한 사전 예방 강화 - 홈페이지별 취약점 점검 결과 제출 및 개선 계획 수립 - 홈페이지 위·변조로 인한 침해사고 사전 대응 - 개인정보처리시스템 대상 개인정보 노출점검 및 접속기록 점검 실시 ◦ 무선 네트워크에 대한 보안성 강화(비인가 무선 AP 차단 등)
물리적 보안	◦ 용역사업에 대한 보안관리 강화 - 참여인력 및 정보시스템 사용 환경에 대한 보안 강화 - 보안성 검토 및 정보보안 감사 실시

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 사용자 정보보안 환경강화를 위한 주요 추진사항

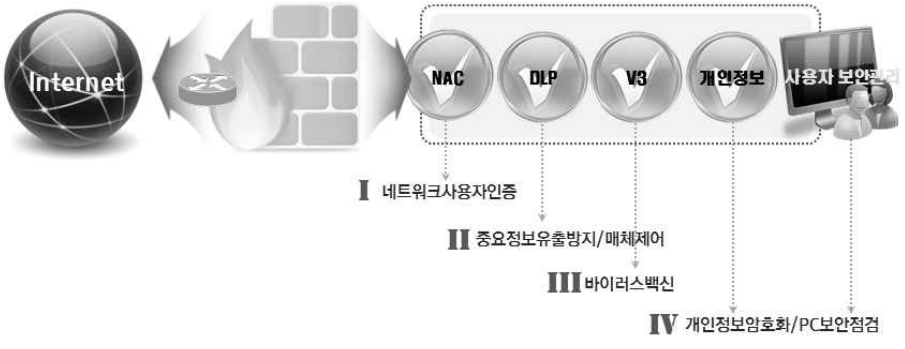
가. 안전한 연구환경 구축을 위한 보안시스템 구축

(1) 보안환경 강화를 위한 단계적 대응체계 수립

최근 보안사고의 유형 및 공격 특징을 살펴보면 사용자 IT 환경과 밀접하게 연관되어 공격자의 공격방법 및 유형이 다양화되고 있는 경향을 보이고 있다. 그 중 사용자 PC를 중심으로 관련 피해사례가 급증하여 사이버공격이 갈수록 고도화 지능화되고 있는 경향을 볼 수 있다. 예를 들면 악성코드 은닉사이트를 통한 홈페이지 은닉형 악성코드 중에서는 정보유출 및 파밍, 랜섬웨어 분야를 중심으로 취약점을 이용한 유포 및 악성코드 유포의 형태로 진행되는 것으로 나타났다.

이에 과학기술사이버안전센터에서는 변화하는 IT환경에 대응하는 사용자 보안 강화를 위하여 4단계 사용자PC 보안 구성을 적용 후 운영하고 있다. 현재 운영 중인 사용자 정보보안 시스템은 현재 유행하고 있는 지능화되고 복합적인 공격들에 대하여 해당 유형별로 파악하고 대응할 수 있는 기반을 마련하였다. 사용자 PC에 가해지는 공격들을 예측하고 이에 대한 선행적 대응이 가능하다면 보다 안전한 연구 환경에서 사용자들이 업무를 진행할 수 있을 것으로 기대한다.

원내 정보보안 전담조직을 중심으로 최종사용자인 PC에 접근하는 각각의 네트워크 레이어(Layer)를 중심으로 APT 공격 사전차단을 위한 차세대방화벽, 네트워크사용자 인증을 통한 접근통제, 중요정보 및 개인정보 유출방지(DLP)를 위한 취약점 점검툴, 사용자 PC에 가해지는 공격들을 예측하고 이에 대한 선행적 대응을 위한 바이러스 백신 및 암호화 툴 등을 중심으로 사용자PC에 대한 4중 구조의 보안체계를 적용하여 운영 중에 있다. KISTI 사용자보안체계는 보다 안전한 연구 환경에서 사용자들이 효율적으로 업무를 수행할 수 있도록 중점을 두고 설계하였다.



<Figure 3-41> 사용자 보안 시스템 구축 현황

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

한국과학기술정보연구원은 과학기술분야 정보서비스의 안정적 운영을 위하여 전담 보안조직을 신설(2015년)하여 운영하였고, 별도의 보안조직을 바탕으로 정보보안분야 중장기계획을 수립하여 사용자 보안시스템을 단계적으로 강화·적용하였다.

<Table 3-13> 사용자 보안 시스템 및 주요 기능

정보보안시스템명	주요 기능
네트워크접근제어시스템	◦ 내부 네트워크 이용시 사용자 인증을 통한 접근 및 미인증 사용자 접근 통제 ◦ 기관 제공 필수 소프트웨어의 배포 및 강제설치 등 사용자 보안 정책 적용 ◦ 미인가 IP 주소에 대한 네트워크 접근 통제 및 IP 관리 현행화 ◦ 네트워크 내 비정상 트래픽 제어 기능
유해사이트차단 솔루션	◦ 악성코드 유입 방지를 통한 세이프 브라우징 및 비업무사이트 차단
매체제어/DLP시스템	◦ 사용자 PC의 각종 포트/인터페이스에 대한 비인가 접근 차단 ◦ 우회경로 툴, 메일, 메신저 등을 통한 내부 자료 유출 차단 ◦ 네트워크 공유 폴더 금지 기능 ◦ 소프트웨어 보안USB 기능
사용자PC 수준진단 관리시스템	◦ 원내 사용자에 대한 보안실태 파악 및 수준 진단을 통한 중앙 점검 ◦ 윈도우 자동 로그온 금지, 바이러스 백신 사용 유무, 윈도우 방화벽 사용 등 사용자 PC 보안점검 정책 적용 ◦ 주민등록번호, 계좌번호 등 개인정보 검출 기능 및 암호화 기능 ◦ 악성코드 및 좀비PC 방지를 위한 알려지지 않은 프로세스 차단 기능
바이러스 백신	◦ 바이러스 및 악성코드 차단

정보보안 인식 제고를 위해 기존의 단순한 교육전달에서 벗어나 양방향 서비스가 될 수 있는 다양한 활동을 수행하였다. 부문별, 업무형태별, 지역별 맞춤형 교육 시행으로 교육의 내실화와 전사적 인식을 강화할 수 있는 교육을 운영하였으며, 내부 소통을 위한 아이디어 도출과 사용자가 공감할 수 있는 정책을 발굴하여 실천방안을 제시하는 적극적인 노력을 수행하였다. 특히 '생활속의 보안'이라는 주제로 보안 준수사항을 지속적으로 인지할 수 있는 홍보자료를 제작하여 배포하였다.



<Figure 3-42> 정보보안 인식제고를 위한 주요 활동(캘린더, 가이드, 스크린세이버 제작)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 본관 통합전산실 통신 인프라 개선 및 주요 서비스 이전

2019년 추진된 「슈퍼컴퓨터 4호기 전산실 및 기반시설 환경개선 공사」가 완료됨에 따라 본관 대내외 서비스용 전산시스템이 본관 통합전산실로 이전되었다. 연구 분야별 소규모 LAB실에서 산재되어 운영중인 전산시스템이나 보안장비 없이 운영되고 있는 전산자원을 위해 과학기술사이버안전센터에서는 연구지원용 네트워크 존(R-DMZ)을 전년도에 구축 완료 하였으며, 금년 전산실 이전을 계기로 물리적인 네트워크 이전과 동시에 연구전용 보안체계 구축과 일원화된 방어체계 마련을 위한 R-DMZ 존으로 논리적인 네트워크 통합 구축을 추진하였다.

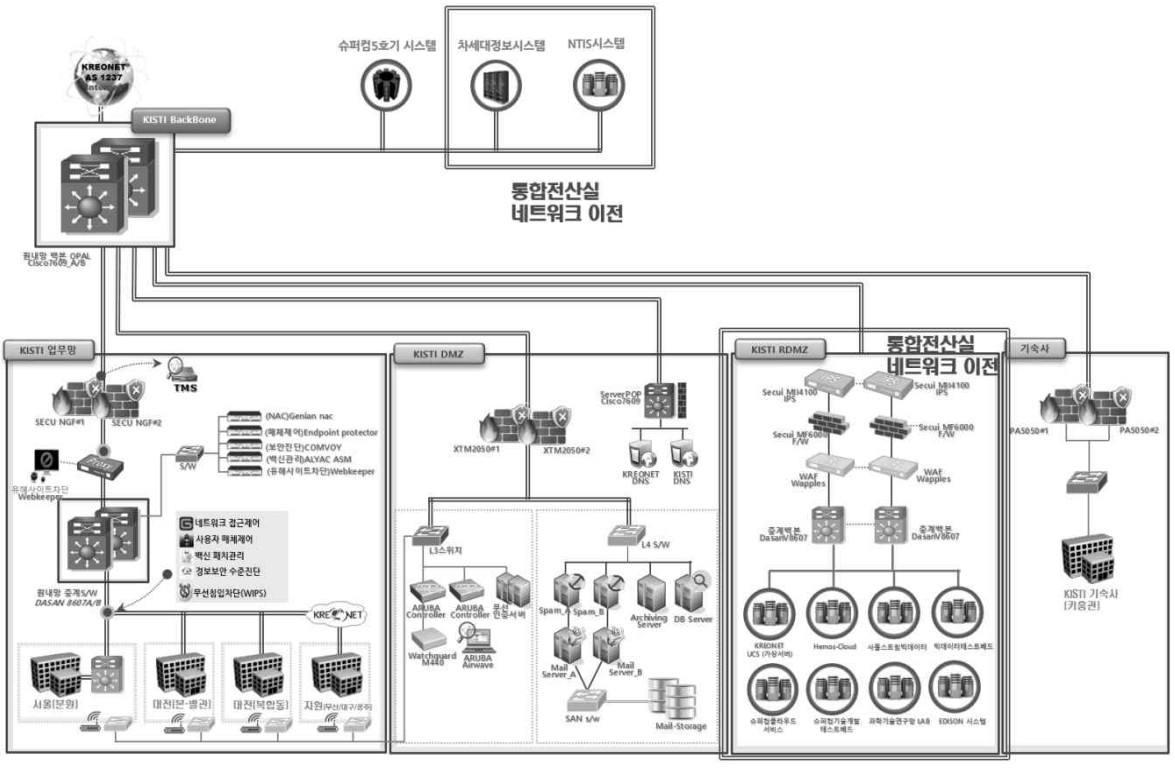
이전 대상 네트워크는 차세대정보시스템 네트워크 포함 18개 네트워크이며 2020년 07월부터 약 3개월간 케이블 인프라 구축, 정보보안시스템 정책 수립, 서비스 네트워크 연동 등이 진행되었다.

<Table 3-14> 본관 통합전산실 이전 네트워크 내역

번호	네트워크명	부서명	설치장소		연동 속도
			기존	변경	
1	슈퍼컴클라우드서비스	슈퍼컴인프라센터	공용서버실	통합전산실	1G, 10G
2	사물데이터수집시스템	연구데이터공유센터	공용서버실	통합전산실	1G
3	빅데이터테스트베드	연구데이터공유센터	공용서버실	통합전산실	1G
4	헤모스클라우드	가상설계센터	공용서버실	통합전산실	10G
5	에디슨(EDISON)서비스	계산과학플랫폼센터	공용서버실	통합전산실	1G
6	슈퍼컴퓨팅응용 LAB	슈퍼컴퓨팅응용센터	슈퍼컴(4)전산실	통합전산실	1G, 10G
7	슈퍼컴클러스터(246net)	슈퍼컴퓨팅기술개발센터	슈퍼컴(4)전산실	통합전산실	1G
8	슈퍼컴클러스터(250net)	슈퍼컴퓨팅기술개발센터	슈퍼컴(4)전산실	통합전산실	1G
9	데이터기반문제해결연구단 클러스터 서비스	데이터기반문제해결연구단	공용서버실	통합전산실	1G
10	차세대정보시스템	정보시스템운영실	정보시스템 전산실	통합전산실	10G
11	차세대정보시스템 DR	정보시스템운영실	정보시스템 전산실	통합전산실	1G
12	NTIS 시스템	NTIS센터	정보시스템 전산실	통합전산실	10G
13	NTIS 시스템(ARS시스템)	NTIS센터	정보시스템 전산실	통합전산실	1G
14	연구망 (R&E)시스템	과학기술연구망센터	본관 2층 ANTLAB	통합전산실	1G
15	연구망 (KAFE/CORREEN)시스템	과학기술연구망센터	본관 2층 ANTLAB	통합전산실	1G, 10G
16	연구망(ScienceDMZ)시스템	과학기술연구망센터	본관 2층 ANTLAB	통합전산실	100G
17	국가데이터공유 시스템	연구데이터공유센터	정보시스템 전산실	통합전산실	10G

대내 서비스용 연구지원 네트워크 통합 구축·이전을 통해 취약한 인터넷으로부터 공격 원천 차단 및 서비스 유형별 맞춤형 보안정책 적용으로 보안성을 강화한 네트워크 구성을 완료하였다. 또한 산재되어 운영되던 연구목적 시스템이 통합전산실의 안정적인 전산 인프라(항온항습, 물리적 접근통제, 안정적인 전원공급)를 통해 위험요인을 최소화함으로써 향후 네트워크 안정성 확보에 의의를 두고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-43> 통합전산실 이전 네트워크 구성도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 사이버보안진단의 날 운영 및 통합보안결재 운영

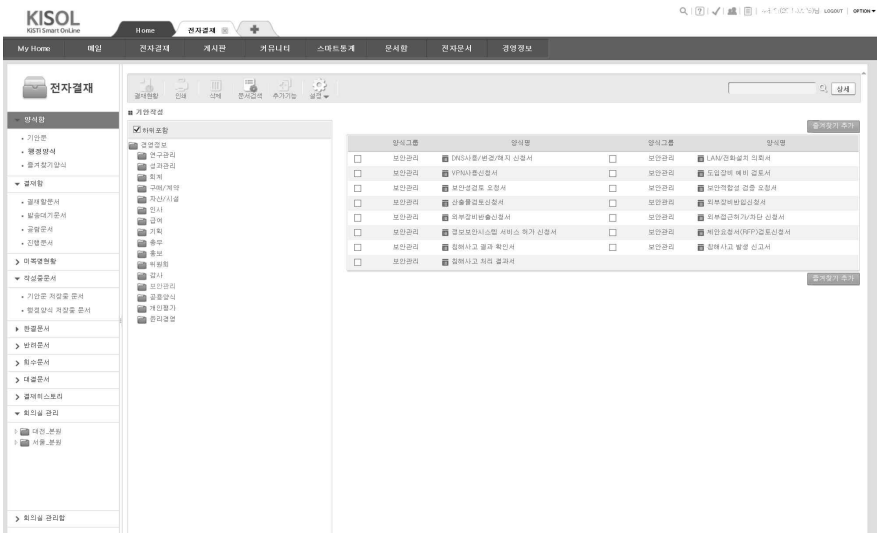
최근 급증하는 사이버 침해 및 정보 유출 사고에 대한 대응능력 배양 및 중요 정보자원의 위협 요인에 대한 사전 예방활동 강화하기 위해 매월 세 번째 주 수요일을 KISTI 사이버보안진단의 날로 지정하여 운영하고 있다.

사이버보안진단의 날은 정기적으로 실시하는 부서별 보안담당자의 협조를 통한 관리적보안의 측면과 실시간으로 실시되는 중앙집중식 PC보안취약점 점검 툴의 운영으로 구분하여 실시하고 있다. 향후 KISTI에서의 업무 환경 변화 및 유관 기관의 정책 변화에 대응하기 위한 내부규정 정비, 자체 보안감사 수행 및 예방활동 강화 등 정보보안 정책 및 전략 수립을 위한 정보보호 수준 신뢰도 제고에 반영하는 것을 목표로 하고 있다.

<Table 3-14> 사이버보안진단의 날 운영현황

구 분	주 기	역 할	비 고
사이버보안진단의 날	정기(매월)	부서별 점검 실시	부서별 담당주관
PC보안 취약점 점검	실시간	11개 지표 준수현황	실시간 중앙관리

또한, KISTI 직원의 보안의식 고취를 위해 설계된 기존 온라인 사이버안전센터와 병행하여 관리 하고 있었던 보안결재 항목에 대하여 이용자들의 편의성을 제고하고자 과학기술사이버안전센터에서는 보안교육, 보안감사, 보안 관련 결재(총 15종)를 직원들에게 제공하고 있다. 2020년도에 15개 부문의 보안결재에 대하여 DNS사용/변경(88건), LAN 및 전화설치(157건), 보안성 검토요청(98건), 보안적합성 검증(4건), 외부접근허가(383건), 제안요청서 검토(101건), VPN사용신청(1579건), 산출물 검토신청(29건) 등 총 2,439건을 보안관리 결재항목에서 활발하게 직원들이 활용하고 있다.



<Figure 3-44> 보안결재 프로세스 효율화를 위한 인트라넷 통합

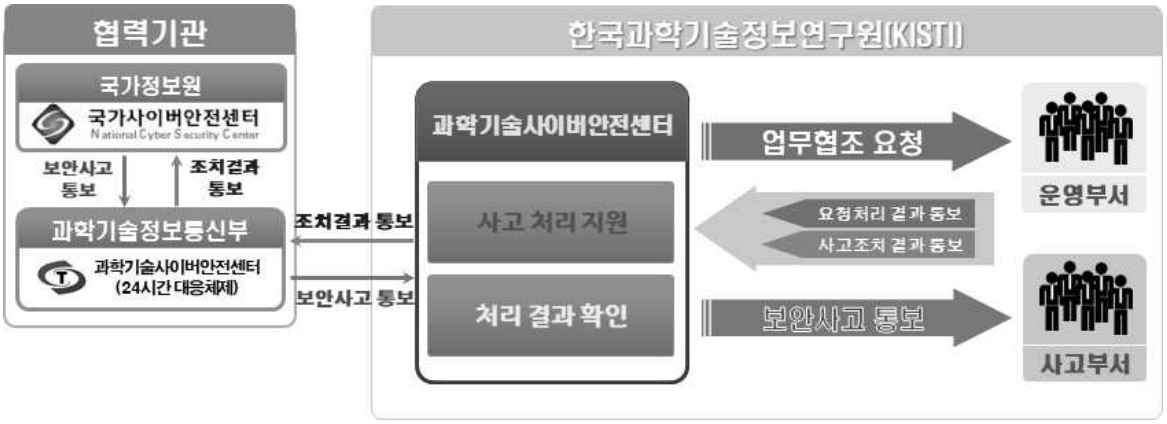
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

다. 사이버침해사고 예방 및 대응

(1) 사이버침해사고 대응체계

사이버 위협 및 APT와 같은 표적 공격이 최근 지능화되고 다양화되고 있는 양상을 보임에 따라 정보시스템 및 중요정보의 데이터를 안전하게 보호하기 위한 보안 활동 및 대응방안이 요구되고 있다. KISTI에서는 사이버보안센터를 통해 침해사고 신고 및 처리결과를 분석하여 가시화하고 있으며 현장 실사를 통하여 보안점검 및 취약점 분석을 진행하고 있다. 이를 통해 향후 예상할 수 있는 사고를 예방함과 동시에 재발방지를 위한 개선 및 대책을 도출하고 있다.

사이버 침해사고 대응체계는 국가정보원 국가사이버안전센터(NCSC) 및 24시간 보안관제를 수행하는 과학기술정보통신부 과학기술사이버안전센터(S&T CSC)와 함께 협력하여 진행하고 있으며, 한국과학기술원에서는 정보보안 전담부서인 과학기술사이버안전센터 내 원내보안팀에서 주관하여 사고처리 지원 및 처리결과 확인 등의 업무를 수행하고 있다.



<Figure 3-45> KISTI 침해사고 대응 체계

<Table 3-15> 대응 조직별 역할

구 분	역 할
국가사이버안전센터 및 과학기술사이버안전센터 - 관제센터	- 중앙집중형 24시간 상시 상황 관제 - 침해사고 발생 시 원내보안팀 통보 - 침해사고 처리결과 확인
과학기술사이버안전센터 - 원내보안팀	- 침해사고(유관기관 통보사항 및 내부탐지) 접수 - 침해사고자 사고내용 통보 및 사고처리 강제 - 침해사고 처리지원 및 사후 조치 확인 - 국가사이버안전센터 및 과학기술사이버안전센터 처리결과 통보
내부 전부서	- 침해사고 처리 - 침해사고 처리결과 원내보안팀 제출

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 사이버침해사고 대응절차

한국과학기술정보연구원 침해사고 대응체계는 사전예방과 사후조사 단계로 구분하여 실시하고 있다. 사전예방단계로는 주요시스템 취약점 점검을 비롯하여 홈페이지 취약점, 네트워크 취약점, 업무 PC 취약점으로 구분하여 실시간으로 수행하고 있으며, 취약점 발생 시 점검하는 활동으로 구성되는 사후 점검절차는 예방, 탐지, 분석, 대응, 복구 등의 체제로 구성되어 있으며, 세부적으로 단계별로 구분하여 적용된다.



<Figure 3-46> KISTI 침해사고 대응절차

<Table 3-16> 단계별 침해사고 대응절차

단계	대응절차
준비단계	- 시스템 점검 및 보안장비 설치 - 사고대응팀 구성 및 역할 등 절차 수립
탐지단계	- 이상 징후 탐지(국정원, 과기정통부, 과학기술사이버안전센터)
초기대응 단계	- 최초분석으로 침입/단순 장애 여부 판정 - 추가 사고 발생 위협요인 제거(차단) - 추후 정밀조사를 위한 증거자료 수집
조치단계	- 사고자에게 사실 통보(6하 원칙에 의거) - 복구 가능한 방법에 대한 자료 수집
복구단계	- 악성프로그램 제거 및 삭제 프로그램 복구 - 시스템 및 네트워크 정상화 단계
보고단계	- 사고내용 보고(문서화)
후속조치	- 사고대응 과정에 대한 피드백(미비점 개선)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) 웹서비스 취약점 진단을 통한 사전 예방활동

(가) 추진 배경 및 목적

과학기술정보통신부 정보보호담당관실에서는 홈페이지 보안관리 강화 계획을 각급 기관에 요청하였으며, 그 일환으로 웹서비스에 대한 정기적인 취약점 점검과 점검 후 후속대책을 수립하는 체계로 구성할 것을 요청하였다. 따라서 과학기술정보통신부 산하 출연연구기관 보안관제 업무를 수행하는 과학기술사이버안전센터에서는 내·외부 정보서비스를 대상으로 웹서비스에 대한 취약점 점검을 실시하였다.

외부에 공개된 홈페이지의 경우 보안 취약점 진단을 통해 웹어플리케이션의 보안 취약점을 파악하고 지속적인 보안체계 마련을 위한 방향성을 제시하여 안전한 웹 서비스를 운영할 수 있도록 함에 그 목적을 두고 있다.

(나) 대상 선정 및 절차

한국과학기술정보연구원은 과학기술분야 정보서비스 제공기관으로 대국민 및 연구자를 위해 제공 중인 홈페이지가 130여개에 달하고 있다. 또한 과학기술사이버안전센터에서는 과학기술정보통신부 산하 공공·연구기관의 보안관제서비스를 시행하고 있는 관계로 대상 기관에서 운영 중인 홈페이지를 대상으로 취약점 점검을 수행하고 있다.

취약점 점검의 형태는 담당자가 직접 수행하는 자가진단과 과학기술사이버안전센터에서 취약점을 진단하는 형태로 구분되고 있으며, 과학기술사이버안전센터에서 지원하는 인적자원과 기술적 자원(정보보안서비스)을 활용하여 대상 기관에게 취약점 진단 서비스를 제공하고 있다.

취약점 점검에 대한 구성은 '홈페이지 SW(웹)' 개발보안 가이드(행정안전부)'와 '주요정보통신기반시설 취약점 분석·평가 기준'항목을 기반으로 통합 진단/관리를 위한 항목으로 구성되어 있으며, 직접 인적자원을 투입하여 진행하는 경우 각 기관의 운영현황에 맞게 상황별로 대응하여 진행하고 있다.

취약점 진단의 세부적인 구성은 21개 취약점 항목별로 1) 개요 2) 판단기준 3) 대응방안 순으로 구성되어 있으며, 특히 대응방안의 경우 웹 애플리케이션, 웹 서버, 보안장비 등 3가지 부문으로 나누어 해당 취약점의 조치방법을 다양한 측면에서 제시하여 2-3중 보안 체계를 구성할 수 있도록 가이드하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<Table 3-17> 웹 취약점 점검항목

단계	취약점 항목	공격피해
웹 어플리케이션	운영체제 명령 실행	시스템 장악
	SQL 인젝션	DB정보 유출
	XPath 인젝션	사용자 인증 우회
	정보누출	서버 정보 노출
	악성콘텐츠	악성코드 감염
	약한 문자열 강도	사용자 계정 탈취
	불충분한 인증 및 인가	관리자 권한 탈취
	취약한 패스워드 복구	사용자 계정 탈취
	불충분한 세션 관리	사용자 권한 탈취
	크로스 사이트 리퀘스트 변조(CSRF)	사용자 권한 탈취
	자동화 공격	시스템 과부하
	파일 업로드	시스템 장악
	경로추적 및 파일 다운로드	웹 서버 정보 노출
	데이터 평문전송	중요 정보 노출
	쿠키 변조	사용자 권한 탈취
	URL/파라미터 변조	사용자 권한 탈취
웹 서버	디렉터리 인덱싱	시스템 파일 노출
	관리자 페이지 노출	웹 사이트 정보 노출
	위치 공개	웹 사이트 정보 노출
	웹 서비스 메소드 설정 공격	시스템 장악

홈페이지 해킹사고의 경우 보안취약점을 악용한 사이버침해사고의 발생으로 개인정보유출과 홈페이지 위변조로 인한 피해가 확산되는 관계로 과학기술사이버안전센터에서는 대국민 정보서비스의 안정된 제공을 위하여 취약점 진단을 실시하고 있다.

각급 기관에서는 취약점 진단을 위하여 웹사이트 취약점 진단 기술지원 신청서를 작성하여 과학기술사이버안전센터에 관련 정보를 송부하여 접수를 진행한다. 과학기술사이버안전센터에서는 해당 자료를 확인 후 대상기관의 요청에 따라 인적자원을 통한 직접 진단과 시스템 자원을 통한 원격진단으로 구성하여 진행한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

각 기관 정보보안 담당자는 해당 취약점 항목에 대한 진단결과를 직접 확인할 수 있고 이를 통해 직접 해당항목에 대한 조치방안을 수립할 수 있도록 진단체계를 구성하였다.

(다) 점검 결과분석

각급 기관에서 운영중인 홈페이지에 대한 취약점 분석결과는 상급 레벨의 취약점이 25개로 발견되어 즉시조치에 해당하는 항목으로 파악되었으며, 총 186개의 취약점을 도출하여 해당 기관 및 홈페이지 담당자에게 통보 조치를 수행하였다.

<Table 3-18> 웹 취약점 점검결과(유형별)

구분		상	중	하	합계
유형별	2020	19	127	40	186
	2019	27	107	35	169
	2018	25	102	99	226

<Table 3-19> 웹 취약점 점검결과(위험도별)

구분		시스템관리	프로그램 보안	사용자 인증	게시판관리	합계
위험도	2020	135	45	6	0	186
	2019	110	56	3	0	169
	2018	186	40	0	0	226

금번 수행된 취약점 점검에서는 WeDAV 취약점, 계정관리 취약점, 파일 업로드 취약점 등과 같은 위험도 상위등급의 취약점은 발견되지 않았으나, 불필요한 Method 허용 취약점, 파일 다운로드 취약점, SQL Injection 취약점과 같은 위험도 상위 등급의 취약점이 발견되었다.

웹취약점 점검을 유형별과 위험도별로 구분하여 분석한 결과 전년도에 비해 상위 등급의 취약점을 비롯하여 전체적으로 취약점 발견의 건 수가 226건에서 169건으로 현저히 줄어들었다. 또한 위험도별 구분에서 시스템관리와 프로그램 보안 관련 건 수가 동일하게 줄어든 것으로 볼 때 매년 진행하는 취약점 점검 및 이행을 통해서 대체적인 보안관리 수준이 양호한 수준으로 판단된다.

과학기술사이버안전센터에서는 취약점 진단 후 조치사항에 대한 이행 확인을 위하여 해당 서비스 담당자로 하여금 후속조치를 수행할 수 있도록 가이드하여 보안 취약점이 재발하지 않도록 지속적으로 개선활동을 수행하고 있다. 자세한 세부 유형별 취약점 발견현황은 아래와 같다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<Table 3-20> 웹 취약점 점검 세부결과

순번	구분	취약점 종류	등급	건수	
1	시스템관리	관리자페이지 노출 취약점	중	2	
2	시스템관리	디렉토리 나열 취약점	중	5	
3	시스템관리	시스템관리 취약점	하	34	
4	시스템관리	WeDAV 취약점	상	0	
5	시스템관리	불필요한 Method 허용 취약점	상	2	
6	시스템관리	취약한 파일 존재 취약점	중	59	
7	시스템관리	계정관리 취약점	상	0	
8	시스템관리	실명인증 취약점	하	0	
9	시스템관리	전송 시 개인정보 노출 취약점	중	25	
10	프로그램 보안	파일다운로드 취약점	상	5	
11	프로그램 보안	파일업로드 취약점	상	1	
12	시스템관리	소스코드 내 중요정보 노출 취약점	중	2	
13	게시판관리	공개용 웹 게시판 취약점	중	0	
14	프로그램 보안	크로스사이트스립트 취약점	중	28	
15	프로그램 보안	SQL Injection 취약점	상	11	
16	사용자 인증	권한인증 취약점	중	6	
17	시스템관리	에러처리 취약점	하	6	
합계				186	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

라. 사이버 모의훈련 기술지원

(가) 추진목적 및 배경

과학기술사이버안전센터에서는 과학기술분야 연구·공공기관의 소속원 및 보안담당자의 사이버 위기대응 능력 제고를 위해 사이버 모의훈련(도상훈련 등 3종) 기술지원을 수행하였다. 또한 각급기관 보안담당자와 과학기술사이버안전센터 간의 긴밀한 상호협력 체계를 마련하기 위하여 모의훈련을 실시하였다.

(나) 추진체계 및 절차

과학기술사이버안전센터는 각급기관으로 기술지원 관련 계획 및 일정을 수립하여 통보하고 협조 요청 공문을 시행하는 것으로 모의훈련이 시작된다. 각급기관에서는 모의훈련을 위한 자체 계획을 수립하고 과학기술사이버안전센터에서는 보안 컨트롤 타워 역할을 수행하여 각급기관에 훈련 상황을 발령 및 모니터링을 실시한다.

구분	주요 역할
과학기술사이버안전센터	◦ '20년 사이버 모의훈련 기술지원 계획 수립 및 통보 (과학기술사이버안전센터 / 2020. 8. 1)
⇩	
각급기관	◦ 사이버 모의훈련 자체 계획수립, 협조 요청 (~ '20. 8. 8)
⇩	
과학기술사이버안전센터	◦ 협조 공문 접수 및 *사이버 모의훈련 사전 점검* (~ '20. 8. 10) ◦ 18년 사이버 모의훈련 기술지원 수행 (~ '20. 9. 7) ◦ 각급기관별 사이버 모의훈련 결과 통보 (~ '20. 9. 17)
⇩	
각급기관	◦ 사이버 모의훈련 결과 활용 : 정보보안 감사 등

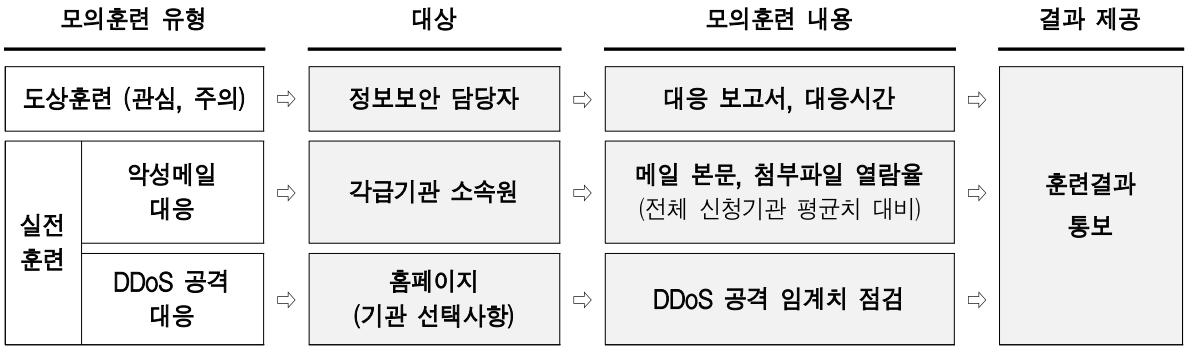
<Figure 3-48> 사이버 모의훈련 기술지원 절차

과학기술사이버안전센터에서는 사회공학적인 해킹공격에 대응하는 최신 공격 시나리오 반영을 통해 훈련의 실효성에 주안점을 두었으며, 각급 기관에서는 사이버 모의훈련을 추진하기 위하여 소속원 및 보안실무자의 대응력 강화를 위한 사이버위기대응 수준 강화에 초점을 두고 모의훈련을 추진하였다. 그 결과 사이버 위기대응 1차년도의 2017년보다 전반적으로 대응시간이 향상된 결과를 가져왔다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(다) 모의훈련 기술지원 범위

사이버 위기대응 역량 강화를 위한 모의훈련은 도상훈련과 악성메일 훈련, DDoS 대응 훈련으로 구분하여 실시하였고, 각급 기관에서는 담당자와 실무자 및 구성원을 대상으로 가상의 시나리오를 기반으로 훈련을 실시하였다.



<Figure 3-49> 사이버 모의훈련 기술지원 범위

(라) 모의훈련 결과분석

사이버모의훈련 기간 동안 훈련기관에서는 경보 발생에 따른 발령인지 및 대응조치와 관련하여 실전훈련과 같이 적극적인 대응과 협조로 원만하게 수행할 수 있었으며, 매년 고도화되는 악성메일에 대한 대응체계 강화로 해킹메일 대응 훈련을 추가 시행하였다. 모의훈련 실시결과 총 46개 기관에서 참여하여 도상훈련 1종과 실전훈련인 악성메일 대응훈련, DDoS 대응 훈련(2종)으로 구분하여 실시하였다.

과학기술정보통신부의 모의훈련 강화정책으로 인하여 참가인원은 총 10,652명이 참가하여 전년도 대비 훈련 참여인원이 260% 증가하는 성과를 가져왔으며, 훈련 홈페이지는 49개로 대상 홈페이는 20% 증가하였다.

<Table 3-21> 모의훈련 신청 및 접수현황

구 분		도상훈련	악성메일 대응훈련	DDoS 대응훈련	비 고
신청/접수	2020	38개 기관	48개 기관	40개 기관 (44개 사이트)	
	2019	43개 기관	49개 기관 (10,652명)	41개 기관 (49개 사이트)	
	2018	41개 기관	40개 기관 (2,937명)	34개 기관 (40개 사이트)	

① 도상훈련 결과

사이버 경보단계 위기상황 대응 수준은 상황별(관심·주의) 상황통보문이 1시간 이내 회신률이

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

90% 이상으로 전년대비 평균 대응시간을 단축하는 효과를 가져왔다. 또한 전체 기관 평균 응답률이 40분대에서 30분대로 진입하는 가시적인 성과를 가져왔으며, 최단시간 대응의 경우 10분대 초반으로 진입하여 향후 10분 이내에 진입할 수 있는 가능성을 보였다.

<Table 3-22> 사이버 모의훈련 결과(도상훈련)

경보 등급		기준시간	전체 기관 평균	최단/최장시간
관심	'17	60분	49분	최단시간 : 17분, 최장시간 : 170분
	'18	60분	44분	최단시간 : 18분, 최장시간 : 113분
	'19	60분	34분	최단시간 : 12분, 최장시간 : 60분
	'20	60분	39분	최단시간 : 8분, 최장시간 : 60분
주의	'17	60분	46분	최단시간 : 18분, 최장시간 : 103분
	'18	60분	40분	최단시간 : 18분, 최장시간 : 148분
	'19	60분	35분	최단시간 : 11분, 최장시간 : 60분
	'20	60분	44분	최단시간 : 10분, 최장시간 : 60분

② 악성메일 대응훈련 결과

악성메일을 열람 후 링크나 첨부파일 실행을 통해 34%의 훈련 대상자가 악성코드에 감염되었으며, 그 중에서 67% 훈련 대상자가 악성코드 감염을 신고한 것으로 집계된다. 악성코드 감염율의 경우 '17년도에서 '18년도의 경우 전년대비 10% 증가하였으나 다시 10%로 감소하였다. '19년 '20년의 경우 악성코드 감염율이 높아진 것은 훈련 시기에 건강보험 가입관련 정교한 피싱메일로 인하여 열람 건수가 증가하였다. 단순열람만으로도 악성코드를 감염한다고 가정할 경우에는 전년도 38%에서 60%로 감염 가능성이 수치가 증가하였던 것으로 나타났다.

<Table 3-23> 사이버 모의훈련 결과(악성메일 대응)

구 분		악성코드 미감염		악성코드 감염
		미열람	단순열람	악성링크/첨부파일 실행
전체기관 평균 대응율(%)	'17	49%	37%	14%
	'18	48%	28%	24%
	'19	62%	28%	10%
	'20	38%	26%	34%

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

③ DDoS 대응훈련 결과

DDoS 대응훈련의 경우 '19년 대비 향상된 공격차단율로 96% 차단을 보였으나 전년도에 비해 감소하여 공격차단율은 98%로 집계되었다. DDoS 공격 상황에서도 각급기관 홈페이지는 정상적으로 운영이 되었음을 확인하였다.

<Table 3-24> 사이버 모의훈련 결과(악성메일 대응)

구 분		공격 유형별 대응 결과			전체평균
		대역폭 초과	홈페이지 부하가중	통합공격	
공격차단율(%)	'17	98%	93.1%	100%	97%
	'18	100%	100%	100%	100%
	'19	96%	95%	98%	96%
	'20	98%	95%	98%	97%

(마) 시사점

사이버모의훈련 기간 동안은 담당자 및 상황인력의 대비태세를 준비하여 경보 발령인지와 대응조치에 대한 조치가 원활하게 수행되었다. 그러나 도상훈련의 경우 일부 대응조치 지연기관이 발생하였으며, 이는 지속적인 모의훈련을 통해 숙달된 환경에서 더욱 결과치가 향상할 것으로 기대된다. 실제로 금년도의 경우 일부 지표에서 17년도, 18년도 대비 향상된 지표가 일부 존재하였다.

또한 악성메일 훈련의 경우 메일 수신자가 해킹이라고 인지하지 못한 상황으로의 사회공학적인 공격을 수행하여 대응 미흡사례를 관찰할 수 있었다. 이는 지속적인 보안인식 향상이 필요할 것으로 판단된다. 모의훈련 중 해킹메일 대응의 경우 4년차에 접어들면서 메일보안에 대한 직원들의 인식이 일부 개선되었음을 확인할 수 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4. 주요정보통신기반시설 보안체계 강화

가. 주요정보통신기반시설 개요

(1) 주요정보통신기반시설 지정목적

주요정보통신기반시설은 '정보통신기반보호법' 제9조에 따라 주요정보통신 기반시설로 지정된 이후 6개월 이내, 그리고 매년 취약점 분석·평가를 실시하여야 한다. 한국과학기술정보연구원은 국가정보원으로부터 2017년 9월 국가슈퍼컴퓨팅시스템 및 국가과학기술연구망의 2개 시설에 대하여 주요정보통신기반시설로 지정되어 운영하고 있다. 주요정보통신기반시설은 정보통신기반보호법(법률 제15376호)에 의거하여 전자적 침해행위에 대해 주요정보통신기반시설의 보호에 관한 대책을 수립·시행함으로써 동 시설물을 안정적으로 운용하고자 법률로 지정하여 관리되고 있다.

(2) 주요정보통신기반시설 추진전략

한국과학기술정보연구원 주요정보통신기반시설은 침해사고 예방과 침해사고 대응 및 복구 부문으로 구분하여 추진전략을 수립하였다. 침해사고 예방은 정보보호 관리체계를 강화하기 위한 관리적 보안 부문에서의 주요 추진 과제를 도출하여 아래와 같은 추진전략을 수립하였다.

○ 정보보호 관리체계를 강화하기 위해 지침, 운영관리 절차를 주기적으로 검토하고 개정
○ 정보보호 중장기 추진계획을 수립하여 체계적인 정보보호 활동 수행
○ 자체 정보보호 수준평가 결과 미흡한 항목에 대한 개선과제 수립, 구현 및 운영
○ 취약점 분석·평가 및 모의해킹, 모의훈련결과에서 도출된 취약점에 대한 보완조치로 잠재적 위협 최소화 및 예방 체계 강화

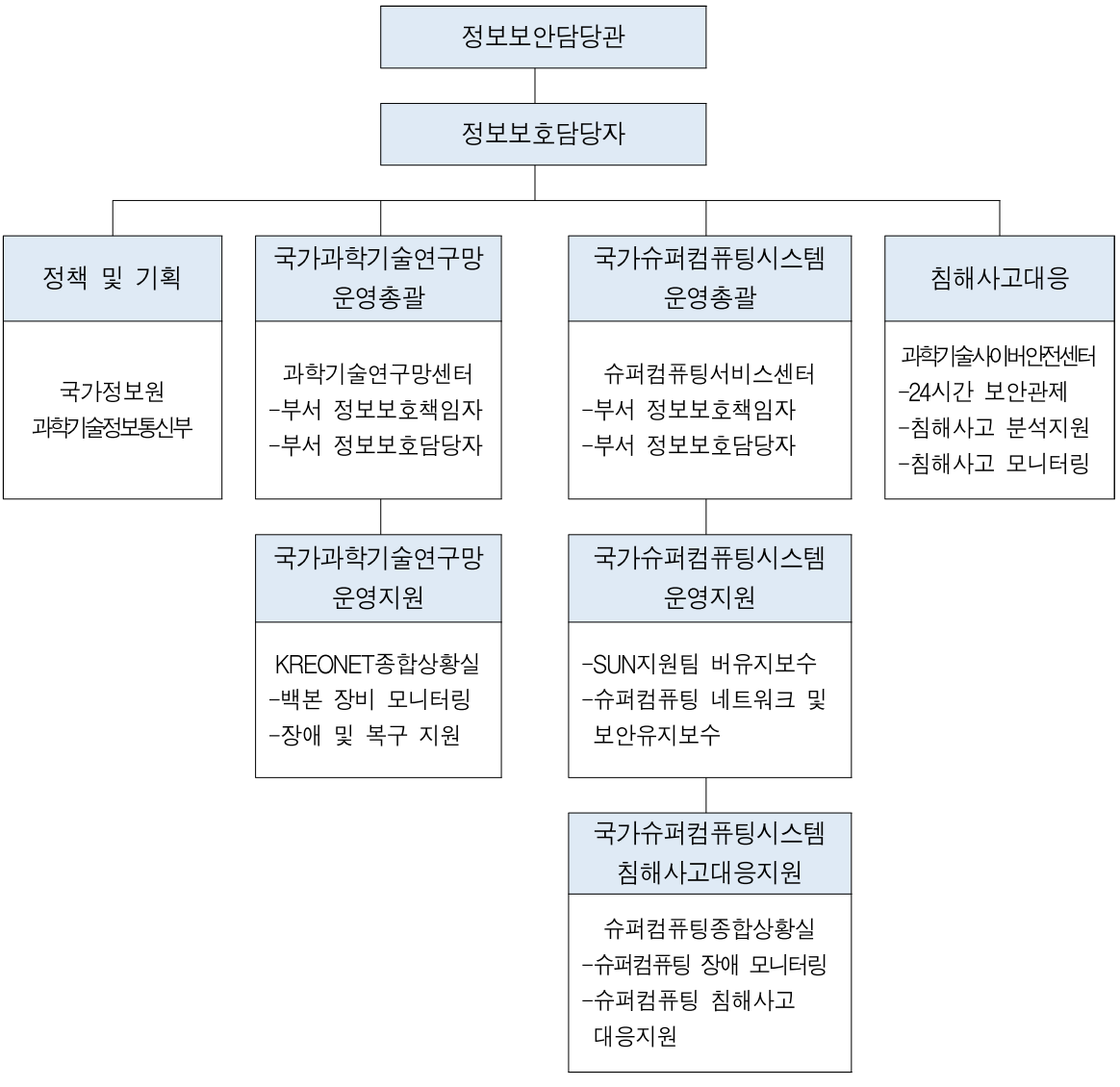
주요정보통신기반시설 침해사고 대응·복구부문에서는 침해대응체계와 연계한 모의해킹 및 모의훈련과 관련하여 복구체계를 수립 및 강화하여 안정적 대응능력을 함양할 수 있는 것을 주요 추진 전략으로 수립하였다.

○ 침해대응 체계와 연계한 모의해킹, 모의훈련을 통해 복구체계를 강화하고 안정적인 서비스를 제공
○ 업무연속성 계획 보완 및 모의훈련 실시로 서버 등 인프라의 가용성 및 안전성 확보
○ 사이버 침해사고 대응훈련을 통한 운영자의 사고대응 능력 강화

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) 주요정보통신기반시설 추진체계

한국과학기술정보연구원 주요정보통신기반시설은 정보보안담당관인 과학기술사이버안전센터장을 총괄 책임자로 정보보호 정책 및 예산 승인 책임을 가지고 있으며, 정책 및 기획분야에서 과학기술사이버안전센터를 두고 있다. 각 기반시설 운영 책임관인 과학기술연구망센터 및 슈퍼컴퓨팅서비스센터에서는 정보보호시스템 운영에 따른 정보보안 실무업무를 수행하고 있다. 마지막으로 과학기술사이버안전센터에서는 침해사고 대응업무를 수행하여 침해사고 대응계획 및 예방활동을 추진하는 체계로 구성되고 있다.

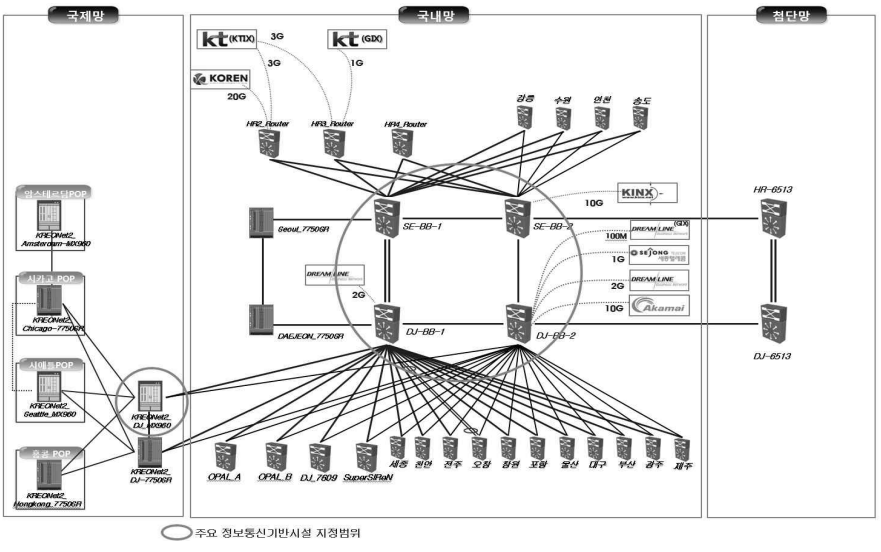


<Figure 3-50> KISTI 주요정보통신기반시설 추진체계(외부협력 포함)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

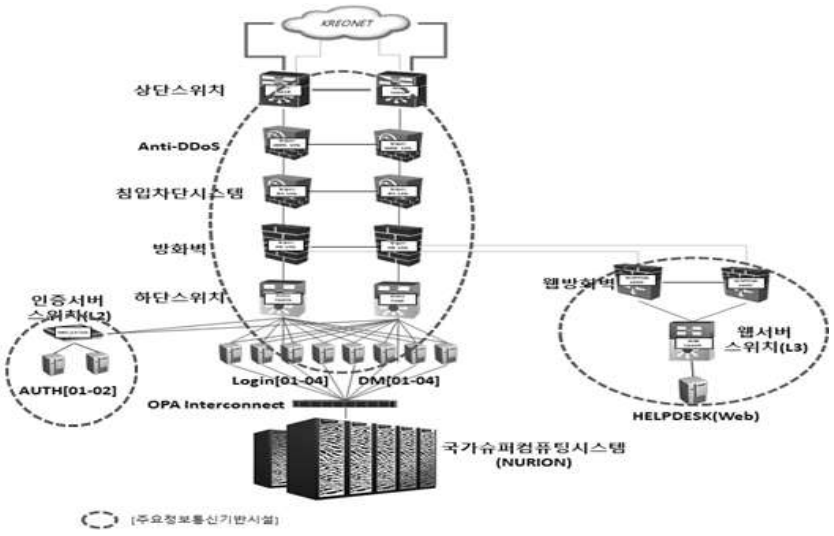
(4) 주요정보통신기반시설 구성 및 관리체계

한국과학기술정보연구원은 KEONET을 통한 200여개의 각급기관으로의 네트워크 중심 기관으로 백본라우터에 대해 주요정보통신기반시설로 지정되었다. 국가과학기술연구망센터는 국내 및 국제 백본라우터에 대한 보안관리체계를 수립하고 매년 주요정보통신기반시설 취약점 점검을 통해 대상시스템에 대한 취약점 보완조치를 추진하고 있다.



<Figure 3-51> 국가과학기술연구망 주요정보통신기반시설 지정현황

국가슈퍼컴퓨팅센터에서는 슈퍼컴퓨터 5호기(NURION)을 비롯하여 관련 보안장비와 네트워킹 장비를 포함하여 주요정보통신기반시설로 지정하여 운영하고 있다. 국가슈퍼컴퓨팅을 관리운영하는 슈퍼컴퓨팅서비스센터에서는 침입차단시스템을 비롯하여 OTP 인증서버, 계정관리 서버, DDoS 장비 등의 보안장비를 운영 중에 있다.



<Figure 3-52> 국가슈퍼컴퓨팅센터 주요정보통신기반시설 지정현황

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

과학기술사이버안전센터에서는 국가정보원으로부터 매년 실시되는 주요정보통신기반시설 이행점검에 대비하여 정보보호전문기업 선정 및 취약점 점검을 수행하였다. 수행기관에서는 정보보호 수준평가를 통해 기반시설별 주요 취약점과 수준향상을 위한 조치 이행으로 관리적(26건), 물리적(9건), 기술적(147건)으로 총 182개의 취약점을 분석하여 점검을 실시하였다. 점검 시 도출된 취약점은 즉시조치, 단기, 중장기, 위험수용으로 구분하여 각각의 위험도에 따라 분류되어 평가 수행 및 조치계획을 수립하여 제출하였다.



<Figure 3-53> 주요정보통신기반시설 취약점 점검 추진 일정

주요정보통신기반시설 취약점 점검은 기반시설의 네트워크, 연계서버(UNIX, Windows), 연계네트워크, 연계 PC를 중심으로 수행하였고, 기반시설 내 네트워크와 백본, 연계시스템으로 구분하여 관리적, 물리적, 기술적 취약점이 도출되었다.

관리적 취약점의 경우 관리적부문의 전체 총점이 부여되고 각 해당 항목별로 정보보호수준에 대한 정보가 부여된다. 인적보안, 자산분류, 매체관리, 교육 및 훈련, 접근통제, 업무 연속성 부문으로 구분되어 실시되며, 보통 또는 미흡 수준으로 개선을 요구하는 레벨을 구분하며 총 114개의 취약점 점검 및 조치 확인하고 있다.

물리적 취약점은 접근통제, 감시 통제, 전력보호, 환경 통제로 구분하여 각 지표별 점수를 부여하여 최종적으로 합산하게 되어있다. 물리적 보안으로 통제구역 및 출입기록 그리고 출입권한에 대한 사항 등 총 26개의 취약점 점검 및 조치 확인하고 있다.

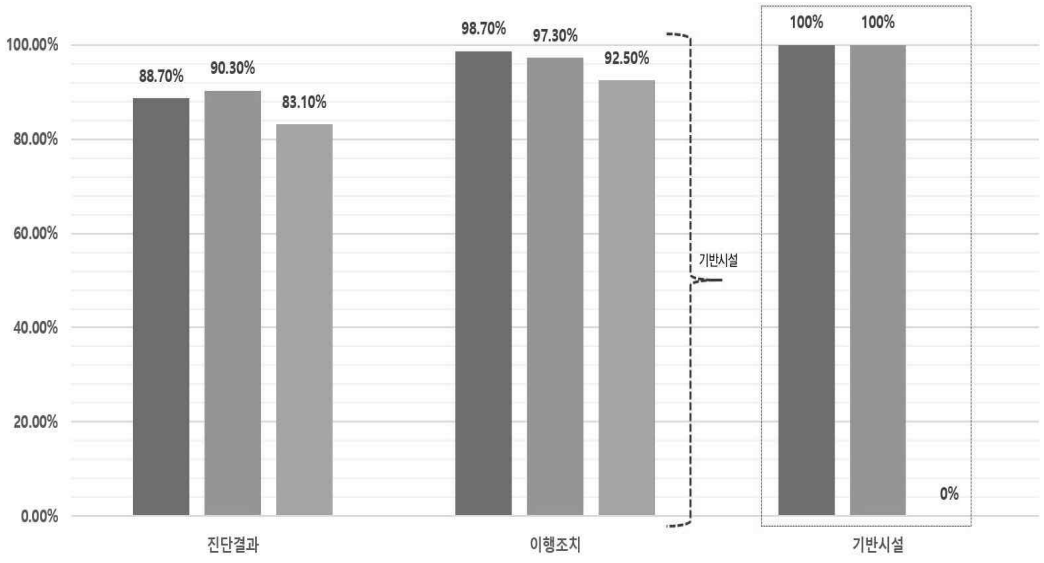
기술적 취약점은 계정 및 서비스 관리 등의 확인하는 절차로 구성되며, 주요 파일의 권한에 SUID와 SGID에 대한 설정이 부여된 파일이 발견 취약점, 접속 IP 및 포트를 제한하고 있지 않은 취약점 등의 총 313개의 취약점 점검 및 조치 확인하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) 주요정보통신기반시설 취약점 분석 결과

최종적으로 KISTI 주요정보통신기반시설에 대한 취약점 진단 결과 평가수준은 90.5%의 우수한 수준으로 평가되었다. 관리적 부문의 평가점수는 1.7% 향상되었고, 물리적 부문의 평가점수는 8% 향상되었으며, 기술적 부문의 평가점수는 4.3%로 감소되었다. 기술적 부문의 평가점수 하락은 신규장비 도입으로 진단대상이 증가하면서 장비 설정 및 보안정책 적용 하는 과정에서 점검하였기 때문이며, 현재는 진단취약점에 대해서 조치를 완료하였으며, 물리적인 부문의 점수 향상은 전산실 이전으로 전체적인 인프라 체계 구축 및 취약점 보완 완료함으로써 향상되었다.

주요정보통신기반시설 실전대응능력 강화를 위한 사이버공격 대응 모의훈련 및 재난대비 모의훈련을 실시하였고, 침해사고 건 수 0건으로 피해 방어율을 100%로 유지하였다. 또한 취약점 분석·평가로 모의해킹, 모의훈련 시 도출된 취약점에 대한 보완조치로 잠재적 위협을 최소화하였으며, 침해사고에 대한 운영관리 절차 보완 등의 점검 및 모니터링 강화로 체계적인 감시 및 대응체계를 확립하였다. 마지막으로 재난대비 신속한 업무 복구 및 비상대응 체계 확립을 위한 업무연속성(BCP) 계획 보완 및 네트워크 이중화 체제 마련, BCP 모의훈련 실시로 대응체계 강화 및 업무 공백을 최소화 할 수 있는 체계를 조성하였다는데 의의를 둔다.



<Figure 3-54> 주요정보통신기반시설 정보보호 수준평가 결과

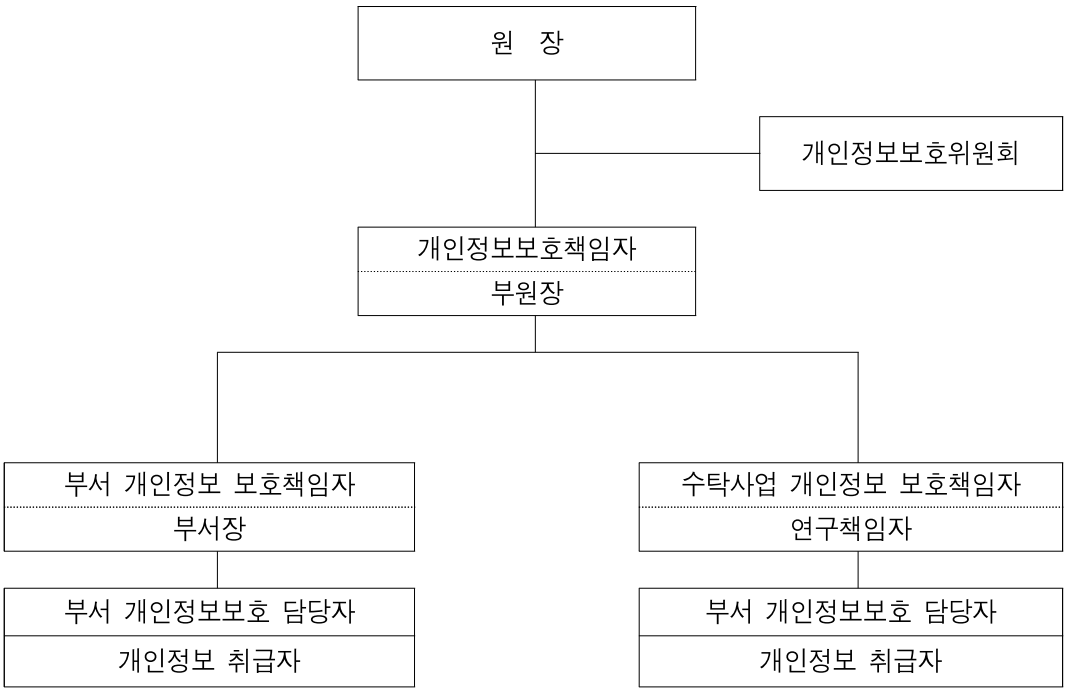
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

5. 기관 개인정보보호 관리체계 정립

가. KISTI 개인정보보호 추진체계 수립

(1) 개인정보보호 추진체계

KISTI는 최근 개인정보보호법 개정과 함께 정부기관 개인정보 보호지침 제정에 따른 범정부 차원에서 추진 중인 개인정보보호 관리체계 강화와 관련하여 연구원의 개인정보 유·노출 방지 및 대응 전략 수립을 위하여 아래와 같이 관리체계를 정비하였다. 이는 보고체계를 부서장에서 경영진으로 상향함으로 개인정보 책임을 강화하였으며, 개인정보 보호업무를 전 기관차원에서 공유하고 임직원의 개인정보 인식 제고에 긍정적인 효과를 가져 올 수 있다.



<Figure 3-55> KISTI 개인정보보호 추진체계

(2) 개인정보보호위원회 구성

개인정보위원회는 경영진 및 보직자를 대상으로 구성하였으며, 연구원의 개인정보와 관련된 주요사업과의 영향을 기준으로 관련 안건을 진행하고 있다. 현재 개인정보보호 연간 계획 및 부서별 개인정보 추진 활동에 대한 내용을 중심으로 구성되었으며, 관련 이행사항 여부를 포함하여 매년 위원회를 개설하여 활동하고 있다.

개인정보위원회를 통하여 임직원의 개인정보보호에 대한 정책 수립 및 정부 방침에 따른 각종

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

점검에 대해 현안을 분석하고, 향후 개인정보 정책에 대한 방향성을 논의하는 소통의 장(場)으로 활용되고 있다.

(3) 개인정보보호 지침 개정

○ 개정 개인정보 보호법(법률 제16930호, 2020. 8. 5.) 및 시행령(대통령령 제30892호, 8.4.) 및 개인정보의 안전성 확보조치 기준(행정안전부 고시 제2019-47호)을 반영하고, 표준 개인정보 보호지침 준수하여 기관 개인정보 관련 규정 및 지침을 개정

☞ 개인정보 보호지침 제정 이래 7차 개정('20.02.18) - 8개 조항 개정

※ 관련근거

- 개인정보보호법 제12조(개인정보 보호지침) 및 제29조(안전조치의무)
- 개인정보의 안전성 확보조치 기준(개인정보보호위원회 고시 제2020-02호)

< 참고사항 >

1. 개인정보 보호법 제29조(안전조치 의무)

개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

2. 개인정보 보호법 시행령 제30조(개인정보의 안전성 확보 조치)

① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 하여야 한다.

○ 주요내용

<Table 3-25> 개인정보보호 지침 주요내용

제3조 (용어의 정의)	• (개정) '접속기록'의 용어 정의 - 개인정보취급자 등이 개인정보처리시스템에 접속하여 수행한 업무 내역에 대하여 개인정보취급자 등의 계정, 접속지 정보, 처리한 정보주체 정보, 수행 업무 등을 전자적으로 기록한 것을 말한다. 이 경우 '접속'이란 개인정보처리시스템과 연결되어 데이터 통신 또는 수신이 가능한 상태를 말한다.
제53조 (접속기록의 위·변조 방지)	• (개정) 안전조치의무내 접속기록 보관 관리 강화 ① 개인정보 취급자가 개인정보처리시스템에 접속한 기록은 최소 1년 6개월 이상 보관하여야 한다. 다만, 5만명 이상의 정보주체에 관하여 개인정보를 처리하거나, 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템의 경우에는 2년 이상 보관·관리하여야 한다. ② 개인정보취급자의 접속 기록은 개인정보의 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보 처리시스템의 접속기록을 월 반기별로 1회 이상 점검하여야 한다. 특히, 1,000건 이상 개인정보를 다운로드한 것이 발견되었을 경우에는 그 사유를 반드시 확인하여야 한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 부서별 맞춤형 개인정보보호 컨설팅

(1) 업무별·분야별 개인정보보호 담당자 지정

개인정보보호 담당자 지정제도는 부서별 개인정보 보호책임자 및 개인정보 보호담당자를 통한 원내 개인정보보호 업무를 효율적으로 운영하기 위한 제도로써 부서별 개인정보 업무를 총괄하여 감독하는 부서별 개인정보 보호책임자와 부서 개인정보보호 업무를 담당하는 부서 개인정보 보호담당자로 구분할 수 있다. 또한 온오프라인에서 개인정보를 업무상 담당하고 있는 대상을 개인정보취급자로 지정하여 운영하고 있다.

(2) 부서 맞춤형 개인정보보호 컨설팅

KISTI는 연구원 특성 상 정보시스템 운영 및 홈페이지 관리를 다수 운영하고 있으며, 각 부서별 상황에 맞는 개인정보보호 관리체계 수립이 요구되었다. 이를 위해 부서별 개인정보 관련 수요조사를 매년 실시하여 대상을 선정하고 부서 담당자와 1:1 커뮤니케이션 형태로 맞춤형 개인정보 컨설팅을 진행하였다. 이는 임직원의 개인정보 의식 함양을 위해 개인정보 보호교육과 더불어 부서 맞춤형으로 진행되어 만족도가 높았으며, 담당 업무별 개인정보 관련 정보제공을 통하여 실제 업무에 애로사항을 해결함과 동시에 개인정보보호법에 따른 기관 전체의 개인정보 수준을 높일 수 있는 계기로 삼을 수 있다.

추진목적

개인정보보호 법령을 준수하고 각 사업별 특성에 맞게 맞춤형 컨설팅 서비스 제공
↳ KISTI 임직원의 개인정보보호 인식 강화 및 개인정보보호 수준 신뢰도 제고

개인정보 컨설팅 절차

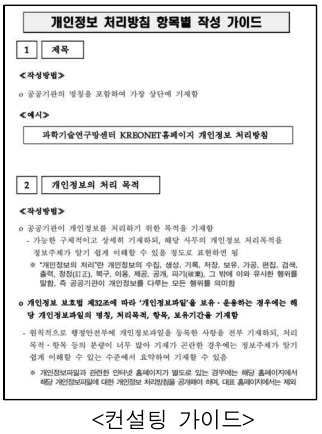
컨설팅 신청	⇒	검토 및 안내	⇒	정책적용 및 이행	⇒	교육, 이행관리
단위부서		기관 담당자		부서 담당자		기관 담당자

대상업무

오프라인 동의서 활용 개인정보처리	- 개인정보 수집시 동의절차, 목적 달성시 파기절차 - 개인정보파일 등록안내 및 관리절차 - 개인정보보호위원회 개인정보종합지원시스템 이용안내 - 타 기관으로부터 수집 또는 요청되는 개인정보 관리 및 처리절차
온라인 홈페이지 활용 개인정보처리	- 개인정보처리방침 작성 가이드 제공 - 개인정보보호법 준수를 위한 안전성확보조치 안내 (접근권한, 접속기록, 암호화 등 절차 안내)

추진실적

◦ 6개 부서 컨설팅 완료
(NTIS센터, 과학기술연구망센터, 학술정보공유센터, 융합서비스센터, 대외협력실, 재무관리실)


개인정보 처리방침 항목별 작성 가이드

1 제목

<작성방법>
○ 공공기관의 명칭을 포함하여 가장 상단에 기재함

<예시>
과학기술연구망센터 KREONET홈페이지 개인정보 처리방침

2 개인정보의 처리 목적

<작성방법>
○ 공공기관이 개인정보를 처리하기 위한 목적을 기재함
- 가능한 구체적이고 상세히 기재하되, 해당 사무의 개인정보 처리목적을 정보주체가 알기 쉽게 이해할 수 있을 정도로 표현하면 됨
※ "개인정보의 처리"란 개인정보의 수집, 생성, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정(訂正), 복구, 이용, 제공, 공개, 파기(破棄), 그 밖에 이와 유사한 행위를 말함. 즉 공공기관이 개인정보를 다루는 모든 행위를 의미함

○ 개인정보 보호법 제32조에 따라 '개인정보파일'을 보유·운용하는 경우에는 해당 개인정보파일의 명칭, 처리목적, 항목, 보유기간을 기재함
- 원칙적으로 행정안전부에 개인정보파일을 등록한 사항을 전부 기재하되, 처리목적·항목 등의 분량이 너무 많아 기재가 곤란한 경우에는 정보주체가 알기 쉽게 이해할 수 있는 수준에서 요약하여 기재할 수 있음
※ 개인정보파일과 관련한 인터넷 홈페이지가 별도로 있는 경우에는 해당 홈페이지에서 해당 개인정보파일에 대한 개인정보 처리방침을 공개해야 하며, 대표 홈페이지에서는 제외

<컨설팅 가이드>

주요 추진사례

① 개인정보 처리업무 개선(행정) : (기존) 개인정보 단순 수집 ⇒ (변경) 법령에 근거한 양식 준수로 全계약업무 적용
② 관리수준 예방 점검활동(연구) : (기존) 수집업무 점검 ⇒ (변경) 개인정보 관련업무 대상 적법성 검증, 현행화 실시

<Figure 3-56> 부서별 개인정보컨설팅 추진 체계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Figure 3-57> 맞춤형 개인정보보호 컨설팅 화면(기관 홈페이지)

(3) 개인정보 유출요인 차단을 위한 선제적 예방활동 수행

개인정보보호는 업무 특성 상 기술적 요인보다 인적 요인을 더 중요한 요소로 삼고 있다. 이를 위해 KISTI에서는 개인정보의 관리적 조치와 기술적 조치로 구분하여 오프라인 업무에 대한 자가진단 체크리스트를 배포하여 개인정보취급자로 하여금 개인정보 보호환경에 대한 자체 점검을 1차로 수행할 수 있는 환경을 구성하였으며, 기술적 조치로 온라인서비스로 업무PC와 정보시스템을 대상으로 개인정보 노출에 대한 수시점검 및 정기점검 체계를 제공하고 있다.

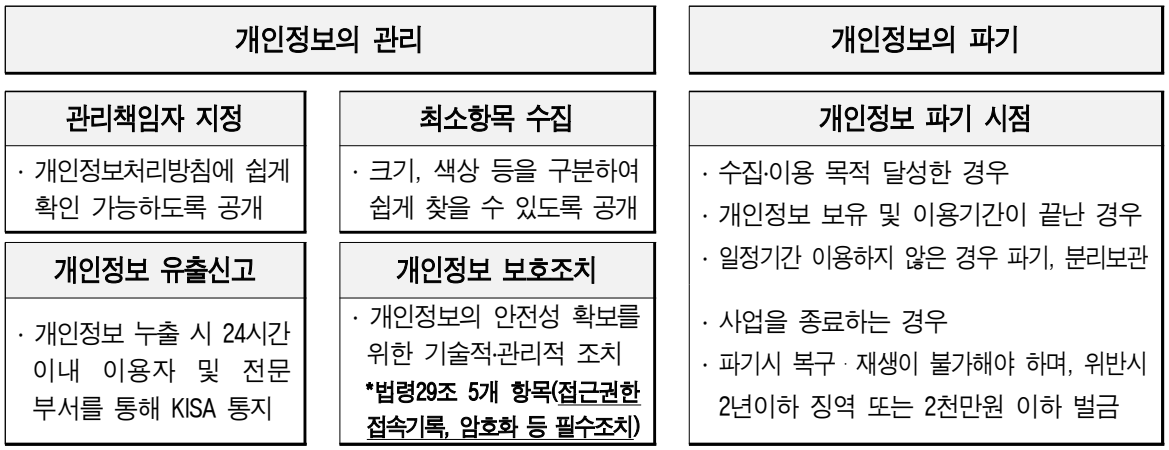
<Table 3-26> 개인정보 선제적 예방활동 체계

구 분	대 상		주요 개인정보 점검 항목
관리적 조치	오프라인 업무		- 개인정보 처리 업무별 취약점 점검(수집양식, 문서 등) - 서면점검(1차) → 방문점검(2차)을 통한 미흡사항 조치결과 확인
기술적 조치	온라인	업무PC	- (수시점검) 업무PC 대상 실시간 개인정보 노출 점검 모니터링
		홈페이지	- (수시점검) 서버 대상 실시간 개인정보 접속기록 로그 모니터링 - (정기점검) URL기반 고유식별정보 노출 점검 모니터링

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

① 개인정보의 관리적 조치 : 개인정보 자가진단 실시

개인정보 자가진단은 개인 직접 측정할 수 있는 지표별 진단항목과 관련 부연 설명으로 이루어져 누구든지 쉽게 개인정보 수준을 측정할 수 있도록 설계되었으며 매년 연간 계획과 함께 전 부서에 배포되어 활용되고 있다. 또한 자가점검을 마친 후 개인정보보호 전문부서에서는 별도 실사 및 점검을 시행하여 개인정보보호위원회에 보고하는 체계로 진행되고 있다.



<Figure 3-58> 개인정보 법령 준수를 위한 주요 점검사항

<Table 3-26> 개인정보보호 자가진단 체크리스트(일부 발췌)

측정지표	1. 개인정보보호 정책 및 자원			
진단항목	질문사항	예	아니요	해당없음
	1.1. 개인정보보호 업무를 수행하기 위한 조직이 구성되어 있는가?			
	1.2. 개인정보보호를 위한 기반이(예산편성 등) 마련되어 있는가?			
	1.3. 개인정보 보호책임자가 지정되어 있는가?			
	1.4. 개인정보 보호책임자는 교육, 관리·감독 등 역할을 수행하고 있는가?			
	1.5. 개인영상정보 보호책임자 지정 및 역할을 수행하고 있는가?			
	1.6. 개인정보의 안전한 처리를 위한 내부 관리계획이 어 있는가?			
	1.7. 개인정보처리자가 내부감사(관리·감독 등)를 수행 하는가?			
세부설명	1.1. 개인정보보호 전담조직 구성 【설명】 개인정보보호 활동을 수행하고 관리하는 인력들에 대한 책임, 권한 및 역할을 정의하여야 한다. 부서별 개인정보보호 업무를 총괄하여 수행할 수 있는 조직을 지정·운영하여 개인정보보호에 관한 예산 및 인력을 운영할 수 있도록 개인정보보호 업무담당자에게 책임과 권한을 부여한다. 【예시】 개인정보보호 전담팀(총괄)을 구성하여 정책을 일관성 있게 추진 및 수행하며, 업무별로(홈페이지분야, DB분야, 민원분야 등) 담당자를 지정·운영한다.			

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

② 개인정보의 기술적 조치 : 온라인 개인정보 실시간 노출점검

정부에서는 개인정보 법령 개정은 안전성 확보조치 측면에서 매년 강화되고 있다. 이를 위해 KISTI에서는 강화되는 법령 개정에 대응하여 선제적으로 개인정보 노출 위험을 제거하고자 전문솔루션 도입을 통해 안전성 확보조치 기준에 부합하는 수준으로 개인정보를 관리하고 있다.

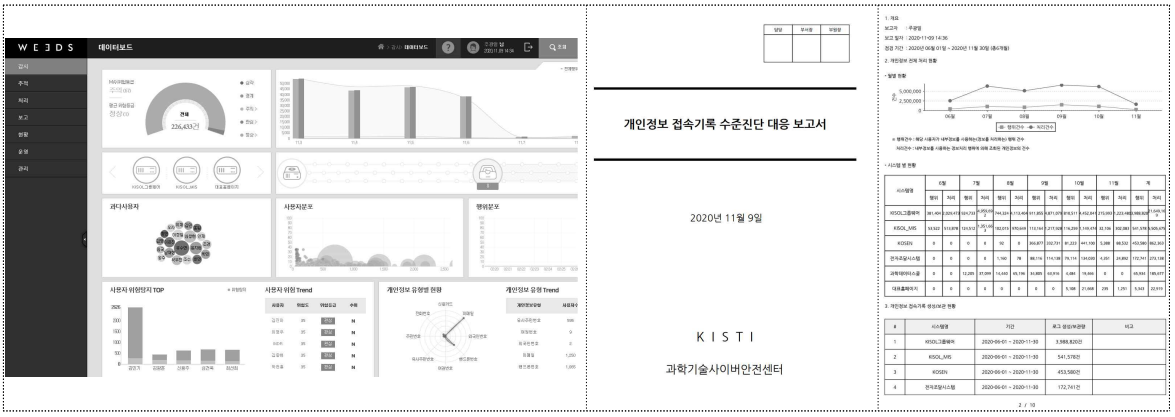
개인정보의 기술적 조치는 외부홈페이지를 비롯한 정보시스템과 내부 사용자를 위한 개인정보 자원(업무PC)로 구분하여 운영하고 있으며, 법령에 따른 주요 이슈사항은 다음과 같다.

정보시스템의 경우 개인정보 유출사고로 인하여 접속기록, 접근권한 부문에서의 정책이 강화되고 있다. 이를 대비하기 위하여 과학기술사이버안전센터에서는 선제적으로 2019년에 전문솔루션을 도입 운영하여 시범사업을 추진하였으며, 2020년에는 수요부서를 조사하여 3개 부서를 대상으로 정보시스템에 전문솔루션을 적용 완료하였다. 이를 통해 정부에서 요구하는 접속기록 항목의 수준에 맞는 정책사항을 준수하도록 추진하였다.

1) 접속기록의 기록항목 구체화 : 누가(접속자 ID, IP), 언제(날짜 및 시간), **누구의(누구의 정보접근)**, 어떻게(열람/저장*/수정/삭제/출력) ***저장 시 사유**를 반드시 기록해야함
2) 접속기록 보관기간 최소 1년 이상으로 변경 예정(기존 6개월 이상)
   - (기본) 모든 개인정보처리시스템은 **1년 이상** 보관, 5만명 이상 개인정보처리(고유/민감 포함)시스템은 **2년 이상**
   - (보관기간 연장) 모든 개인정보처리시스템에 때해 2022년부터 **3년 이상**, 2025년부터 **5년 이상**으로 연장
3) 접속기록 점검 주기
   - 내부 관리계획 이행실태 점검에 접속기록 관한 사항 포함
   - 접속기록 점검 주기 단축 : 반기별 1회 이상 → **월 1회** 이상 (강화)
   - 개인정보를 **다운로드 한 경우 그 사유를 반드시 확인** (신설)

<Figure 3-54> 개인정보 접속기록 관련 개정사항(행안부 고시 제2019-47호)

개인정보 모니터링체계는 접속기록에 대한 모니터링과 개인정보 유출에 관한 모니터링으로 구분할 수 있으며, 접속기록에 대한 모니터링의 경우 분석현황 대시보드를 통해 모니터링 에이전트가 설치된 정보시스템을 중심으로 수행하고 있다.



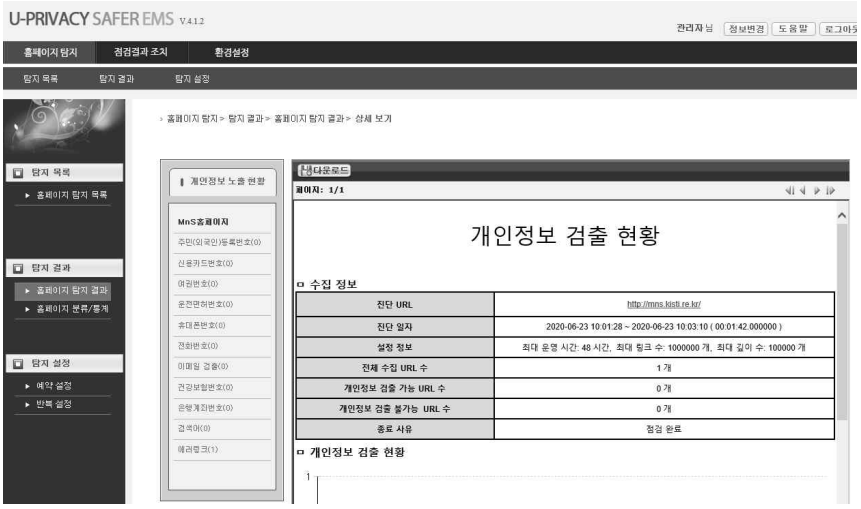
<Figure 3-54> 개인정보 접속기록 분석현황 및 결과보고

개인정보 분석 결과보고는 연구원내 통합관리 및 각각 개별정보시스템별로 구분하여 수행할

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

수 있으며, 각각의 관리수준에 따라 맞춤형으로 대응할 수 있는 장점을 가지고 있다. 현재 전체 정보시스템을 대상으로 접속기록 솔루션이 설치되지 않았으나, 주요 정보시스템을 중심으로 접속기록 솔루션을 적용하고 있으며, 개인정보 위험도가 높은 수준의 정보시스템을 선별적으로 구분하여 개인정보보호 정책을 부합할 수 있도록 부서별 컨설팅을 수행하고 있다.

개인정보 노출 모니터링의 경우 연구원내 운영 중인 모든 홈페이지를 대상으로 노출점검을 실시하고 있으며, 보안상 취약요인을 점검하는 웹사이트 보안수준 자가진단과 더불어 개인정보 노출에 대한 점검을 정기적으로 수행하고 있다.



<Figure 3-54> 개인정보 노출 모니터링 수행 보고서

개인정보 기술적 조치의 직원을 대상으로 하는 개인정보자원(업무PC)에 대해서는 개인정보 검출에 대한 점검 솔루션을 적용하여 실시간 검출 및 적용을 수행하고 있다. 연구원의 개인정보자원에 대해서는 개인정보 노출점검 에이전트를 설치하도록 정책을 적용하고 있으며, 개인정보 검출 건에 대한 PC취약점 점수 반영으로 직원 개인이 관련 사항을 직접 확인하고 조치할 수 있도록 반영하였다. 이를 통해 개인정보에 대한 임직원의 인식을 고취시키는 것과 동시에 개인정보 전문부서를 통하여 관련 내용을 지원받을 수 있도록 안내함으로 연구원의 개인정보 관리수준을 강화할 수 있는 조치로 추진하였다.



<Figure 3-54> 개인정보자원 대상 개인정보 노출점검시스템 적용 사례

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

제4장 목표달성도 및 관련분야에의 기여도

제 1절 연구개발 목표달성도

과학기술사이버안전센터의 주요 기능으로 과학기술분야 보안관제 통합운영을 비롯하여 보안관제 자동화기술연구 및 전주기적 정보보호 서비스를 수행하고 있다. 핵심고객으로는 과학기술연구망을 활용하고 있는 200여 대상기관과 한국과학기술정보연구원 내부의 대외서비스 주체, 전임직원을 들 수 있다.

본 연구사업은 '자동분석·처리를 통한 사이버위협 침해대응 신속성 향상'을 최종 목표로 하고 있다. 세부 추진목표로 인공지능 기술을 활용한 자동화 기반 보안관제 기술연구와 적용 및 기술확산을 제시하고 있다.

본 사업은 아래 표와 같이 3개년(2018~2020) 연구목표를 수립하여, 최종 목표인 자동분석·처리를 통한 사이버위협 침해대응 신속성 향상을 달성하고자 한다. 연구사업의 단계별 목표는 아래와 같다.

<Table 4-1> 연구사업 단계별 목표

'18년 목표	'19년 목표	'20년 목표
세부과제명 : 자동화 기반 과학기술 정보보호 서비스		
· 과학기술계 보안관제 체계 재정비	· 과학기술계 보안관제 통합운영 서비스	· 과학기술계 보안관제 통합운영 안정화
· 보안관제 전용 인공지능 알고리즘 테스트베드 구축	· 보안관제 전용 인공지능 알고리즘 개발·시범적용	· 보안관제 전용 인공지능 알고리즘 적용·고도화
· 이상행위 탐지기술 연구	· 이상행위 탐지기술 개발·시범적용	· 이상행위 탐지기술 적용·고도화
· 원내 정보보안 관리체계 개선 (연구자 중심)	· 원내 정보보안 관리체계 안정화	· 원내 정보보안 관리체계 고도화
보안관제 자동화 기술연구 기반 조성	**보안관제 자동화 기술연구 개발·적용**	**보안관제 자동화 기술연구 고도화·확산**

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1. 세부 성과지표 수립

초연결·지능정보사회로 요약되는 제4차 산업혁명시대에서 사이버공격은 경제적·사회적 혼란을 야기할 뿐만 아니라 국민의 안전과 생명까지 위협할 수 있는 중요한 문제로 대두되고 있다.

따라서, 사이버안전 분야에서 보안관제·침해대응에 소요되는 시간을 점진적으로 단축하는 '하향지표'방식의 성과목표 수립을 지양하고, 세계 최초로 사이버안전 골든타임을 제시하여 '최종지표'방식의 성과목표 수행체계 정립하고자 하였다.

특히, '얼마나 신속하게 사이버공격을 탐지하여 대응했는가(예시 : 119구급차 평균 출동시간)'보다는 '얼마나 많은 시스템을 사이버공격에 의한 피해발생에서 구해냈는가(예시 : 119구급차 출동에 의한 생존률)'에 집중하였다.

이에, 과학기술사이버안전센터는 사이버 안전 분야에 세계 최초로 『사이버 안전 골든타임』을 제시하고, 과학기술분야 사이버안전 컨트롤타워로서의 역할 수행 및 위상 정립을 하고자 한다. 연구·개발 단계(플랫폼 구축→알고리즘 개발→적용)를 고려하여 목표치 단계적 상향 조정한 바, '17년 준자동분석 기반 보안관제 기술 원형개발·시범 적용 결과(22% 수준) 참고하여 대용량 위협데이터 자동분석 기술적용 및 보안관제 전용 인공지능 알고리즘 개발에 따른 최종 목표치를 50%로 설정하였다.

과학기술사이버안전센터는 침해위협에 대한 피해확산을 최소화할 수 있는 대응시간 5분을 사이버안전 골든타임으로 제시하였으며, 성과지표 달성도는 다음과 같이 산출한다.

※과학기술사이버안전센터에서 수행한 사이버위협 탐지·대응지원 총 건수* 대비 골든타임 이내 사이버위협 탐지·대응지원 건수의 비율

$$= \frac{\sum \text{골든타임(5분)이내 사이버위협 탐지·대응지원 건수}}{\sum \text{사이버위협 탐지·대응지원 총 건수}} \times 100$$

* 국가정보원에서 국가공공부문 보안관제센터에 일괄 배포하는 탐지규칙을 적용하여 범국가적으로 발생하는 동일유형·난이도 수준의 사이버위협을 KISTI가 처리한 전체 건수

<Table 4-2> 사이버안전센터 대응지원 신속도 관련 성과지표

센터명	성과지표	목표	목표치 산출근거	측정방법	자료출처
보건복지 사이버 안전센터	침해사고의심 적기 전파율 (단위 : %)	98.5%	탐지되는 의심유형 분석의 최소 시간 (목표치 20분)	20분이내 침해사고 처리건수 / 침해사고건수 ×100	보건복지 사이버안전센터 SLA 결과보고서
우정사업 사이버 안전센터	사이버침해사고 대응지원 신속도 (단위 : 시간)	15분	경보이벤트 발생 후 대응에 필요한 최소시간 (목표치 15분)	침해시도 탐지부터 분석, 대상기관 통보까지 소요시간	보안관제시스템 대응지원 DB (소요시간)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상기 핵심지표뿐만 아니라, '자동분석·처리를 통한 사이버위협 침해대응 신속성 향상'을 최종 목표 달성을 위해 2020년에는 크게 3가지 성과지표를 설정하였다.

<Table 4-3> 2020년 성과지표 및 실행계획

성과 지표	세부실행계획	측정방법
1. 사이버안전 골든타임 달성율	· 인공지능 기반 자동분석· 처리 기술적용을 통한 알려진공격 대응역량 강화	· 전체 사이버위협 탐지· 대응지원 건수 대비 골든타임 이내 대응지원 건수의 비율
2. 신·변종공격 대응수준	· 이상행위 탐지· 분석 기술적용을 통한 신· 변종공격 대응역량 강화	· 전체 사이버위협 탐지·대응지원 건수 대비 신· 변종공격 대응지원 건수의 비율
3. 침해사고 예방활동	· 실용적 보안기술 접목을 통한 침해사고 예방·대응 활동, 사용자 기술지원 강화	· 침해사고 예방을 위한 교육, 컨설팅 및 정보시스템 취약점 점검 실적

2. 성과지표 달성도

각 부문별로 연구사업 추진 결과 각 성과지표별로 100% 이상의 실적을 달성하였으며, 세부 실적에 대한 분석은 앞서 '제3장 연구개발 수행내용 및 결과'에서 다룬바 있다.

<Table 4-4> 부문별 성과요약

성과목표	성과지표	'20년 목표	핵심스펙	달성도
사이버안전 골든타임 달성률		50%이상	50.1% 사이버위협 탐지·대응지원 총 건수 : 460건 골든타임(5분)이내 탐지·대응 건수: 234건	100%
	1-1. 과학기술계 사이버위협 통합 대응체계 구축 및 서비스	-	통합보안정보분석시스템(SMARTer) 자동검증 룰셋 개발·적용 : 83건	-
	1-2. 인공지능 기반 대용량 위협데이터 자동분석·대응 기술연구 및 적용	-	보안관제 전용 인공지능 알고리즘 테스트 플랫폼 개발 완료 및 활용	-
신·변종공격 대응수준		10%이상	20.4 사이버위협 탐지·대응지원 총 건수: 460건 신·변종 위협 탐지·대응지원 건수: 94건	204%
	2-1. 대규모 네트워크 기반 이상행위 탐지분석·대응 기술연구 및 적용	-	·네트워크 이상행위 탐지·분석 기술연구(2건) ·침해위협정보 실시간 가시화 시스템 고도화	
침해사고 예방활동		100건	111건	138%
	3-1. 사이버보안 사전예방활동	-	·대외서비스 취약점 점검 활동:111건 ·침해사고 예방교육 가이드·홍보물발간:4건 ·주요정보통신기반시설 모의훈련·교육:2건	-
	3-2. 맞춤형 개인정보보호 컨설팅	-	·부서별 맞춤형 개인정보보호컨설팅: 7건	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 대표성과

주요내용	◦ 보안관제 전용 인공지능 알고리즘의 성능 테스트를 위한 플랫폼 개발 – 다양한 인공지능 알고리즘의 성능에 영향을 미치는 학습 및 테스트 데이터 생성, 특징 추출, 가중치 정규화 등을 효율적으로 수행하고, 알고리즘별 성능 평가 결과를 효율적으로 관리 가능 (인공지능 알고리즘 : Deep Learning, SVM, 클러스터링, Decision Tree 등) ◦ 인공지능 기반 차세대 보안관제 기술 방법론 설계 및 시스템 자체 개발 – 과학기술사이버안전센터에서 구축·운영 중인 전용장비(침해위협관리시스템)가 탐지한 대용량 보안정보에 시범 적용하여 실제 해킹공격을 실시간으로 분석 가능한 기반 기술 구축
우수성	◦ 폭발적으로 증가하는 사이버위협에 대한 대응 역량을 강화, 인력중심 보안관제 체계에서 발생하는 보안사각 지대 최소화 – 사이버위협 정보를 자동 분석 가능한 「인공지능 기반 차세대 보안관제 기술」 개발 – 1일 평균 1000만 건(약 1만건/1분) 이상 발생, 전문인력을 통한 전체 보안로그 분석 불가 ◦ 인공지능 기술을 활용한 「자동분석 알고리즘(모델) 생성→시스템 적용→자동분석」 全과정 자동화 – 과학기술사이버안전센터에서 개발·운용 중인 '보안이벤트 자동검증 기술'은 알려진 사이버 위협에 대해서 대응이 가능하고, 전문인력이 알고리즘을 수동으로 생성해야 함.
기대효과 (또는 파급효과)	◦ 보안관제 전용 인공지능 알고리즘을 자체 개발하고 알고리즘의 성능을 효율적으로 검증 및 극대화하기 위한 테스트 환경으로 활용 ◦ 인공지능 기반 차세대 보안관제 자동화 기술을 적용하기 위한 기반 기술로 활용 ◦ 선도적 기술 연구·개발·적용으로 과학기술정보 중심기관으로서의 위상제고 및 관계분야 기술보급·확산을 통해 국가 차원의 기술수준 고도화에 기여



< 인공지능 기반 차세대 보안관제 기술 적용 전·후 개념도 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

제5장 연구개발결과의 활용계획

1. 연구사업 성과의 활용 방안

가. 과학기술적 성과활용

보안관제 업무는 침해위협 수집센서를 통한 위협데이터 분석을 바탕으로 다량의 분석량을 평소에 추진해야하는 어려움을 지니고 있었다. 또한 기존의 보안관제 패러다임은 전문인력의 수동분석 위주로 관제업무가 수행되었다. 과학기술사이버안전센터의 금번 연구과제는 IT 활용자원의 폭발적인 증가로 인하여 보안 분석량도 증가하는 시점에서 인적자원으로 분석을 할 수 없는 대용량 분석데이터에 대한 처리기술을 확보하고 이를 기존의 수동식 관제분석의 업무체계를 준자동단계를 거쳐 검증을 수행한 후 향후 완전자동화를 목표로 추진되었다.

그 결과 세계 최고 수준의 보안관제 전용 인공지능 알고리즘 개발 및 고도화를 통해 일 평균 2천만건의 보안 이벤트를 처리하는 24시간 365일 분석 가능한 체제를 구축하였다는 점에서 대표적인 성과를 달성할 수 있다.

나. 국가·사회적 성과활용

국가적으로는 2018년 상반기 해킹 공격 수가 157만건에 달하고 월평균 26만건의 보안 공격이 감행되고 있는 시점에서 침해사고에 대한 대응 능력이 요구되는 시점에서 과학기술사이버안전센터를 중심으로 사이버안전 골든타임 도입으로 침해와 유출 시간 간격을 극적으로 신속히 대응할 수 있는 체계를 구축하였다는 점에서 의의를 둔다.

또한 과학기술사이버안전센터에서 독자 개발한 보안관제 전용 인공지능 알고리즘을 통해 타 분야 보안관제센터에 기술보급 및 확산하는데 역할을 수행할 것으로 기대하고 있으며, 실제 타 중앙부처 및 국가정보원의 사이버안보 보안관제부문 표준 프레임워크로 개발을 추진할 계획을 수립하고 진행 중에 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 기대효과

가. 기술적 측면

과학기술사이버안전센터는 연구개발과 운영을 병행하는 국내 유일의 사이버안전센터로써 보안관제 전용 인공지능 알고리즘을 선도적으로 연구 · 개발하여 이를 접목시켜 발전시킬 수 있는 역량을 갖추고 있다. 따라서 과학기술사이버안전센터에서 추진하는 성과목표인 사이버안전 골든타임 역시 타 보안관제센터에도 동일하게 적용하여 기술적 발전을 함께 향상시킬 수 있는 모멘텀으로 활용할 수 있다.

또한 과학기술사이버안전센터에서 개발된 인공지능 알고리즘과 차세대 보안관제시스템을 관계분야에 보급 및 확산하여 기술료 수입을 통한 지적재산권 확보 및 국가차원의 기술 수준 고도화에 기여할 수 있을 것으로 판단된다.

나. 경제적 · 산업적 측면

과학기술계의 연구데이터 생태계 보호수준 제고를 통하여, 과학기술분야에서 주도적으로 실현중인 국가 거대과제 · 도전과제에 대한 안정적 기반을 확보할 수 있다. 또한 국가 경쟁력 향상을 위한 기반 마련 측면에서 국가 연구개발의 핵심 인프라인 국가슈퍼컴퓨팅 및 국가과학기술연구망의 안정적 유통과 연구데이터 전반에 걸친 사이버 위기대응 수행체계가 안정적으로 운영되고 구축됨에 따라 글로벌 공동연구 및 연구그룹의 네트워킹을 위한 안전한 연구환경을 제공해준다는데 의의를 둔다.

다. 사회적 측면

보안관제서비스의 고도화를 통해 기존의 수작업 중심에서 자동화 중심의 패러다임 선도를 통해 보안관제 산업의 수요 창출로 사회적으로 요구되고 있는 일자리 창출에 기여할 것으로 예상된다. 또한 국가 안전분야(사이버안전)를 주도함으로써 과학기술정보분야에서의 전문기관에 대한 위상을 정립 · 강화할 것으로 기대된다.

과학기술분야에서의 사이버안전(재난) 문제를 획기적으로 해결할 수 있는 선도기술을 독자적으로 연구 · 개발함에 따라 강소기업으로의 기술확산을 통해 사회 전반에 걸친 과학기술서비스에 대한 대국민 신뢰도를 향상시킬 수 있는 계기로 마련한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 기업화 추진방안

과학기술사이버안전센터에서는 차세대 보안관제 원천기술을 정보보안 전문기업으로 보급・확산을 추진하였으며, 대용량 보안정보 실시간 자동분석 및 가시화 기술을 전문기업으로 이전을 수행하였다.

가. 사이버공격 자동분석 시스템 기술이전 현황

사이버공격 자동분석 시스템(SMARTer)에 대한 기술이전은 2018년도 대용량 보안정보 실시간 자동분석 기술과 2019년도 사이버공격 자동분석 룰셋 및 생성 노하우 기술에 대한 건으로 구분하여 정보보안 전문기업인 ㈜씨커스로 완료하였으며, 해당 기술은 보안전문기업에서 조달청 등록을 통해 보안관련 사업에 확산하는 단계에 이르고 있다.

사이버공격 자동분석 시스템의 기술력 확보를 위해 2018년도에 특허등록 1건(기존 6건 포함) 및 국제출원 1건을 진행하여 보안관제의 신속성 및 정확성을 획기적으로 향상할 수 있는 자동분석기술로 평가받고 있다.

나. 보안관제 가시화 기술이전 현황

가시화 기술의 경우 보안관제 및 네트워크 모니터링 전문기업인 ㈜하몬소프트로부터 기술이전을 추진하였으며(2018년 9월), 지능형 보안관제 및 네트워크 모니터링 기술로 침해위협관리시스템(TMS) 등의 센서에서 수집되는 보안로그를 실시간으로 처리하여 공격자 이상행위 및 상관관계를 자동으로 가시화하는 기술을 이전하였다.

가시화 기술의 특허 출원은 사이버 보안정보의 가시화 장치, 사이버 보안 정보 가시화 방법 및 사이버 보안 정보를 가시화하는 프로그램을 저장하는 저장매체로 구분하여 2019년도에 2건을 완료, 관련 기술력을 확보하였다.

2020년도는 방화벽 정책 및 로그 가시화 시스템을 ㈜유넷시스템으로 기술이전을 추진하였다. 보안분야 전문기술을 보안전문기업에 전수함으로 보안관련 사업 진흥에 기여하고 있다.

다. 인공지능 기술이전 현황

인공지능 기반 자동화 기술의 경우 자동화 플랫폼 및 보안관제 전용 AI 생성 모델에 대한 노하우를 중심으로 보안관제 전문기업으로 기술이전을 완료하였다(2019년 11월). 이는 과학기술사이버안전센터에서 기존에 자체적으로 추진하였던 보안관제 전용 인공지능 알고리즘을 개발한 이후 상용화를 위한 단계로 인공지능 기반 보안관제 모듈에 대한 기술력을 입증받은 사례라고

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

할 수 있다.

과학기술사이버안전센터에서 추진하는 기술기반 실용화 사업은 보안시장의 확장과 출연연 기반의 연구개발을 바탕으로 전문기업과 상생하는 모델로 자리잡고 있음을 평가할 수 있다. 전문기업에서는 본 기술을 활용하여 기존 보안관제 및 네트워크 모니터링 솔루션에 사이버공격 가시화 기술을 보완하여 상용화 및 세계시장 진출에 나설 것으로 계획하고 있으며, 보안관제 업무의 효율화 및 사이버안보 역량 강화에 기여할 것으로 예상하고 있다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제5장 참고문헌

[1] T. Limmer and F. Dresler, “Improving the performance of intrusion detection using dialog-based payload agregation,” 201 IEEE Conf. Comput. Commun. Work. INFOCOM WKSHPS 201, p. 82 - 827, 2011.

[2] F. Erlacher, W. Estgfaeler, and F. Dresler, “Improving Network Monitoring through Agregation of HTTP/1.1 Dialogs in IPFIX,” Proc. - Conf. Local Comput. Networks, LCN, p. 543 - 546, 2016.

[3] J. Sonchack, A. J. Aviv, and J. M. Smith, “Cros-domain colaboration for improved IDS rule set selection,” J. Inf. Secur. Apl., vol. 24 - 25, p. 25 - 40, 2015.

[4] Y. Jihon, S. Kangsik, and W. Yojae, “Encrypted Network Trafic Analysis Method via Secure Socket Layer Handshake Control,” In: Advanced multimedia and ubiquitous enginering. Springer, Singapore, p. 61- 6, 2017.

[5] A. Red and M. Kranch, “Identifying HTTPS-Protected Netflix Videos in Real-Time,” Proc. Seventh ACM Conf. Data Apl. Secur. Priv. - CODASPY ’17, p. 361 - 368, 2017.

[6] J. Muehlstein, Y. Zion, M. Bahumi, I. Kirshenboim, R. Dubin, A. Dvir, and O. Pele, “Analyzing HTTPS Encrypted Trafic to Identify User Operating System, Browser and Aplication,” 2016.

[7] B. Anderson and D. McGrew, “Identifying Encrypted Malware Trafic with Contextual Flow Data,” Proc. 2016 ACM Work. Artif. Intel. Secur. - ALSec ’16, p. 35 - 46, 2016.

[8] Jehyun Le, Hejo Le, "GMAD: Graph-based Malware Activity Detection by DNS trafic analys is", Computer Communications, Vol. 49, No. 1, p. 3-47, Aug. 1. 2014.

[9] Rashad Aliyev, Dongwon Seo, Hejo Le, "DROP-FAST: Defending against DDoS Atacks using Cloud Technology", Int'l Conf. on Security and Management (SAM), Jul. 24. 2013.

[10] Kaspersky, APT Trends Report Q2, https://securelist.com/apt-trends-report-q2-2017/79332/, (2017.8)

[11] Kaspersky, DDOS attacks in Q1, https://securelist.com/apt-trends-report-q1-2017/78285/, (2017.3)

[12] FireEye, M-Trends 2017 - A View From the Front Lines, https://www.fireeye.com/blog/threat-research/2017/03/m-trends-2017.html, (2017.3)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[13] Kaspersky, Threat Prediction for 2018, https://cdn.securelisti.com/files/2017/12/KSB_Predictions_2018_eng.pdf, (2017.11)

[14] Hillary Sanders, Joshua Saxe, “Garbage In, Garbage Out: How purportedly great ML models can be screwed up by bad data”, Blackhat, US-17, 2017.7.

[15] Whitehouse, “Presidential Executive Order on Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure”, https://www.whitehouse.gov/presidential-actions/presidential-executive-order-strengthening-cybersecurity-federal-networks-critical-infrastructure/, 2017.11.

[16] IBM, “Cybersecurity in the cognitive era: Priming your digital immune”, IBM, Somers NY, 2016.11

[17] NormShield, “Cyber Security with Arificial Intellignece in 10 Question ”, https://www.normshield.com/cyber-security-with-artificial-intelligence-in-10-question/, 2018

[18] Annabelle Graham, “Arificial intelligence in cyber security ”, https://www.itgovernance.co.uk/blog/artificial-intelligence-in-cyber-security, 2018.3

[19] Veeramachaneni, Kalyan, et al. "AI^2: training a big data machineto defend." Big Data Security on Cloud (BigDataSecurity), IEEE International Conference on High Performance and Smart Computing(HPSC), and IEEE International Conference on Intelligent Data and Security (IDS), 2016 IEEE 2nd International Conference on. IEEE, 2016.

[20] N. Hubballi and S. Vinoth, “False alarm minimization techniques in sig nature-based intrusion detection sys tems: A survey,” Computer Communications, vol. 49, pp. 1-17, Aug. 2014.

[21] G. Spathoulas and K. Sokratis, “Methods for post-processing of alerts in intrusion detection: A survey,” International Journal of Information Security Science, vol. 2, no. 2, pp. 64-80, June 2013.

[22] H. Liang, L. Taihui, X. Nannan, and H. Jiejun, “False positive elimination in in trusion etection based on clustering,” 12th International Conference on Fuzzy Systems and Knowledge Discovery (FSKD), pp. 519-523, Aug. 2015.

[23] Cisco, “Annual Cybersecurity Report”, Cisco 2018, 2018.2

[24] Cisco, “Annual Cybersecurity Report”, Cisco 2018, 2018.2

[25] 한국인터넷진흥원, “사이버위협 동향보고서”, 2017

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니디

[26] 국가정보원, “국가정보보호백서 2018”, 2018

[27] 국가정보원, “국가사이버안전관리규정”, 2013

[28] 국가정보원, “정보보안기본지침”, 2015

[29] 행정안전부, “개인정보 보호법”, 2017

[30] 행정안전부, “개인정보 보호법 시행령”, 2018

[31] 행정안전부, “표준 개인정보 보호지침”, 2018

[32] 한국과학기술정보연구원, “보안관제 탐지규칙 보안관리지침”, 2014

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 주 의 -

1. 이 보고서는 한국과학기술정보연구원에서 수행한 주요 연구사업보고서입니다.

2. 이 보고서의 내용을 발표 또는 인용할 때에는 반드시 한국과학기술정보연구원에서 발행한 보고서임을 밝혀야 합니다.

3. 국가과학기술 기밀유지에 필요한 내용은 대외적으로 발표 또는 공개를 금합니다.